



Financiado por
la Unión Europea
NextGenerationEU



Plan de
Recuperación,
Transformación
y Resiliencia



INSTITUTO NACIONAL DE CIBERSEGURIDAD

ENTENDIENDO LA MENTE DEL CRIMEN



Campus Tecnológico-Deportivo para
Jóvenes

Universidad de Oviedo



Universidad de Oviedo



Escuela de
Ingeniería
Informática
Universidad de Oviedo

JOSÉ MANUEL REDONDO LÓPEZ PROYECTO "M-31 'SEGURA'" v1.2





ACERCA DEL USO DE CONTENIDO GENERADO POR IA



José Manuel
Redondo López

- En esta presentación se usan algunas imágenes generadas por IA
 - Salvo error, **cualquier imagen a la que no se le atribuya una fuente u origen expreso**
- La IA generativa usada para ello es Microsoft Copilot 
 - <https://copilot.microsoft.com/>
- Se ha restringido el uso de estas imágenes a la ilustración de los conceptos explicados en algunas de las páginas
 - Es decir, **como refuerzo visual** a lo explicado en algunas transparencias
 - El procedimiento ha sido describirle a la IA con toda la precisión posible los elementos que quería que apareciesen en la imagen (prompt)
 - Y la selección del mejor resultado obtenido, a juicio del autor de esta presentación
 - **No se ha mencionado ni indicado que se copie el estilo a ningún autor, ni que se plagien obras concretas**
- El autor declara expresamente su apoyo al trabajo de los artistas, ilustradores y creadores, de extrema importancia en la actualidad
 - El uso de estas técnicas se ha hecho solo con fines de mejora de las explicaciones, y cuando la alternativa era **no contar con refuerzos visuales** por restricciones de tiempo y presupuesto

¡BIENVENIDO!



José Manuel
Redondo López

- *¿Nunca te has parado a pensar por qué hay tantas ciberestafas?*
- **Pues es por dos motivos**
 - **Mucho ciberdelincuente** 🧑💰 : El culpable **siempre** es el delincuente
 - Y “**empresas del crimen**”: organizadas, que hasta cotizan por sus empleados (lógicamente con una buena tapadera)
 - **Falta de formación de las víctimas** 🧒🧒🧒
 - El primer motivo es inevitable (como Thanos 🦋)
 - Así que no nos queda otra que protegernos...
- **Esta presentación quiere dejarte muy claro lo primero, para que hagas mejor lo segundo 😊**



La cantidad de delincuentes que hay en Internet (individuales u organizados) es **ENORME**. No queda otra que aprender “**ciberdefensa**”. Y para eso, lo mejor es entender bien cómo piensan

¿Y TODO EL RESTO DE MATERIAL?

• ¿Sabías que en Asturias hay un programa de formación integrado por niveles en ciberseguridad? Ahora ya sí 😊

- Yo soy la persona que está detrás de esta idea
- Toco muchos “palos” y cada uno tiene un nombre de barco

• ¿Cómo “enrolarte” en la armada asturiana?

- Ofrezco **muchos contenidos gratuitos**
 - Durante este curso se hará referencia a otros complementarios que te regalo y que forman parte de la misma iniciativa
 - Puedes encontrarlos en: https://github.com/jose-r-lopez/Formacion_-Seguridad_Joven/wiki
 - En el futuro quiero subir videos explicando cada curso en mi canal: <https://www.youtube.com/@JoseRedondo-dj7xk>
- También **imparto clases en la Universidad de Oviedo**
 - Grado en Ingeniería Informática del Software (GIISOF)
 - Máster Universitario en Ingeniería Web (MIUNGEWEB)
 - Micro credenciales (MU), Diplomas y Máster de Formación Permanente (MFP) en temas de Ciberseguridad (Títulos Propios)



TODOS (gratuitos y no gratuitos) están conectados entre ellos y regidos por los mismos estándares de creación y criterios de calidad

Gratis no implica peor, sino pensado para servicio público

Itinerario de concienciación

Itinerario de investigación

Itinerario técnico



La "Armada Asturiana" por José Manuel Redondo López



Respuesta a indecentes
S-64 "Narval" ●



No apto para menores
Peligros para los menores en Internet
"A-71 Juan Sebastián Elcano" ●



Investigar Redes Sociales
Técnicas de investigación para RRSS
F-31 "Descubierta" ●



Configuración Segura Básica
Asegura tus PCs y dispositivos móviles
R-01 "Dédalo" ●

Rango 1
(Marinero)



La Mente del Crimen
Mentes criminales y engaño
M-31 "Segura" ●



Ataques contra Personas
Ciberacoso
P-74 "Atalaya" ●



Investigación de Webs
Detección de webs problemáticas
S-74 "Tramontana" ●



Investigación de Personas
Buscar a padre, hijo y espíritu santo
"Santísima Trinidad" ●



Virtualización Básica
Creación y uso de máquinas virtuales
R-11 "Príncipe de Asturias" ●

Rango 2
(Marinero de Primera)



Ciberseguridad General
Ciberseguridad general para el día a día
F-74 "Asturias" ●



Crime-spotting
Ejemplos de fraudes reales para su estudio
"Nautilus" ●



Para vosotr@s, Programador@s
Técnicas básicas de codificación segura
C-23 "Ferrol" ●



Vigilancia de Redes
Ataque y defensa en redes modernas
F-83 "Numancia" ●

Rango 3
(Cabo)





La "Armada Asturiana" por **José Manuel Redondo López**



Introducción a la Ciberdefensa Personal

Técnicas generales contra ciberataques (Niveles A1, A2)
Cursos G-9, PDI, Pr. DIGICOMPEDU. "BPM P-51 'Asturias'"



Investigación con Fuentes Abiertas (OSINT)

Técnicas de investigación con fuentes abiertas
OCW (parcialmente). "A-21 Poseidón"



Defensa contra el Cibercrimen

Identificación y lucha contra el cibercrimen
Divulgación pública, cursos. P-45 Audaz"

Rango 4
(Sargento)



Ciberdefensa Personal Avanzada

Técnicas avanzadas contra ciberataques (Niveles B1, B2)
Cursos G-9, PDI, Pr. DIGICOMPEDU. "BPM P-51 'Asturias'"



Seguridad de Redes

Threat hunting
TBA. L-52 "Castilla"



Administración Segura de SO

Infrastructure as Code
MUINGEWB, OCW. L-62 "Princesa de Asturias"



Seguridad de Sistemas Informáticos

Capacitación técnica general en ciberseguridad
Grado en Ing. del Software, OCW. S-81 "Isaac Peral"

Rango 5
(Suboficial Mayor)



Liderazgo en Ciberdefensa para Equipos

Herramientas y estrategias de protección (Nivel C1)
Proyecto DIGICOMPEDU. "BPM P-51 'Asturias'"



Identificación y Análisis de Vulnerabilidades en Web

Seguridad ofensiva:
Reconocimiento y Explotación
MUINGEWB, TK-210 "красный октябрь" (Octubre Rojo)



Arquitecturas de Seguridad

Arquitectura de infraestructuras seguras
Guías INCIBE, F-105 "Cristóbal Colón"



Desarrollo Seguro de Software

Platform engineering seguro
Guías INCIBE. F-113 "Menéndez de Avilés"

Rango 6
(Capitán de Fragata)



Innovación e Investigación en Ciberdefensa

Avances e innovación en ciberdefensa (Nivel C2)
Proyecto DIGICOMPEDU. "BPM P-51 'Asturias'"



El lado oscuro de la red

Desinformación y ciberguerra
TBA. "Flying Dutchman"



Post-Exploiting e Intrusión en Sistemas

Seguridad ofensiva:
Post-Explotación
TBA. K-329 "Belgorod"



Protección de Servidores y Aplicaciones Web

CISOs de perfil técnico
MUINGEWB. D-73 "Blas de Lezo"

Rango 7
(Vicealmirante)





La "Armada
Asturiana" por
José Manuel
Redondo López



Introducción a la construcción de sistemas seguros y rol del CISO

*CISOs de perfil técnico
Microcredenciales. C-33
"Blas de Lezo"*

*(D-73 + coordinación de 12
microcredenciales)*



Explotación y Post- Explotación de Sistemas

*Seguridad ofensiva: Recorrido
completo del MITRE ATT&CK
TBA, RK-085 "Адмирал Нахимов"
(Admiral Nakhimov)*

(TK-210 + K-329)

**Rango 8
(Almirante)**



Defensa Integral de Sistemas

*CISOs de perfil técnico +
formación integral en ramas
técnicas
TBA. B-41 "Sigillum Regiae
Universitatis Ovetensis" (SRUO)*

(D-73 + F-113 + L-62)



Técnicas, Tácticas y Procedimientos de Explotación y Post- Explotación a Máquinas y Usuarios

*Seguridad ofensiva: Recorrido
completo del MITRE ATT&CK +
OSINT Framework
TBA, B-51 "Rex Pelagius"*

(RK-085 + A-21)

**Rango 9
(Almirante
General)**



Universidad de Oviedo

ÍNDICE



Phishing y ransomware



Malware en general y phishing



El ransomware



Otros crímenes comunes



Mentes criminales



Objetivos de un ciberdelincuente



Psicología de los ciberdelincuentes



Formas de engaño



Documentos Maliciosos



Documentos con enlaces maliciosos



Documentos con malware dentro



Documentos falsos



Llamadas y mensajes falsos



Webs falsas



Identidades falsas



La IA usada para potenciar el engaño



El futuro...



Accede a este
Módulo en YouTube

LA MENSAJERÍA EN LA ACTUALIDAD



José Manuel
Redondo López

- Hoy día tienes dos formas de hablar con alguien
 - El email, el clásico “boomer”, pero que aún se usa mucho 🧑
 - Las **aplicaciones de mensajería instantánea** 📱
 - O la **mensajería integrada** en redes sociales, juegos... 💬
- Pero tenlo claro: el email es más **inseguro** 😬
 - El emisor se puede falsificar con bastante facilidad 😬
 - Sus contenidos no van cifrados normalmente 🔒
 - *¿Enviaste algo vergonzoso? ¡Pues se puede interceptar más fácilmente!*
 - **Consecuencia: Hay más fraudes que por mensajería**
- Pero no te engañes: Por todos esos sitios te pueden llegar estafas en cualquier momento
 - Y, de hecho, **son muy similares**
 - Tenemos que saber **cómo piensan quienes las hacen**



Internet está plagado de estafadores/as. Esto son hechos, no es algo que me invente yo.
¿Cómo van a llegar a ti?
Mandándote un mensaje con malas intenciones, obviamente 😊

LA MENSAJERÍA EN LA ACTUALIDAD



José Manuel
Redondo López

- Hoy en día hay grandes proveedores “gratuitos” de
 - Email: Gmail, Outlook, Yahoo...
 - Mensajería: WhatsApp, Telegram...
- Pero no son realmente “gratis”, al igual que las redes sociales y otros servicios
 - Recuerda que lo vimos en la **F-31 “Descubierta”**
 - **Nuestros datos son el pago por usarlos**
- Y dirás: “Bueno, pero nos protegen de posibles ataques a cambio” 
 - Y es verdad, pero como se dice siempre, **la seguridad no es perfecta**
 - Los delincuentes **aprenden a saltarse los sistemas de protección**, que deben evolucionar
 - Pero al final **van a por el más obvio: Tú** 
 - Por eso es importante que sepas cómo operan
 - Porque tú eres el último sistema de protección contra los ataques de los delincuentes
 - **¿Preparado para “subir de nivel”?** 

< Ir al Índice



PHISHING Y RANSOMWARE

Siempre que pasa algo, es uno de estos dos



 Malware

 Ransomware

 Otros crímenes



¿QUÉ VAMOS A VER EN ESTE BLOQUE?



José Manuel
Redondo López

● En este bloque te voy a enseñar...

- Cuáles son las **principales fuentes de ataques** hoy en día
- Cómo actúa un **malware** típico
- En qué consiste el **phishing** y los tipos que existen
 - Y consejos generales para prevenirlo
- En qué consiste el **ransomware** y cómo actúa
 - Y el enorme daño que puede hacer...
- **Otros tipos de ataques** comunes



¿POR DÓNDE ME PUEDE VENIR EL SUSTO?

- **Ciberataques por mensajería hay muchos**
 - Como se ve en el “**Nautilus**”
- **Pero hay dos que son las “estrellas”**
 - **Infecciones por malware** 🐛 (especialmente ransomware 💰)
 - Está produciendo **pérdidas económicas masivas** a empresas (y personas)
 - Incluso cierre de negocios (**ruina** 🏠), hospitales (**muerte** 💀) y paralización de actividades (**miseria** 🥲)
 - Lo más probable es que afecte a tu máquina y a todas las de su misma red, porque **se propagan** 🔄
 - Tu casa, el trabajo de todos los que viven en ella
 - **Te daña a ti**, a **tus compañeros**, a **tu familia** y posiblemente **a su medio de vida**
 - **Ser víctima de timos / phishing** 🐟 (cualquier clase de engaño)
 - Las principales consecuencias son el **robo de dinero y de información personal** (privada, comprometedor...)
 - La información robada **se vende en “mercados del crimen”**
 - Lo vimos en el **S-74 “Tramontana”**
 - O se usa como “tapadera” para hacer más timos (**suplantación de víctimas**)



La “pesca” (de víctimas que caigan en un engaño por falta de formación o tener un descuido o mal día) también se practica en Internet, por desgracia ☹

TIPOS DE CIBERATAQUES



José Manuel
Redondo López

● Tipos de ciberataques hay muchos

- Y con el tiempo van apareciendo más... 🤔

● En esta sección veremos una muestra de ellos

- Centrándonos en los más comunes que mencionamos antes: phishing 🐟 y ransomware 💰
- Luego veremos una muestra de otros
 - Pero para conocerlos más en detalle tenemos otro curso el **"Nautilus"**
- Con el phishing 🐟 y el ransomware 💰 cubrimos la gran mayoría de amenazas que podemos sufrir en nuestro día a día

TIPOS DE CIBERATAQUES



MALWARE

Es la abreviatura de "Malicious Software" y se trata de programas que dañan los equipos informáticos y/o extraen información de los usuarios sin que éstos consientan su autorización.

SPYWARE

Es un software espía que recopila información de un ordenador sin conocimiento de su propietario y la transfiere a otros dispositivos.

DDOS

Ataques a webs que provocan su colapso y la denegación de servicio a los clientes.

TROYANOS

Son programas que al ejecutarlos permiten un acceso remoto al equipo infectado.

PHISHING

Se trata de emails que suplantán la identidad de un servicio o compañía, por ejemplo, de una entidad bancaria, solicitando datos confidenciales del usuario para usarlos en beneficio propio.

RANSOMWARE

"Ransom" significa "rescate" en inglés, por lo tanto, es un tipo de programa que restringe el acceso a determinados archivos y pide un rescate para liberar esta información.



Malware en general y su relación con el phishing

Un malware es software...creado para hacer algún mal

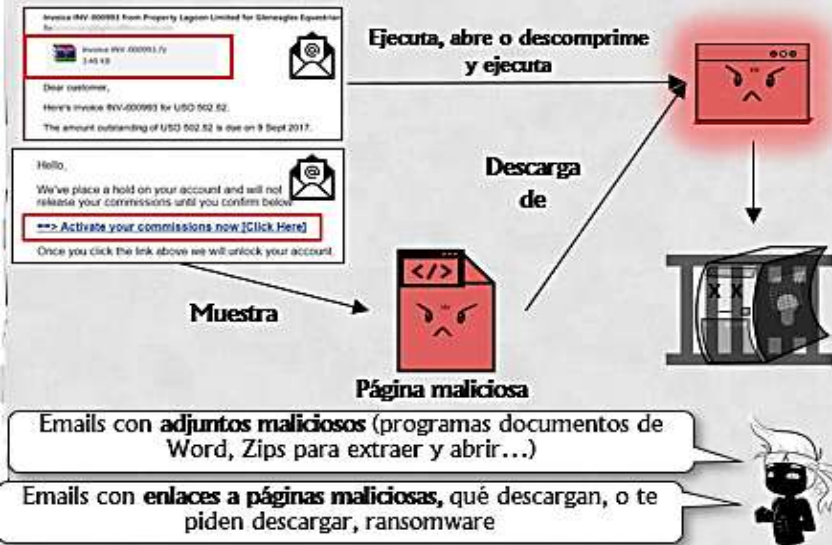


MALWARE: FORMAS DE QUE NOS LLEGUE...

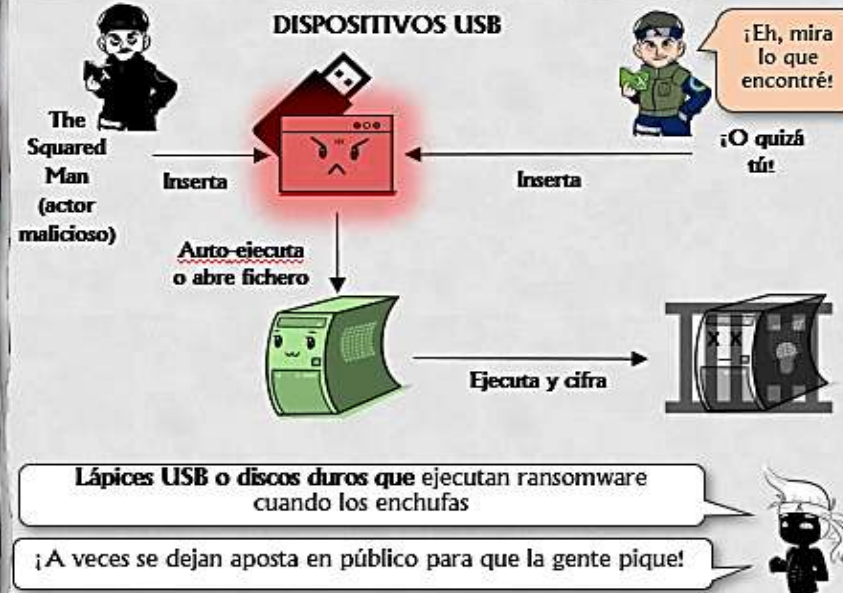


José Manuel
Redondo López

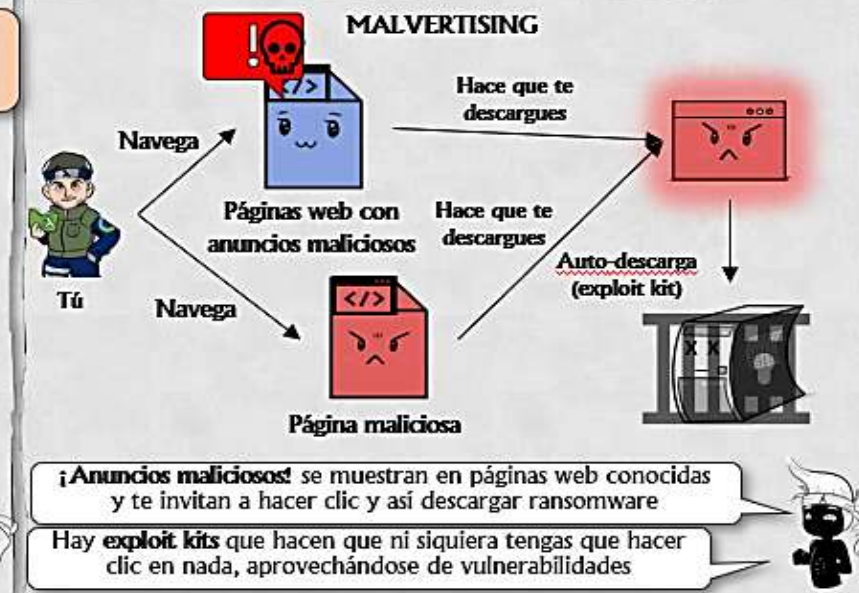
TROYANOS



DISPOSITIVOS USB



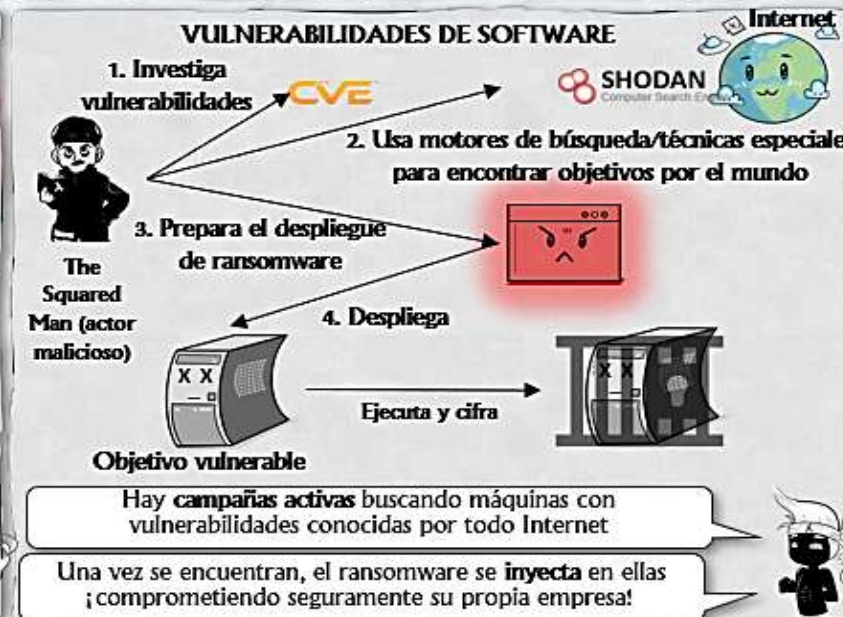
MALVERTISING



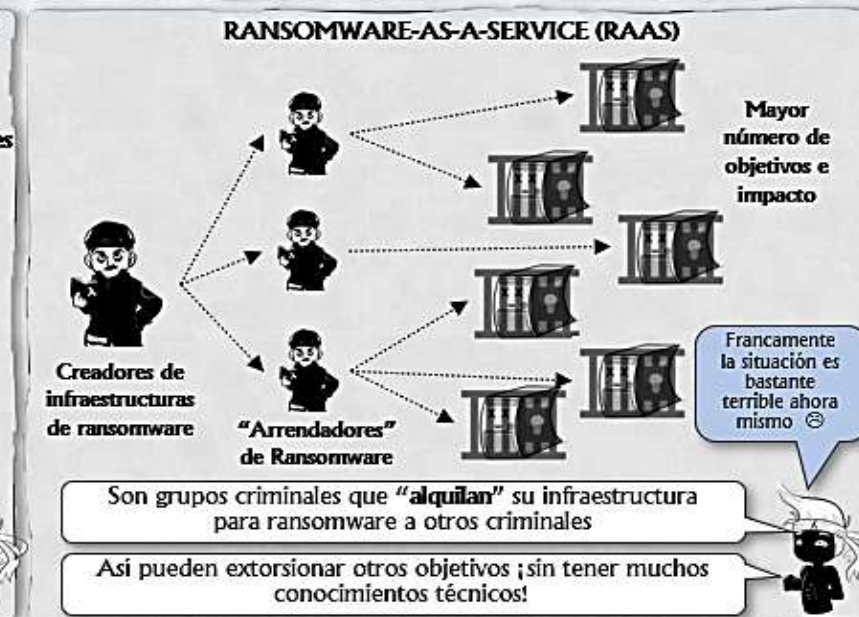
REDES SOCIALES Y MENSajerÍA



VULNERABILIDADES DE SOFTWARE



RANSOMWARE-AS-A-SERVICE (RAAS)



¿CÓMO ACTÚA UN MALWARE / RANSOMWARE HABITUALMENTE?

- **Lo típico: Abres un fichero que tiene “bicho” (malware)** 
 - Que te llega junto con un mensaje que **te engaña para que lo abras**
 - Al hacerlo, infecta tu PC o móvil, sin que tu antivirus lo detecte
- **Muchos no solo infectan, buscan vías para propagarse** 
 - Empiezan a **buscar otras máquinas** a tu alrededor 
 - En tu red de casa, las del trabajo de tu gente...
 - La idea es encontrar una vulnerabilidad en ellas que le permita propagarse
 - Carpetas compartidas, falta de parches, problemas de configuración...
 - O leen tu **lista de contactos** de tu cuenta de correo 
 - Para enviarse a todo el mundo que esté en tu libreta de direcciones
- **Ahora imaginemos que ha infectado a otros PCs /móviles**
 - **El proceso se repite con cada usuario infectado y se sigue propagando...**
 - Por tanto, la cantidad de **afectados puede aumentar enormemente** de forma muy rápida ☹️ (¡la que has liao por no tener cuidao!)



Los antivirus son necesarios, pero no son 100% infalibles. Es como las vacunas: reduces las posibilidades de enfermarse, pero nunca son 0%

¿QUÉ RELACIÓN HAY ENTRE MALWARE Y PHISHING?

- **¡Toda!**: Los mensajes de phishing son la vía favorita para propagar malware
 - Se denominan “de phishing” si son engañosos, **sin importar el tipo de engaño** que puedan contener
- **Pero normalmente se distinguen tres tipos**
 - **Phishing “general”** 🐟: Mensajes que se envían en masa a ver si alguien pica
 - Envían **millones a coste mínimo**, por lo que muchas veces, aunque pique el 1%, ya sacan rendimiento
 - **Spear phishing** (“pesca con arpón”) 🐉: Cuando el mensaje **se personaliza** (y se envía) a un grupo de personas particular porque los delincuentes tienen sus direcciones
 - Normalmente, **una filtración de datos de una empresa** (y como últimamente hay pocas...)
 - Alumnos y profesores de X colegio, miembros de un equipo de futbol concreto, etc.
 - **Whaling** (“pesca de ballenas”) 🐳: Un **spear phishing** que se envía a una sola persona, un **“pez gordo”**
 - Van a por alguien que “maneja” 💰, porque saben que si lo consiguen van a tener un gran beneficio
 - El mensaje está totalmente personalizado para esa víctima concreta 🤖
 - Investigándola, mirando sus contactos...
 - Hacen una inversión en investigación porque saben que sacarán **“rendimiento” de ella** 💵 🏠 📧 📱 📺
 - Hasta en esto hay niveles...

PHISHING



José Manuel
Redondo López

● A los “plebeyos” nos “toca” el general o el spear phishing 🐟

- Mensajes imitando a los de la empresa real
 - Bancos, compañías de transporte, de tarjetas de crédito, de email, de redes
 - O toda clase sociales, servicios (Amazon, PayPal, eBay, Netflix...)...
- Con webs asociadas falsas
 - Clonando / imitando la original

● Además de propagar malware, buscan los datos de la víctima 📄

- Ej.: El usuario que tiene la víctima dado de alta en los servicios de la empresa suplantada
- A través del **enlace** que contiene el mensaje
- La víctima intenta entrar en su cuenta en la página falsa creyendo que es la real y... ✨

Fuente: INCIBE

DECÁLOGO ANTIPHISHING

EL PHISHING es un ataque que se inicia enviando a la víctima una comunicación en la que, suplantando a una entidad conocida, le piden que haga clic en un enlace, descargue un fichero o envíe información sensible.

El objetivo es **robar** cuentas, contraseñas y otros datos, o **infectarle** con malware.

SIGUE ESTE DECÁLOGO PARA HACERLE FRENTE.

USERNAME:

PASSWORD:

CLICK

1. **Instala un antivirus** con antiphishing para correo y páginas web. Mantenlo actualizado, con las firmas al día y activado.

2. **Actualiza el software de tus sistemas y de tu web** en cuanto conozcas que hay una actualización, pues se aprovechan de estos fallos para instalar el malware.

3. **Permanece atento** para reconocer los ataques de **ingeniería social**. Si tienen prisas, te adulan o te amenazan, ¡desconfía!

4. Si tienes dudas de la veracidad del mensaje o de su procedencia, **contacta por otro medio con el remitente** y confirma que realmente te ha enviado ese mensaje antes de responder o hacerles caso.

5. No hagas clic en una **URL** para introducir tus datos sin antes pasar el ratón sobre el enlace para comprobar si es legítimo el sitio a donde te dirige.

6. Desconfía de las **URL acortadas**, pues no se puede comprobar si el destino es legítimo o no. Los sitios legales no las utilizarán para pedirte datos.

7. Antes de hacer login en una web, **comprueba su identidad**: consulta los datos de certificado, en el candado de la barra de navegación. Verifica que usa https://.

8. Antes de introducir el email, y otros datos sensibles, en una web o en un formulario **lee y comprende la política de privacidad y el aviso legal** para evitar dar tu consentimiento a que cedan esos datos a terceros y terminen en manos de ciberdelincuentes.

9. Ante la menor sospecha: **¡borra el mensaje o cuelga esa llamada!**

10. Al descargar un fichero no hagas clic en «habilitar el contenido» salvo que confíes en la fuente de dónde procede. Si al descargar un fichero te solicita permiso para **habilitar el contenido**, no te fíes, podría iniciarse la descarga del malware.

PHISHING Y PRECAUCIÓN



José Manuel
Redondo López

● El problema es **tan grave** que el INCIBE (y muchas otras instituciones) tiene muchísimo material de formación para prevenirlo

- <https://www.incibe.es/ciudadania/tematicas/ingenieria-social-fraudes-online/phishing>
- Voy a enseñarte unos cuantos, **pero te recomiendo que entres y leas todo lo que tienen**

¿QUÉ ES EL PHISHING?

Fraude que consiste en enviar correos electrónicos que suplantan a entidades y empresas conocidas para engañar a los usuarios bajo cualquier excusa y robar así sus datos personales, bancarios, contraseñas, etc.

¿Has caído en el engaño? Sigue estos consejos:

- 1 Cambia tu contraseña lo antes posible si la has facilitado. Y actualiza la de otros servicios online en los que utilizaras la misma.
- 2 Contacta con tu entidad bancaria si has proporcionado datos bancarios.
- 3 Realiza búsquedas en Internet de tus datos personales para comprobar que no se estén usando.
- 4 Reenvía el correo fraudulento a INCIBE (incidencias@incibe-cert.es)
- 5 Denuncia ante las Fuerzas y Cuerpos de Seguridad del Estado proporcionando las evidencias.
- 6 Y si aún tienes dudas, contacta con 'Tu Ayuda en Ciberseguridad' de INCIBE, llamando al 017, o a través de WhatsApp (900 116 117) o Telegram (@017INCIBE).

1 La dirección del remitente no coincide con el nombre de la empresa o entidad que dice ser.

2 El mensaje contiene errores gramaticales o de ortografía.

3 Apela a tus emociones para que accedas a las peticiones de manera urgente.

4 Facilita un enlace para realizar la gestión en cuestión.

5 Lleva adjunto un archivo que supuestamente es un documento oficial.

¡Cómo actuar ante él?
¡No respondas al email sospechoso! En caso de duda, contrasta la información con la empresa que supuestamente te está contactando a través de sus canales oficiales.

017

Financiado por la Unión Europea NextGenerationEU

GOBIERNO DE ESPAÑA MINISTERIO DE ECONOMÍA Y TRANSFORMACIÓN DIGITAL

Plan de Recuperación, Transformación y Resiliencia

España | digital 2026

incibe INSTITUTO NACIONAL DE CIBERSEGURIDAD

OSI Oficina de Seguridad del Informante

PHISHING Y PRECAUCIÓN



José Manuel
Redondo López

Cómo identificar un correo electrónico malicioso



Cientos de emails fraudulentos llegan a nuestras bandejas de correo y, aunque muchos son eliminados, otros consiguen su objetivo, ser leídos. **Depende de nosotros saber cómo identificar un correo electrónico malicioso:**

3 OBJETIVO DEL MENSAJE

¿Cuál es el objetivo del correo?

Una entidad de servicios como el banco, suministros del hogar (agua, gas) u otros nunca te pedirá tus datos personales por correo. Además, si es de carácter urgente, amenazante o con ofertas y promociones muy atractivas, es muy posible que sea un fraude.

5 ENLACES

¿Los enlaces llevan a una página legítima?

Sitúa el cursor encima del enlace, o mantén presionado el enlace en dispositivos móviles, podrás ver la URL real a la que redirige. Si no coincide o es una web sin certificado de seguridad (https://), no hagas clic.

1 REMITENTE

¿Esperabas un email de esta persona/entidad?

Comprueba que el email coincida con la persona o entidad remitente que dice ser o si está suplantando a alguien.

2 ASUNTO

¿Capta tu atención el asunto del correo?

La mayoría de correos fraudulentos utilizan asuntos llamativos e impactantes para captar tu atención. Ten en cuenta esta consideración.

4 REDACCIÓN

¿Tiene errores ortográficos o parece una mala traducción de otro idioma?

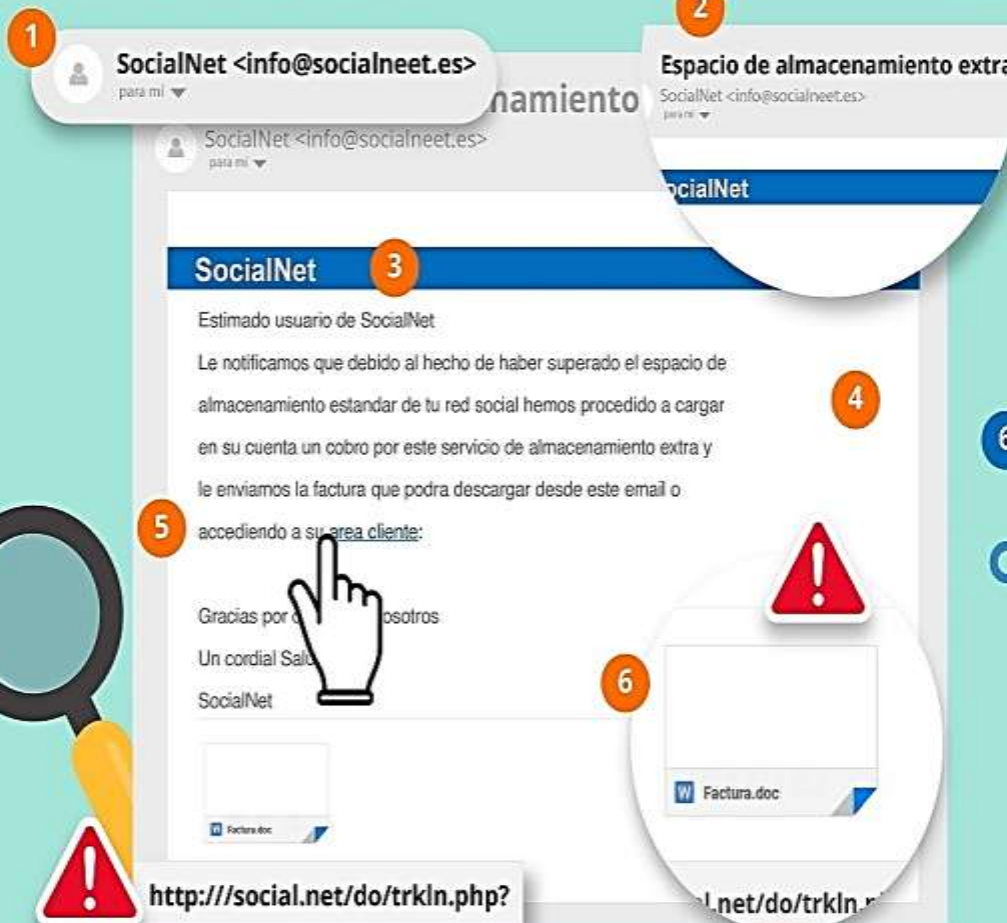
Revisa la redacción en busca de errores de ortografía o gramaticales. Además, si no está personalizado o parece una traducción automática, sospecha.

6 ADJUNTOS

¿Contiene un archivo adjunto que no estabas esperando o es sospechoso?

Analiza los adjuntos antes de abrirlos, puede tratarse de un malware.

Los antivirus y analizadores de ficheros te ayudarán a identificar si están infectados.



Finalmente, **no olvides utilizar el sentido común y aplicar todos los contenidos que se encuentran en la OSI para convertirte en un usuario ciberseguro.**

¡Sigue estas pautas y disfruta de un correo electrónico libre de riesgos!

CAMPAÑAS DE PHISHING



¡¡ESTATE ATENTO!!

Es habitual que cada cierto tiempo se lancen ataques de Phishing suplantando la identidad de Organizaciones y Bancos.

Estos correos contienen mensajes fraudulentos para los ciudadanos requiriendo sus datos personales o credenciales de accesos a través de enlaces falsos.

RECUERDA

- Si recibes un correo de estas características **debes desecharlo**.
- **No facilites datos personales** o corporativos en páginas web de dudoso origen.
- Si recibes un correo electrónico de un remitente desconocido **no accedas a sus enlaces** ni descargues sus ficheros adjuntos.
- **Las Organizaciones Legítimas no suelen mandar enlaces.**
- El phishing es una técnica consistente en la **suplantación de identidad** de un organismo o entidad **cuya finalidad es robar tus datos** personales o credenciales de acceso.
- Puedes informarte de este y otros tipos de ataque en las siguientes páginas:

Oficina de Seguridad del Internauta

<https://www.osi.es/es>



Instituto Nacional de Ciberseguridad

<https://www.incibe.es/>



IDENTIFICA UN CORREO DE PHISHING

De: Banco <jose_ramos@cochesymotos.es> → Remitente desconocido, no coincide con la entidad

Asunto: Tu cuenta ha sido bloqueada

 BANCO

Hola cliente,
Tu cuenta ha sido bloqueada
Motivo: alta de información.

→ Ingeniería social, genera situación de alarma

Encaja con la “estafa del susto” veremos luego

Detalles

Falta información personal.
Falta información de facturación.
Falta información de la tarjeta de crédito.

→ Faltas de ortografía, una entidad legítima no las tendría

Haga clic en el enlace y siga los pasos para desbloquear su cuenta.

ENLACE → Enlace. Una entidad legítima no pone enlaces

Este mensaje validado, de manera exclusiva, a su destinatario y puede contener información confidencial y sujeta al secreto profesional, cuya divulgación no está permitida por Ley.

→ Firma de correo distinta a la habitual

PHISHING Y PRECAUCIÓN: SPEAR PHISHING CON BANCOS



José Manuel Redondo López

'SMISHING' BANCARIO POR SMS

El 'smishing' (combinación de las palabras SMS y 'phishing') es el intento de fraude para obtener información personal, financiera o de seguridad a través de un mensaje de texto.



¿CÓMO LO HACEN?

El mensaje de texto normalmente te pedirá que hagas clic en un enlace o que llames a un teléfono para "verificar", "actualizar" o "reactivar" tu cuenta. Pero... el enlace te lleva a una página web falsa, y el número de teléfono es el de un estafador que suplanta a una empresa.

¿QUÉ PUEDES HACER?

- No hagas clic en enlaces, adjuntos o imágenes que recibas en mensajes de texto no solicitados sin antes verificar el remitente.
- No te apures. Tómate tu tiempo y haz las comprobaciones necesarias antes de responder.
- Nunca respondas a un mensaje de texto que te solicite tu PIN o la contraseña de tu banco, o cualquier otra credencial de seguridad.
- Si crees haber respondido a un 'smishing' y proporcionado tus datos bancarios, contacta con tu banco de inmediato.

BANCA ELECTRÓNICA FRAUDULENTO

Los 'phishing' bancarios vía correo electrónico suelen incluir enlaces que te redirigen a una página web fraudulenta, donde te solicitan tus datos personales y financieros.



¿QUÉ SEÑALES TE ALERTARÁN?

Las páginas web bancarias fraudulentas son casi idénticas a su equivalente legítimo. Estas páginas utilizan ventanas emergentes solicitando tus credenciales bancarias. Un banco real nunca las utilizaría.

Estas páginas web muestran habitualmente:

Urgencia: no encontrarás este tipo de mensajes en páginas web legítimas.

Diseño poco cuidado: ten cuidado con las páginas web que tienen fallos en el diseño o faltas de ortografía.



Ventanas emergentes: se utilizan para obtener información delicada sobre ti. No hagas clic ni introduzcas en ellas información personal.

¿QUÉ PUEDES HACER?



Nunca hagas clic en enlaces de correo electrónico que te redirijan a la web de tu banco.



Escribe siempre la dirección en el navegador o utiliza un enlace almacenado en tu lista de "favoritos".



Utiliza un navegador con bloqueo de ventanas emergentes.



Si hay algo importante que requiera tu atención, tu banco te alertará de ello cuando accedas a tu banca electrónica.

'PHISHING' BANCARIO POR CORREO ELECTRÓNICO

'Phishing' se refiere a correos electrónicos fraudulentos que engañan a los destinatarios para que compartan su información personal, financiera o de seguridad.

¿CÓMO LO HACEN?

Estos correos electrónicos:

Pueden parecer idénticos al tipo de correspondencia que envían los bancos reales.

Copian los logotipos, el diseño y el tono de los correos electrónicos reales.

Te piden que descargues un documento adjunto o hagas clic en un enlace.

Usan un lenguaje que transmite un sentido de urgencia.



Los ciberdelincuentes asumen que las personas están ocupadas; a simple vista, estos correos electrónicos falsos parecen ser legítimos.



Ten cuidado cuando uses un dispositivo móvil. Puede ser más difícil detectar un intento de 'phishing' desde tu tableta o móvil.

¿QUÉ PUEDES HACER?

- Mantén tus aplicaciones actualizadas, incluyendo navegador, antivirus y sistema operativo.
- Presta especial atención si un correo electrónico de tu 'banco' te solicita información confidencial (p. ej. la contraseña de tu cuenta bancaria).
- Revisa el correo con cuidado: compara la dirección con los mensajes auténticos de tu banco. Comprueba si existen errores de ortografía o de gramática.
- No respondas a un correo electrónico sospechoso, reenvíalo a tu banco escribiendo tú la dirección real.
- No hagas clic en el enlace o descargues el archivo adjunto, escribe la dirección real de tu banco en el navegador.
- En caso de duda, comprueba la información entrando en la página web de tu banco o por teléfono.

#Ciberestafa



Aprende a reconocer fraudes en redes sociales y WhatsApp

En nuestras redes sociales y aplicaciones de mensajería instantánea, como WhatsApp, son comunes los fraudes y estafas. Por eso, debemos aprender a reconocerlos y evitarlos:

1 Concursos y promociones falsos: ¡He ganado un premio sin haber participado!

Si para recibirlo debo:

- ▶ Compartirlo con mis contactos.
- ▶ Rellenar un formulario con mis datos personales.
- ▶ Efectuar un pago o suscripción a un servicio de pago.
- ▶ Aceptar unas bases legales confusas o que se contradicen.

Más información en "Sorteos y premios online, un reclamo para hacerse con nuestros datos".

2 Secuestro de WhatsApp: Me han robado mi cuenta de WhatsApp.

Inesperadamente:

- ▶ He recibido un código de verificación de la app por SMS para configurar la cuenta en un nuevo dispositivo.
- ▶ Un usuario me ha solicitado el código bajo alguna excusa.

Más información en "¡Socorro, me han secuestrado WhatsApp!".

3 Cuentas falsas: ¿Perfiles de empresas o famosos demasiado parecidos en una red social?

Analizo si:

- ▶ Existen dos o más cuentas con un nombre similar y la misma descripción e imágenes.
- ▶ El perfil no cuenta con la insignia de verificación de la cuenta (check).
- ▶ Comparte enlaces a webs desconocidas o que no tienen nada que ver con la empresa.
- ▶ Manda mensajes genéricos solicitando apoyo económico a sus seguidores.

Más información en "Suplantación de identidad y secuestro de cuentas: ¿cómo actuar?".

4 Sextorsión y amores en línea: Buscando pareja encontré un perfil fraudulento.

Se caracteriza por:

- ▶ Utilizar perfiles abiertos, con fotografías de personas atractivas.
- ▶ Usar fotos robadas de otras cuentas privadas o públicas en Internet.
- ▶ Compartir los mismos gustos, aficiones, etc.
- ▶ Pedir ayuda económica bajo algún pretexto.
- ▶ Solicitar imágenes íntimas o vídeos explícitos.

Más información en "Amor online: ¡Que no te den sapo por príncipe azul!".

5 Anuncios de tiendas fraudulentas: He visto un anuncio que es un chollo.

Pistas:

- ▶ Se difunden en redes sociales con promociones muy atractivas.
- ▶ Promocionan productos de marcas muy conocidas.
- ▶ La URL y estética de la tienda anunciada no tiene nada que ver con la original.
- ▶ Las imágenes y descripciones de los productos están poco cuidadas (poca calidad y mala redacción).
- ▶ Proporcionan escasa información, o es inexistente, sobre quién es la empresa y cómo contactar con ella.
- ▶ No aceptan **métodos de pago seguros**, facilitan un formulario para introducir todos los datos de tu tarjeta, sin ninguna garantía de seguridad.

Más información en "Tiendas online fraudulentas".

Fraudes hay de muchos tipos, desde **falsas ofertas de empleo**, **préstamos falsos**, **promociones de viaje que no llevan a ningún lado**, **anuncios de alquileres o venta de productos y viviendas que acaban en decepción**.

En la OSI, canal especializado en ciudadanos de INCIBE, encontrarás más información sobre todos ellos, además de recursos para ayudarte a identificarlos y prevenirlos.

www.incibe.es | www.osi.es



VICEPRESIDENCIA
PRIMERA DEL GOBIERNO
MINISTERIO
DE ASUNTOS ECONÓMICOS
Y TRANSFORMACIÓN DIGITAL

SECRETARÍA DE ESTADO
DE DIGITALIZACIÓN E
INTELIGENCIA ARTIFICIAL

incibe
INSTITUTO NACIONAL DE CIBERSEGURIDAD



OSI
Oficina
de Seguridad
del Internauta



@INCIBE @osiseguridad

PHISHING Y PRECAUCIÓN



José Manuel
Redondo López

El mejor material de formación y concienciación desde cero que tiene el INCIBE es "Experiencia senior"

- <https://www.incibe.es/ciudadania/experiencia-senior>
- Totalmente gratuito, adaptado a **TODOS** y con ejercicios para practicar
- ¡Léetelo para estar mucho más protegido!
- ¡O recomiéndaselo a tus padres / conocidos que creas en peligro!

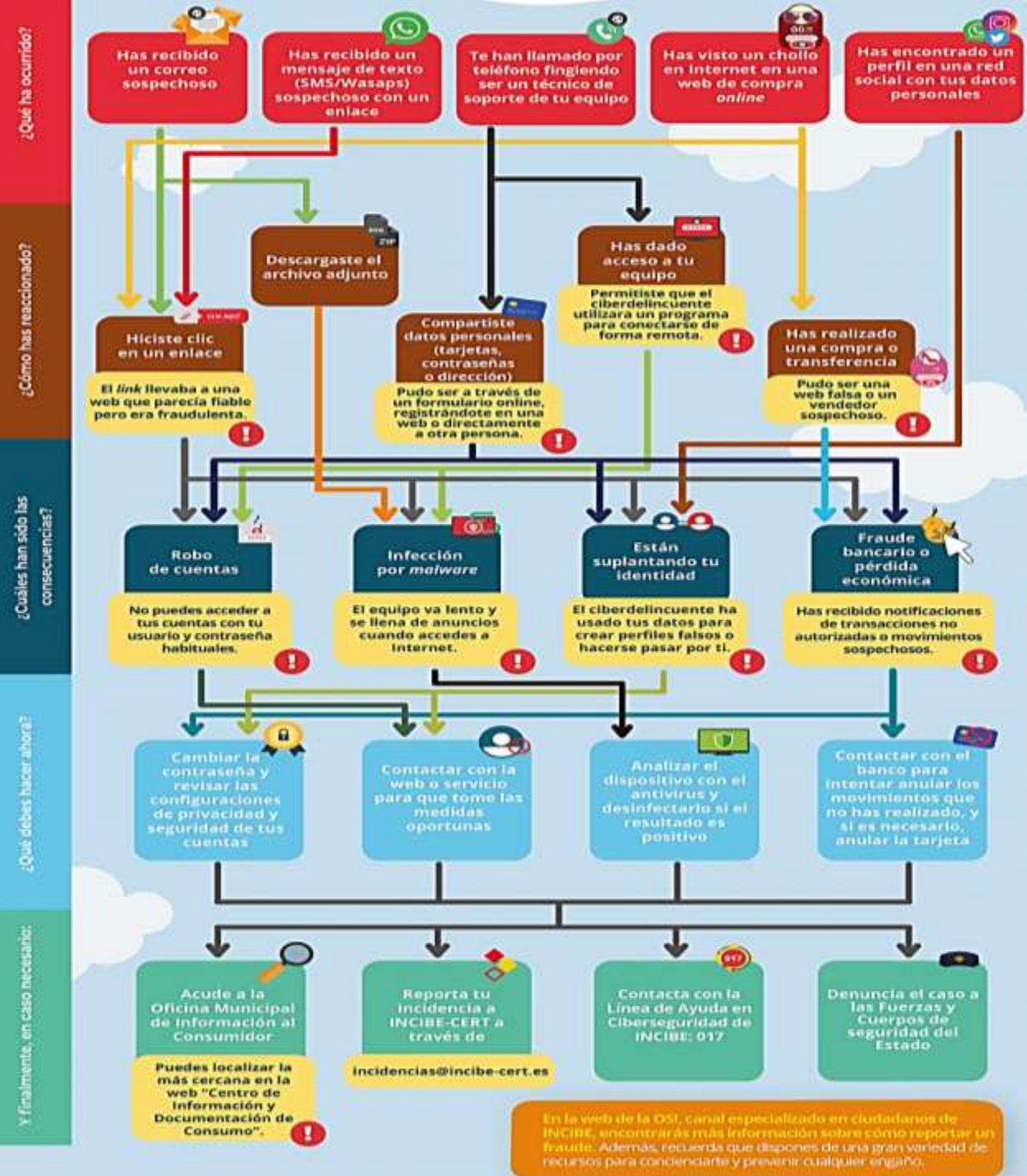
Fuente: INCIBE:

<https://www.incibe.es/ciudadania/experiencia-senior/que-hacer-si-eres-victima-de-un-fraude>

Qué hacer si eres víctima de un fraude

Sigue el camino correspondiente y descubre la mejor forma de actuar.

Experiencia
SENIOR





El ransomware

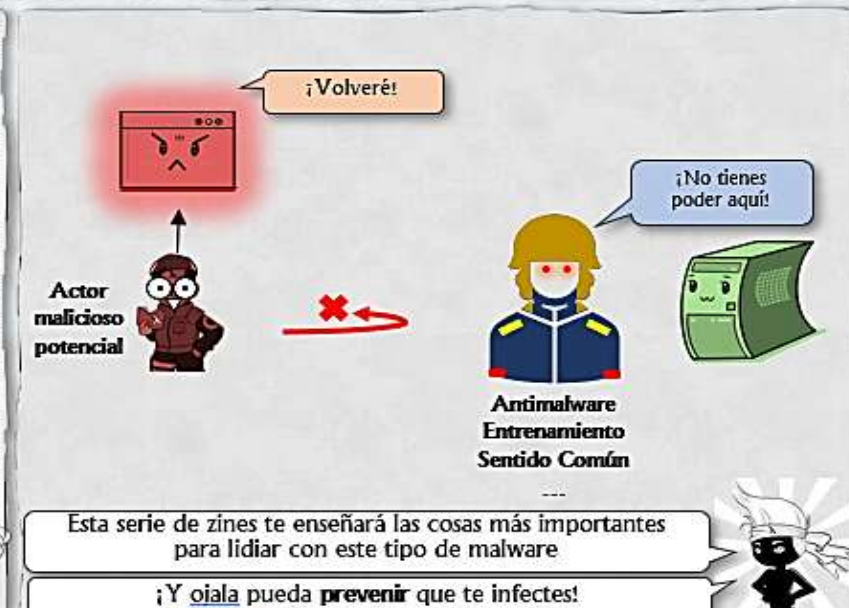
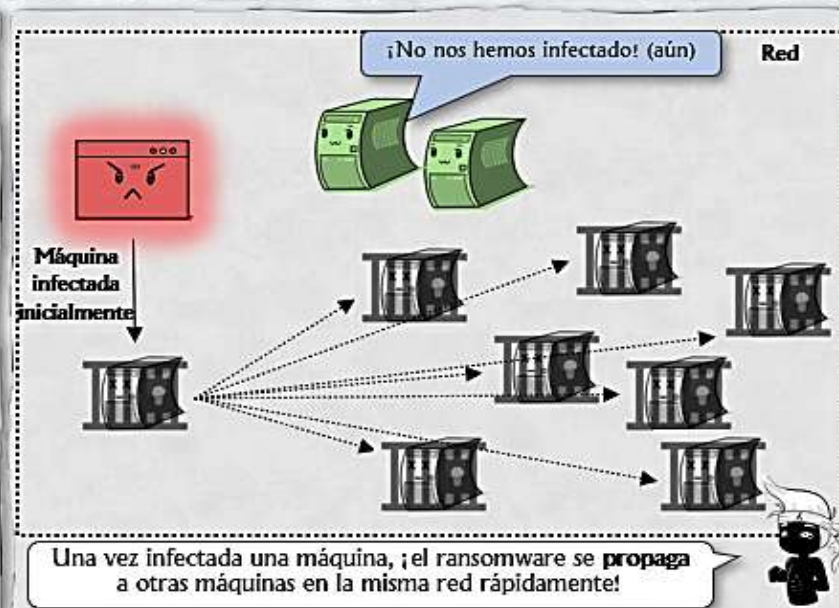
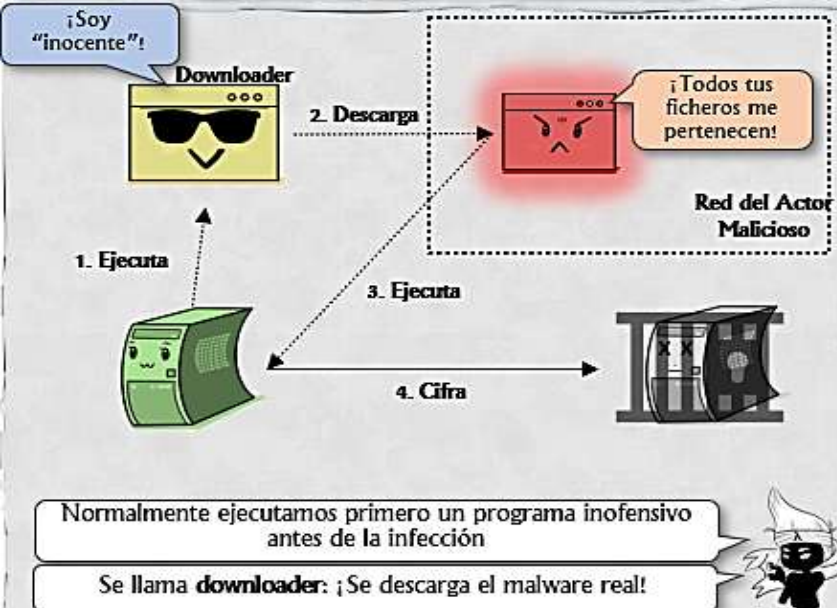
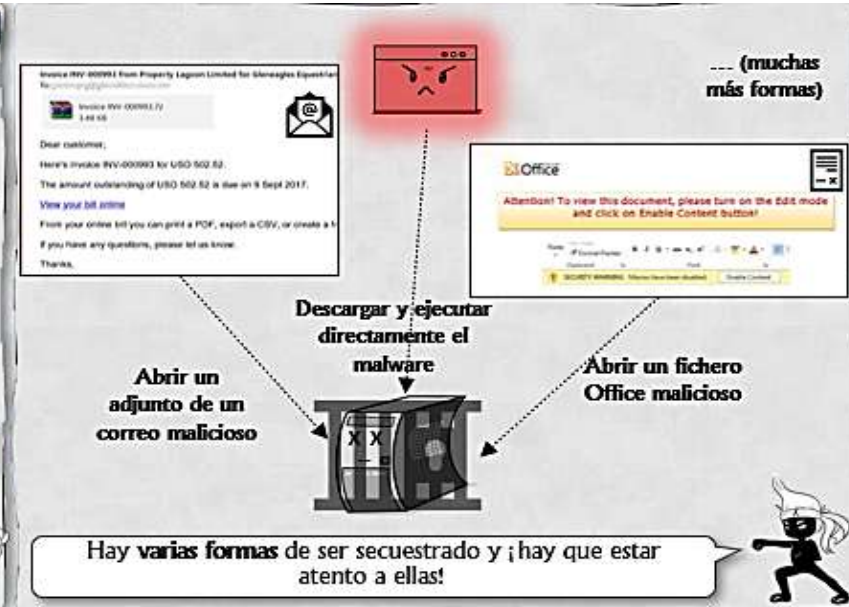
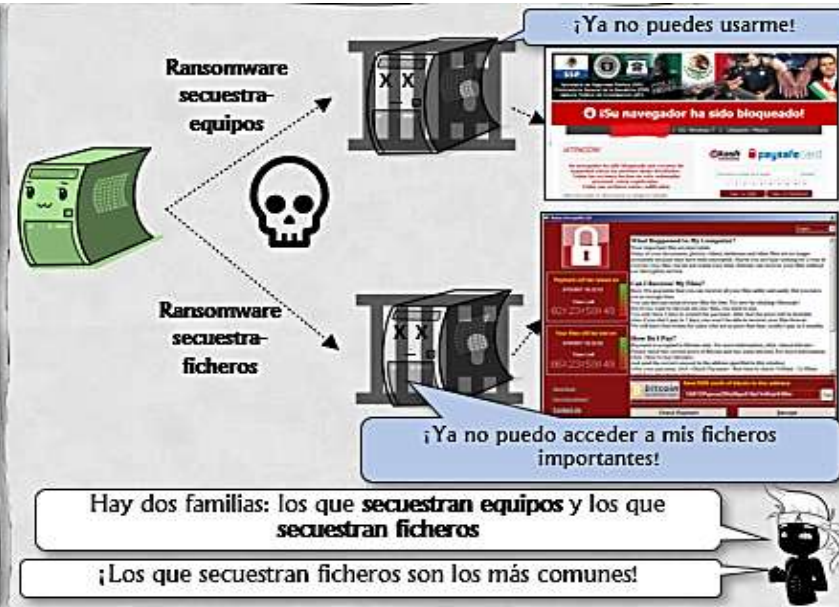
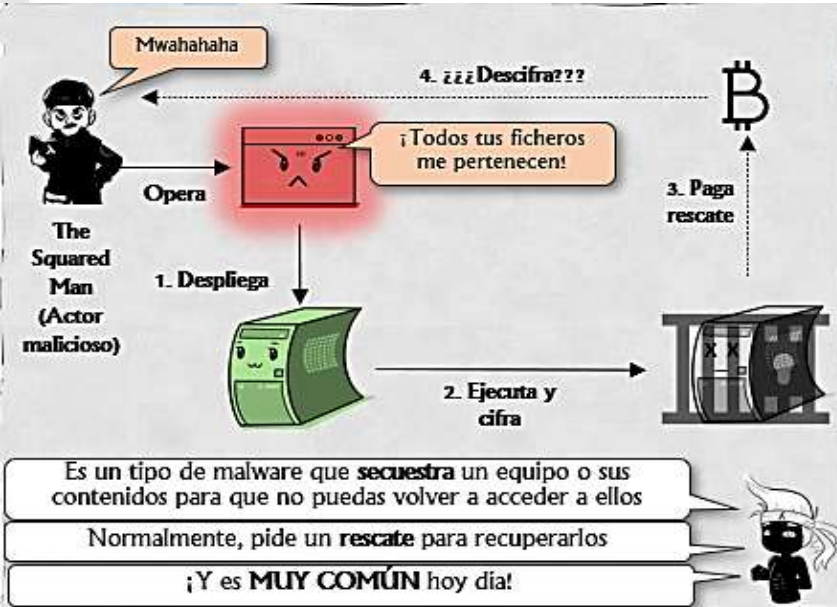
La mayor “pandemia digital” de la actualidad



¿CÓMO ACTÚA UN MALWARE / RANSOMWARE HABITUALMENTE?



José Manuel
Redondo López



¿CÓMO ACTÚA UN RANSOMWARE HABITUALMENTE?



José Manuel Redondo López

- De entre todos los malware, el ransomware es probablemente el peor 🐾
- ¿Qué hace cuando entra en un equipo?
 - Inspecciona el PC/móvil “infectado” en busca de **datos privados** que valgan dinero para la víctima
 - O conecta con su “operador”, que los busca “a mano”
 - ¡Sin que tú te enteres!
 - Paulatinamente **roba estos datos**
 - Haciéndose una copia y **destruyendo tus copias**
 - Y, en la mayoría de los casos, **cuando ha terminado** de robar todo lo importante...
 - Cifra el disco duro y **ya no puedes leer tu propia información**
 - Aparece el típico aviso que vemos en las noticias
 - Salvo que **pagues o tengas una copia no infectada**, perderás esos datos



Estos son avisos reales de ransomware. Cuando aparecen **ya es tarde** (está todo cifrado ya) y siempre hay una cuenta atrás para forzar al pago inmediato...

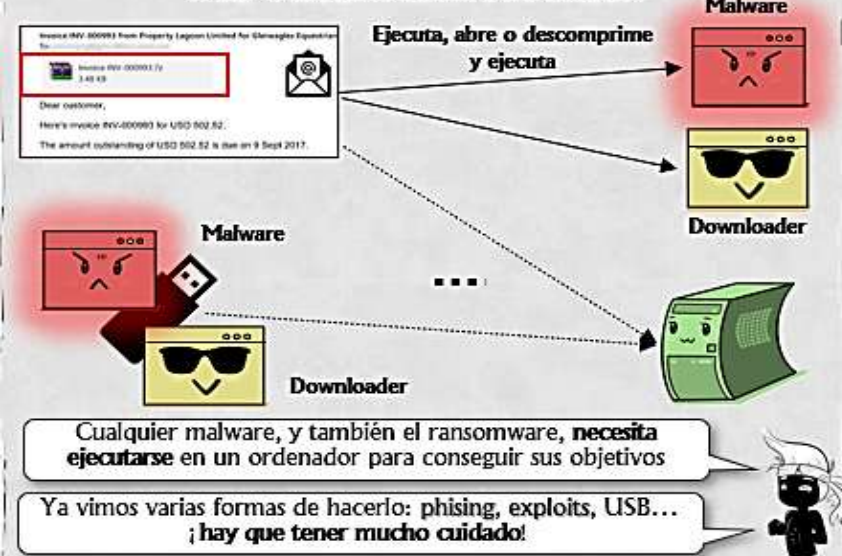


¿CÓMO ACTÚA UN RANSOMWARE HABITUALMENTE?

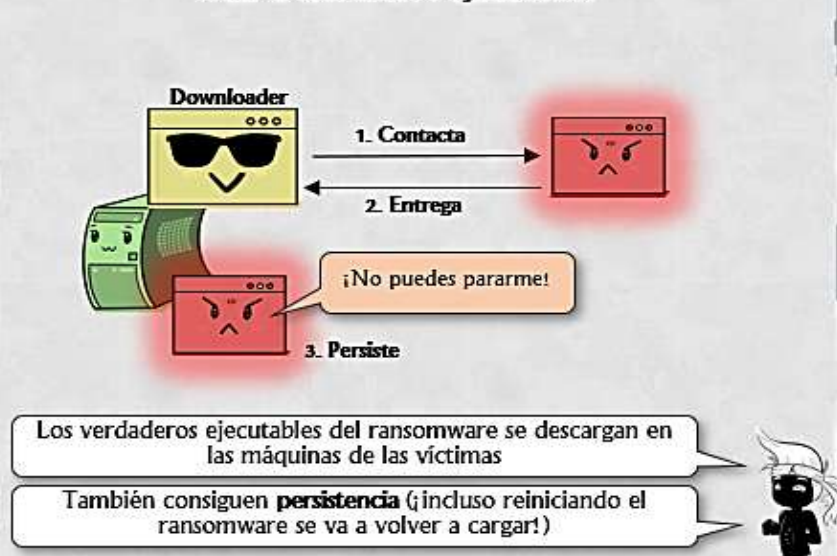


José Manuel
Redondo López

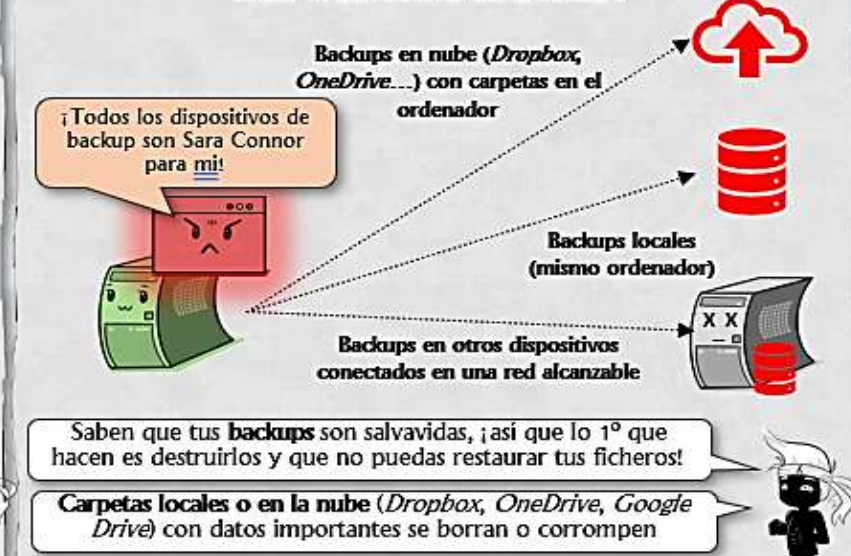
FASE 1: EXPLORACIÓN E INFECCIÓN



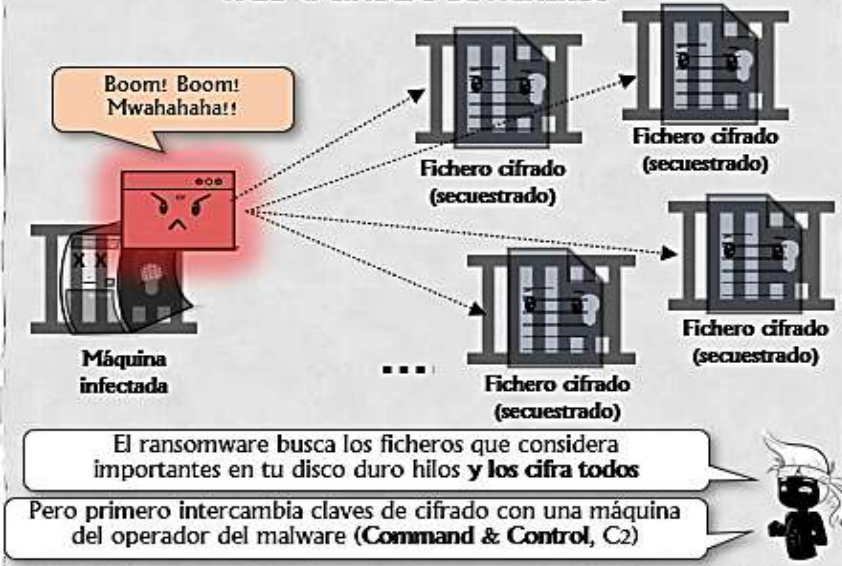
FASE 2: ENTREGA Y EJECUCIÓN



FASE 3: BORRADO DE BACKUPS



FASE 4: CIFRADO DE FICHEROS



FASE 5: NOTIFICACIÓN AL USUARIO Y LIMPIEZA

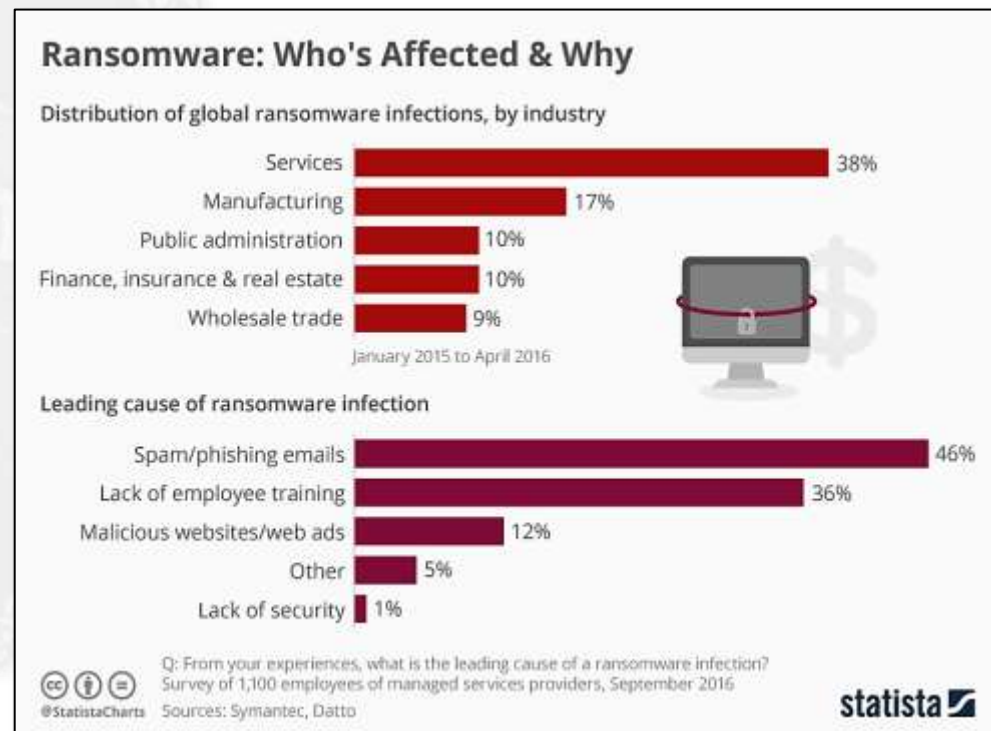


¿CÓMO ACTÚA UN RANSOMWARE HABITUALMENTE?



José Manuel
Redondo López

- Entonces *¿Cuándo me sale el aviso es demasiado tarde ya?* **Sí**
- En ese momento empieza la **extorsión**
 - Pagar por la clave para **descifrar tus propios archivos** 💰🔄
- Pero nadie te da **ninguna garantía** de recuperarlos: ¡son criminales! 💀
 - Podrías no recuperar una parte (**datos corruptos**) 💣
 - Podrían extorsionarte más veces 🧙‍♂️
 - Te suben el precio, no te dan la clave de todo, te vuelven a atacar...son delincuentes
 - **Podrían filtrar los datos**, aunque hayas pagado (¡son delincuentes!) 😡
 - Pérdida de reputación, clientes, problemas legales...
 - Es decir, **es demasiado tarde** 😞
 - ¡Mejor pon barreras antes no abriendo lo que no debes!



No se libra ningún sector, y el 94% de los casos son por caer víctima de *phishing*, falta de entrenamiento en ciber prevención y navegar por sitios inadecuados. *¿Entiendes la importancia de este curso ahora?*

¿PUEDO HACER ALGO A NIVEL TÉCNICO COMO PREVENCIÓN?

● El gráfico anterior habla solo...

- **Conocer la “mente del criminal”** 🧠 para detectar y evitar caer en phishing y spear phishing ayuda a prevenir el **46% de los casos**
 - Si aprendes a pensar como ellos, ¡aprendes a defenderte de también!
 - Es el objetivo principal de este curso
 - También ayuda saber moverte en redes sociales (**F-31 “Descubierta”**)
- **Entrenar** 🏋️ para conocer la “anatomía” de tipos de delitos habituales ayuda a prevenir el **36% de los casos**
 - Como se explica en el **“Nautilus”**
 - Aunque también este curso participa en ello
- **Tener un entorno de navegación seguro** 🧱 ayuda a prevenir el **12% de los casos**
 - La web es un medio de entrada muy común
 - Se explica en el **S-64 “Narval”**
 - También ayuda el **R-11 “Príncipe de Asturias”** (aislamiento)



¿Te das cuenta todo el mal que puedes llegar a evitar con un entrenamiento adecuado?



Otros crímenes comunes

Ojalá solo hubiera dos tipos de cibercrímenes...☹️



ATAQUES TÍPICOS CONTRA PERSONAS



José Manuel
Redondo López

- Vamos a hacer una enumeración de posibles ataques contra personas
 - Muchos usan falsificaciones que veremos en el curso
 - Para más detalles, recomiendo ver el “**Nautilus**”
- Una persona puede sufrir estos delitos
 - **Difusión de material obsceno** 🤔 : Comprometedor, privado, revenge porn, extorsiones...
 - Ni siquiera tiene que ser real (deepfakes)
 - **Difamación** 🗨️ : Cualquier tipo de desacreditación personal o profesional a una persona
 - **Hacking** 🐱💻 : Acceso no autorizado a un dispositivo
 - Normalmente con fines de espionaje
 - **Cracking** 💣 : Además de lo de antes, alterando, modificando o eliminando información
 - Ya no es malo que entren en tu máquina ¡sino que encima te engañan modificando tus cosas!

CYBER CRIMES AGAINST PERSONS



Fuente: https://www.linkedin.com/posts/vijay-kumar-11999825a_cyber-crime-against-persons-protecting-activity-7196169093312335875-kJ6v

ATAQUES TÍPICOS CONTRA PERSONAS

- **Spoofing de email** 🤪 📧 : Escribir emails en nombre de otras personas, suplantando su dirección de email real o usando una muy parecida con fines de engaño
 - La persona puede ser o no un conocido de la víctima
- **Spoofing de SMS** 🤪 💬 : Lo mismo que antes, pero con SMS
 - Aprovechándose de que los n°s de los emisores / llamantes son falsificables
- **Carding** 💳 : Robar y usar fraudulentamente los datos de tarjetas de crédito o débito para hacer compras en nombre de otra persona
- **Fraudes y engaños** 🤡 : Cualquier tipo de delito que busque sacar un beneficio económico
 - Son tantos que tenemos este curso y el “**Nautilus**” para intentar estudiarlos 🧐
- **Pornografía infantil** 🍆 : Envío/tráfico/venta de material pornográfico de menores de edad
 - Ya sea real o fabricado con IA (deepfakes)
- **Amenazas y asaltos** 🗣️ : Agresiones verbales y actos intencionados que ponen a la víctima en peligro o la dañan de alguna forma
 - En Internet, puede incluirse el reporte masivo de una cuenta para cerrarla o silenciarla
- **Ciber-stalkeo** 🕵️ : Acoso por internet, a través de las redes sociales u otros medios
 - Muchas veces dejando constancia “sutil” de que se está realizando, para que la víctima se altere
 - O bien usando en contra de él/ella la información recopilada en la vida real

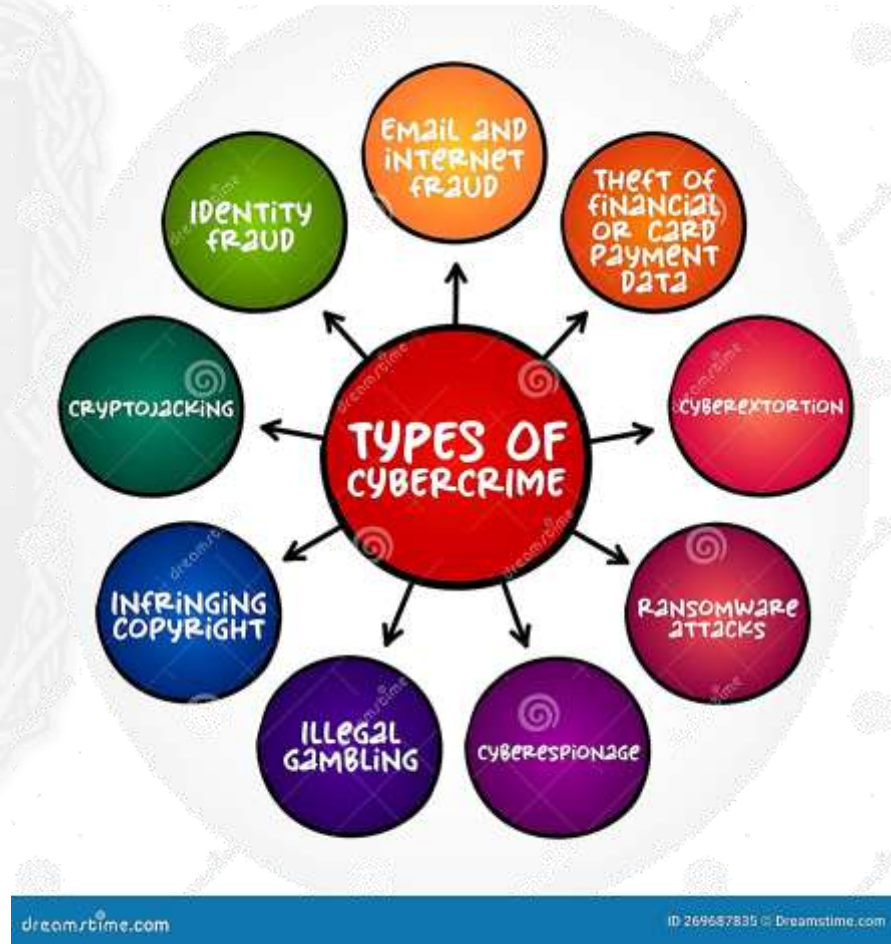
TIPOS PRINCIPALES DE CIBERCRÍMENES



José Manuel
Redondo López

● Los principales tipos de cibercrimen son

- **Robo de identidad** 🗑️ : Suplantar a una persona o entidad en Internet, actuando falsamente en su nombre
 - Detallaremos más en el **A-71 “Juan Sebastián Elcano”**
 - Con creación de cuentas falsas o robo de información previa
- **Robo de cuentas de email o de servicios en Internet** 📧 :
Típico medio para conseguir lo anterior
 - También para **propagar estafas o desinformación** entre los contactos de la cuenta robada
- **Robo de datos bancarios y medios de pago** 💰 🏠 🏦 🏠 🏠 :
El delincuente compra, la víctima paga
- **Ciberextorsión** 😞 : Alguien tiene algo de la víctima comprometedor y pide dinero para no revelarlo
 - Normalmente a sus contactos o familiares
 - Puede ser falso (deepfakes), pero afectar a la reputación
 - Detallaremos más en el **A-71 “Juan Sebastián Elcano”**



TIPOS PRINCIPALES DE CIBERCRÍMENES

- **Ransomware** 🐱‍💻🔒 : Descrito durante este curso
- **Ciberspionaje** 🐱‍💻🔍 : Mantenerse en un PC o una cuenta de un servicio de la víctima sin ser detectado todo el tiempo posible
 - Con el objetivo de tener **conocimiento exhaustivo** de todo lo que hace la víctima hace o dice
 - De forma que pueda adelantarse a sus movimientos, lo que dice o lo que hace
 - Parece solo de empresas o gobiernos, pero hay gente que se obsesiona con otra y...
- **Juego ilegal** 🎲 : Cualquier casino, sistema de apuestas o similar encubierto, fuera de la legalidad u ofrecido de manera que parezca que es otra cosa
 - Por ejemplo, hay **videojuegos** (especialmente de móviles) que se tienen elementos que rozan peligrosamente caer en esta categoría
 - Con elementos que **fomentan la adicción** y la compra compulsiva de sobres, cajas de botín, etc.
 - Detallaremos más en el **A-71 “Juan Sebastián Elcano”**
- **Infracción de copyright** 📄❌ : Usar algo que pertenece a otra persona sin su permiso, porque tiene una licencia que no permite hacerlo
 - O apropiarse del trabajo de otro directamente, borrando su nombre o cambiándolo mínimamente
- **Cryptojacking** 💰⚙️ : Secuestro de un dispositivo de una víctima para aprovechar sus capacidades de computo para **minar criptomonedas** para el atacante
 - Tú pagas la luz, ellos consiguen criptos 💰💰

DELITOS DE CARÁCTER TÉCNICO



José Manuel
Redondo López

- Hay delitos que tienen un componente altamente técnico como
 - **Malware y phishing** 🐟 : Vistos durante este curso
 - **Attacker-in-the-Middle** ↔ : Un atacante intercepta una comunicación entre dos víctimas
 - Escuchando todo lo que se envían y/o modificándolo
 - **Drive-by downloads** ↓ : Descargar un programa malicioso solo por visitar un sitio web
 - Normalmente **se aprovecha de vulnerabilidades** para instalarse solo, sin necesidad de acciones
 - Esto quiere decir que si no actualizas el navegador te puedes comer un malware **solo por visitar una web** 🤖
 - Por tanto...
 - A ver **dónde navegas y cómo** lo haces (**S-74 "Tramontana"**)
 - Ojito con **cómo tienes configurado** tu PC o móvil (**R-01 "Dédalo"**)



Fuente: <https://techradix.in/types-of-cybercrime/>

DELITOS DE CARÁCTER TÉCNICO



José Manuel
Redondo López

- **Malvertising** 🧑‍💻 : Anuncios maliciosos que descargan software
 - Sin conocimiento ni consentimiento de la víctima
 - A veces ¡solo por verlos!
 - Más información: <https://www.incibe.es/aprendeciberseguridad/malvertising>
- **Rogue software** 🧑‍💻 : Programas que dicen que hacen algo, pero en realidad son directamente malware
 - Normalmente **falsos antivirus** u otro programa de protección que, en lugar de solucionar problemas, causan más
- **DDoS** 😞 : Ataque que saturan un servicio de manera que queda inutilizado por no poder atender más peticiones
 - Varios dispositivos atacantes “petan” a una víctima a base de una ametralladora de peticiones, hasta que no puede atender más
 - A veces se extorsiona con eso a los propietarios del servicio
- **Ataques a contraseñas/formas de acceso a cuentas** 🧑‍💻 : Cualquier infiltración, adivinación por fuerza bruta, técnica de robo, etc. de datos de acceso a una cuenta
 - Típicamente instalando un **malware** con alguna de las técnicas anteriores que es el que lo roba



¿CREES QUE LO HAS ENTENDIDO TODO? ¡AUTOEVALÚATE!



José Manuel
Redondo López



● Asegúrate de haber entendido lo siguiente

- *Que con el phishing y el ransomware se cubren la inmensa mayoría de delitos en la actualidad*
- *Que el objetivo de muchos malware es propagarse lo más posible mientras o antes de hacer daño*
- *Que existe el fin para pobres y para ricos en función de la importancia de la víctima*
- *Que si ves un aviso de cifrado de un ransomware ya es tarde*
- *Que nadie se libra del efecto del ransomware, dedique a lo que se dedique*
- *Que “conocer la mente de un criminal” es una pieza muy importante, junto con las otras que forman parte de otros cursos “hermanos”, para prevenir ataques*
- *Que existen otra clase de ataques posibles, además de los principales vistos*

[< Ir al Índice](#)

 [Objetivos](#)

 [Sicología](#)



MENTES CRIMINALES

¿Cuáles son sus intenciones?



¿QUÉ VAMOS A VER EN ESTE BLOQUE?



José Manuel
Redondo López

● En este bloque te voy a enseñar...

- **Cuáles son los objetivos** de un ciberdelincuente
 - Siempre es un beneficio propio, pero no siempre es directamente dinero
 - Hay otros incentivos
- **Las diversas formas de contacto** que tienen los ciberdelincuentes para dar contigo
 - ¡El correo electrónico solo es una de ellas!
- **Cómo piensa** un ciberdelincuente
 - Esto te puede ayudar a entender que **no van a tener piedad de ti** y que van a recurrir a **cualquier táctica** con tal de engañarte





Objetivos de un ciberdelincuente

Qué quieren y cómo lo intentan conseguir



¿PERO QUÉ QUIEREN LOS DELINCUENTES?

- **Siempre es su propio provecho** 💰 , lo que se puede traducir en...
 - **Conseguir dinero** 💰 : Que se lo transfieran, que se haga pasar por la víctima y te lo robe, que la víctima haga una compra que resulte ser un timo...
 - Datos de tarjetas de crédito, servicios de pago para comprar fraudulentamente...
 - **Conseguir datos privados / suplantar identidad completa** 👤 : Con ello pueden hacer/facilitar más estafas usando el nombre de la víctima, engaños, ventas fraudulentas, extorsiones...
 - Usarla de “cobertura”, dañar su reputación, **infiltrarse y cometer delitos en su nombre**...
 - Robo y publicación de datos privados, enfrentándose a consecuencias penales / multas
 - **Conseguir cuentas en algún servicio de la víctima** (Ej.: servicios en nube) 👤👤
 - La víctima paga, el delincuente lo usa para su provecho o algo malicioso
 - Eliminar o comprometer la cuenta (parada de negocio)...
 - **Conseguir el control de equipos** 🖱️ : Robo, extorsión, hacer estafas en nombre de la víctima...
 - Criptominería, espionaje, ...
 - **Conseguir que le sigas/valides** 👍 : Para ganar influencia / reputación, dar credibilidad a noticias (fake news), pérdida reputacional para la víctima...
- **Bien sobre víctimas concretas o empresas** 💼 (¡eso puede ser una liada guapa!)

¿CÓMO SE HACE?

• La acción desencadenante es simple

- **Que hagas clic**  en un enlace y accedas a la web que el delincuente quiera
 - Para **instalar malware** engañándote para que lo ejecutes
 - O por **vulnerabilidad de tu navegador**, ¡sin que hagas nada! 😞
 - O ser falsa y engañarte para que **des tú voluntariamente datos personales...**
- **Que hagas clic**  e instales un programa o abras un documento
 - Que tendrá malware con alguno de los efectos anteriores
- **Que hagas clic**  y sigas a un medio / cuenta / canal de YouTube, Twitch...
 - Para que des **credibilidad a sus noticias / afirmaciones**
 - A más gente apoyando algo, más credibilidad tendrán productos, noticias, afirmaciones, teorías de la conspiración, ofertas...y ¡estafas!

• Es decir: **que hagas clic en algo que les de beneficio**

- ¡El clic donde no debes es la raíz de casi todos los problemas!

• *¿Y cómo lo consiguen?*

- **Contactando contigo** de alguna forma para engañarte...



¡El clic de la muerte!

FORMAS DE CONTACTO CON LA VICTIMA (¡TÚ!)



José Manuel
Redondo López

● Hay MUCHÍSIMAS, pero ejemplos clásicos son...

- Tu email 📧 o mensajes 💬 de aplicaciones como WhatsApp, Telegram, Discord, cualquier videojuego...
 - Cualquier sitio donde alguien te pueda escribir o hablar
- **Cualquier red social** 🐼
 - Perfiles falsos que te hablan y te piden cosas
 - Mensajes públicos o **privados** fraudulentos / publicidad engañosa que te llega o ves
 - Cubierto en el **F-31 "Descubierta"**
- **Páginas de compra/venta** de productos falsas 🛒
 - Su sistema de mensajería, webs falsas que suplantán a las reales...
- **SMS o llamadas telefónicas** (vishing o voice phishing) 📞
- **Comentarios** en canales de YouTube, Twitch / Kick ... 💭
 - ¿Algo admite comentarios? Alguien puede escribir algo engañoso



El email o el WhatsApp es muy mainstream, ahora la moda de los timos es poner una publicación falsa o anuncio en una red social con un "clickbait" para que hagas clic en una web fraudulenta creyendo que es una noticia y entres. No, ¡aunque use el logo de "El Mundo" no es ese periódico!

FORMAS DE CONTACTO CON LA VICTIMA (¡TÚ!)



José Manuel
Redondo López

• Pero nos podemos poner “esotéricos” 🧛

- **Carta física** 📧 (¡sí! ¡aún ocurre!)
- **Códigos QR** 📱 pegados en cualquier parte
- **Dispositivos USB conectables** 🔌 que vengan de lugares inseguros 🤪
 - El problema es que **cualquiera puede serlo** en cualquier momento
 - ¿Te fías de que tu colega que te ha pasado eso en un lápiz no tenga virus?
 - A lo mejor los tiene y **no lo sabe ni el mismo** 🤔 🤔
 - **U “Olvidados”** (a propósito), especialmente preparados para hacer daño ☠️
 - Hay dispositivos USB pensados expresamente para hacer daño
 - Al conectarlos a un PC, se desencadena una campaña de **malware**
- **El Google Calendar** 📅: Llegan invitaciones con el texto de alguna estafa

• O “intensos” ⚡

- Combinaciones de todos los anteriores, con ataques **en varias fases**
 - O incluso que involucren a **varias personas**
 - Que a veces son la misma suplantando a varios...
 - No olvides que existen los **deepfakes de audio y video...**



Rubber Ducky
(<https://shop.hak5.org/products/usb-rubber-ducky>) y **USB Killer** son dispositivos USB pensados para conectarlos a un PC y liarla bien parda...

¿CARTA FÍSICA? ¿A LA ANTIGUA? ¿ESTÁS DE BROMA?



José Manuel
Redondo López

- Desgraciadamente no...estas cosas siguen pasando de vez en cuando 🤔
 - Especialmente contra los más mayores 🧓
 - En Asturias tuvimos un caso muy sonado hace muchos años con el "Petromocho"
 - https://www.elconfidencial.com/cultura/2018-04-22/petromocho-asturias-timo-gobierno-gijon_1552457/
- ¡El email es sólo **UNA FORMA** posible de contacto, pero hay **MUCHAS MÁS!**
 - Aunque una de las más comunes...
- Es necesario que sepas que los mismos ataques **pueden llegarte de muchas formas**


TESORERÍA GENERAL
DE LA SEGURIDAD SOCIAL

CAMBIO DATOS BANCARIOS SEG SOCIAL

Estimado

Desde la seguridad social nos ponemos en contacto con usted porque es necesario que nos envíe la siguiente documentación debido a que la ley que entró en vigor el pasado mes y debido al ataque informático en los sistemas de Hacienda y Seguridad social muchos de los datos de los ciudadanos se han perdido.

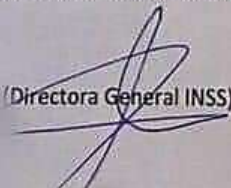
1. Ante todo va haber un incremento de las prestaciones, jubilaciones por lo que es necesario que nos adjunte la siguiente documentación, si es tan amable:
 - a. Fotos de ambas caras del DNI o NIE
 - b. Foto del extracto bancario donde usted aparezca como titular u autorizado en una entidad bancaria.
 - c. Última cantidad que cobró el mes pasado, una estimación.
2. El incremento será de 75€ a 150€ dependiendo el caso.

Deberá mandar la documentación a la siguiente dirección de correo:

- Seguridadsocial.granada@outlook.es

Y en el asunto poner Documentación + Num DNI

Atentamente,

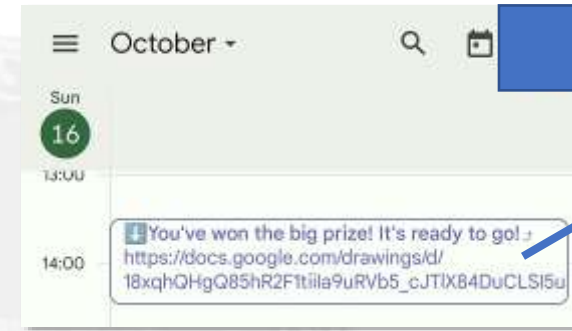

(Directora General INSS)

FORMAS DE CONTACTO CON LA VÍCTIMA MÁS ATÍPICAS

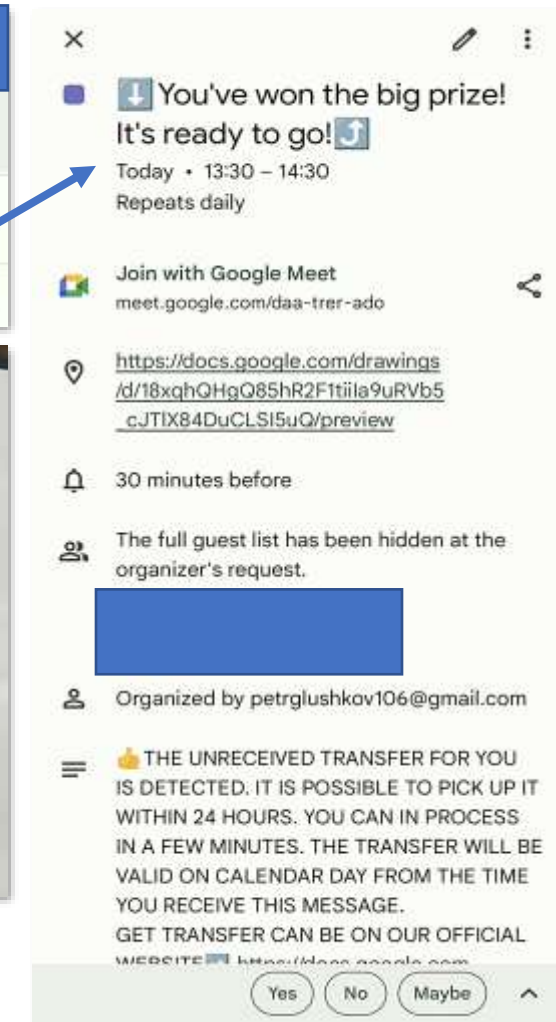


José Manuel
Redondo López

- Las formas de contacto evolucionan
 - Nuevos programas, redes sociales, tecnologías...
- Se “ponen de moda”. Ej.:
 - Los **códigos QR**  pegados en cualquier parte
 - Incluso **pegando falsos encima de verdaderos**
 - Lo escaneas con tu teléfono, accedes a la página web que contienen y...ya la has liado
 - El **Google Calendar** 
 - ¿Tienes eventos que no recuerdas? **CUIDADO**
 - Quieren que hagas clic y entres a una web chunga 
- Asume que todos los timos pueden llegarte por **TODAS estas formas de contacto**
 - ¡“Clásicas” o nuevas!



¡Un USB salvaje apareció!
¡Es super efectivo! (por desgracia)



Sí, este es muy obvio. Ahora imagina uno de “Pedir cita urgente en <página web>”



Psicología de los ciberdelincuentes

En la mente del mal

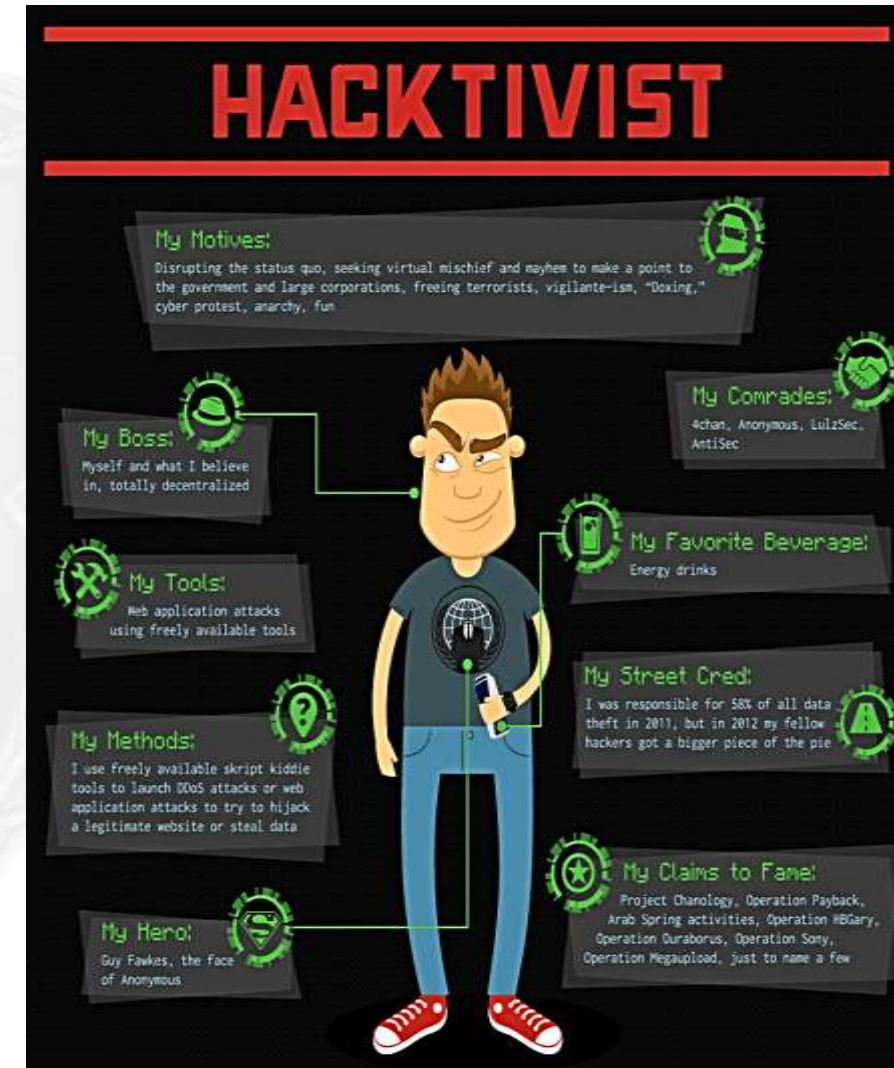


PERFILES TÍPICOS DE CIBERDELINCUENTES: HACKTIVISTA



José Manuel
Redondo López

- Usa habilidades de hacking o ciberataques para promover una causa política, social o ideológica
 - Actúa como medio de protesta, difundir un mensaje, denunciar injusticias o defender una postura
- Pero, aunque la causa sea legítima, es muy fácil caer en actividades delictivas para ello, como
 - **Filtración** de información privada
 - Ataques de **denegación de servicio** (DDoS)
 - **Modificar sitios web** legítimos con reivindicaciones
 - ... (cualquiera de los vistos antes)
- El principal problema es que esos actos de protesta pueden tener efectos secundarios
 - Y hacer daños **muy difíciles de predecir** o calcular
 - **El fin no justifica los medios**



Fuente:

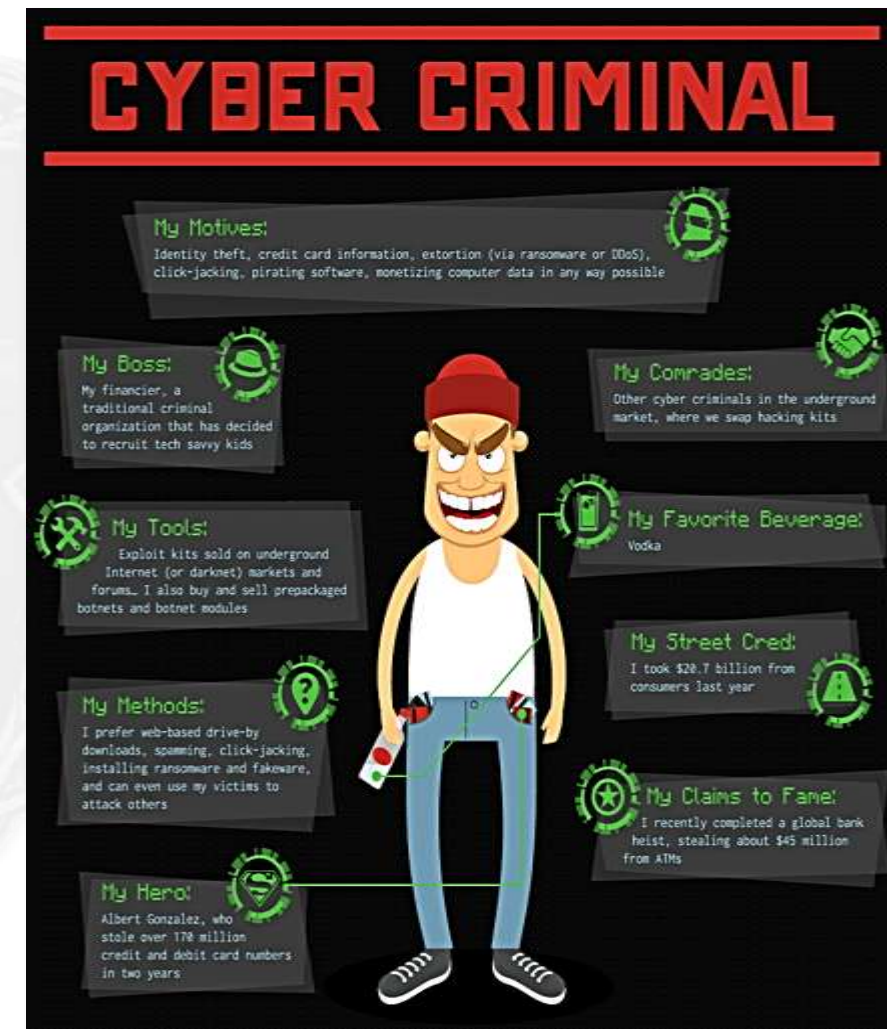
<https://biztechmagazine.com/article/2013/06/hacker-profiles-meet-new-kids-block-infographic>

PERFILES TÍPICOS DE CIBERDELINCUENTES: CIBER CRIMINAL



José Manuel
Redondo López

- Cualquier persona o grupo que utiliza la tecnología e internet para cometer delitos
 - Como hemos dicho, por **su propio beneficio**
 - Económico o por daños (les pagan para dañar a otros)
 - Muchas veces son ataques a gran escala, por grupos muy profesionales y especializados
- A diferencia del hacktivista, suele estar motivado por puro dinero, robándolo o bajo contrato para
 - El **espionaje** corporativo
 - El **sabotaje**
 - La **interrupción** de servicios
 - Atacar la **reputación online** de un grupo o individuo
 - ... (cualquiera de los delitos vistos antes)



Fuente:

<https://biztechmagazine.com/article/2013/06/hacker-profiles-meet-new-kids-block-infographic>

PERFILES TÍPICOS DE CIBERDELINCUENTES: ACTOR ESTATAL



José Manuel
Redondo López

- **Ciberataque patrocinado, orquestado o llevado a cabo por un gobierno o una agencia estatal**
 - Contra otro estado, entidades privadas (empresas, organizaciones), individuos...
- **El atacante es básicamente un país**
 - No individuos o grupos cibercriminales independientes
 - Aunque a veces puedan usar a estos como **fachada** 🤖
 - Suelen tener **objetivos geopolíticos**, de espionaje (robo de secretos de estado, propiedad intelectual...), sabotaje de infraestructuras críticas, desinformación, interrupción de operaciones enemigas... 🇺🇸
 - Con **muchos recursos** financieros, tecnológicos y humanos
 - Les permite desarrollar herramientas y técnicas sofisticadas
 - Por ello, suelen ser **ataques muy complejos**, difíciles de detectar y atribuir, y persistentes en el tiempo
 - ¡Aunque se sospeche que ha sido un país X, **no es fácil probarlo!**



Fuente:

<https://biztechmagazine.com/article/2013/06/hacker-profiles-meet-new-kids-block-infographic>

PSICOLOGÍA DE UN DELINCUENTE

- Como hemos dicho, ten bien claro que el objetivo de un delincuente es siempre **obtener un beneficio de ti**
 - Obviamente, uno de los principales es el **beneficio económico**
 - **Directo:** Dinero, productos, servicios
 - **Indirecto:** Formas de conseguir dinero con la información de otro
 - Una de las formas **más comunes** de hacerlo es **ofertarte** dinero, productos, servicios, empleo, etc... **con “truco”**
 - Tendrás que **pagar por adelantado** una cantidad de dinero (además del supuesto precio) antes de acceder a esa oferta, producto o servicio
 - Con una **ENORME** variedad de excusas que justifiquen ese pago
 - En el “**Nautilus**” veremos muchas variantes
 - Se denominan Advance-Fee Scams 🍒
 - **Mucho cuidado con este tipo de timos**



De una forma u otra, directa o indirectamente al final el objetivo es obtener un beneficio

PSICOLOGÍA DE UN DELINCUENTE

• *¿Entonces es la típica estafa de pagar por algo que no existe?*

• ¡Sí!, pero hay más: **van a intentar que pagues varias veces**

- Inicialmente te pide dinero para completar el envío / transacción 💰
- Si envías el dinero, **inventará otra excusa** para que envíes más dinero para “desbloquear el proceso” 💰 💰
 - Siempre problemas “casuales” (yatusabeh)
- A medida que se vaya enviando más dinero, el delincuente “**subirá la apuesta**” 💰 💰 💰
 - Te dirá que esta es la última vez (mentira) 😬
 - Que estás **sólo a un paso** de conseguir el producto/servicio, que no lo dejes escapar, que ya casi lo tienes 🤞 (mentira)
- **Te trata de engañar el mayor n° de veces posible** para que pagues 💰 💰 💰 💰
 - **NUNCA** recibirás NADA a cambio, o recibes algo falso (**tenlo BIEN claro**)
 - Hasta que “amigo/a date cuenta” y “cortes el grifo” 😬 😬
 - Entonces el delincuente **cortará el contacto** y se centrará en sus otras víctimas...



La víctima cae en una “espiral de engaño” de la que es MUY difícil salir a nivel psicológico

¿CÓMO ES POSIBLE QUE ESTO FUNCIONE?

- Puedes pensar que tú estás a salvo de estas estafas...
 - Pero veremos que hay algunas **MUY BUENAS, DEMASIADO**
 - ¡Ojo con el exceso de confianza! 😏
- Pero también estas rodeado de gente que **no ha tenido la suerte de tener tu formación y conocimiento** 😬
 - Y son **su principal tipo de víctima**
 - **Siempre puede haber una víctima potencial en tu entorno**
 - Seguro que se te viene un nombre de alguien que conoces a la cabeza ahora mismo, ¿verdad? 😐



El objetivo siempre es el más débil. Te puedes imaginar quiénes van a ser, ¿verdad?

¿CÓMO ES POSIBLE QUE ESTO FUNCIONE?

- Porque las víctimas **“invierten emocionalmente”** en el tema
 - Si “pican” y pagan la 1ª vez, la probabilidad de que lo sigan haciendo es muy alta
 - Han **“invertido”** en el tema 😍
 - Económica y emocionalmente, las excusas para enviar dinero suelen **“atacar”** la parte emocional
 - No pueden permitirse / se avergüenzan de **perder su inversión**
 - El delincuente crea una sensación creciente de **urgencia** (“venga, esto se acaba ya”) 😬
 - Para que las víctimas creen que su inversión tendrá por fin resultados a muy corto plazo
 - Siempre se recurre a **tácticas** para hacer ver a la víctima que su inversión / sacrificio económico **merece la pena** 🙏
 - Porque lo que va a obtener a cambio es mucho más valioso
 - O introducir un **sentimiento de urgencia** para evitar que la víctima piense o consulte
 - O atacar sentimientos primarios (**codicia**, la **buena fe** o la **necesidad** (de relaciones o económica))
 - **En resumen:** La víctima se mete en la **“espiral del engaño”** de la que hablamos 🌀
 - De pérdidas económicas y promesas de “salir” con éxito en la siguiente “vuelta”
 - Lo que **NUNCA** ocurre

¿CÓMO PUEDE LA GENTE “CAER” EN ESTO?

- Si ya has caído, “romper la cadena” podría serte difícil
 - Aún te lo crees, **te niegas a reconocer que te han estafado...**
- Recurren a cualquier táctica que se les ocurra (luego detallamos esto)
 - Crean **páginas falsas** de bancos / tiendas online / empresas 
 - Para que veas que el dinero / producto ofertado existe
 - De manera muy muy elaborada (páginas que funcionan, no solo copian el aspecto)
 - Como es el delincuente quien las controla, te pueden dar incluso un usuario de acceso
 - **Falsifican identidades de personas reales** 
 - Ligadas a una web real que supuestamente te está ofertando algo
 - Con información pública o privada real de la persona
 - Obtenida de filtraciones de datos (ej.: direcciones, DNIs...)
 - El mismo delincuente suele usar **varias identidades de personas** involucradas en el proceso  
 - Abogados, procuradores, empresas de seguridad, sacerdotes, etc...
 - Para ganar credibilidad (“monta una película”)...¡son grandes actores!
 - **Falsifican documentos** de distintos tipos para aumentar la credibilidad 
 - O usa documentos reales robados y/o comprados en la dark web (**F-31 “Descubierta”**)

José Manuel Redondo López

**José Manuel
Redondo López**

ro destacar tres cosas

podemos ser víctimas:

s vacunas: impide caer en muchas estafas...

Y buenas, y **nadie está exento de ser una víctima**

tos en ciber fraude confiesan que han tenido

uiendo una estafa de un mensaje real

nido “un día tonto” (que podemos tener **cualco**

, pero si **no tienes una falsa sensación de confiar**

a no ha tenido la suerte de ser formada contr

ioritario para estos delincuentes

s recrimines que les hayan engañado

cientemente mal!

- La formación es como las vacunas: impide caer en muchas estafas...
 - ...pero hay estafas MUY buenas, y **nadie está exento de ser una víctima**
- Hasta los mayores expertos en ciber fraude confiesen que han tenido **graves problemas** distinguiendo una estafa de un mensaje real
- Otros confiesen haber tenido “un día tonto” (que podemos tener **cualquiera**) y haber caído
 - Esto no se puede evitar, pero si **no tienes una falsa sensación de confianza** es más difícil caer
- **Recuerda:** Si una persona no ha tenido la suerte de ser formada contra estafas, es un objetivo prioritario para estos delincuentes
- **Ayúdales** y encima no les recrimines que les hayan engañado
 - ¡Ya se sienten los suficientemente mal!



Joven, “nativo/a digital”, “techie”, lo sabes todo, tienes confianza en ti mismo, eres un hakin bestia, etc. Lo siento, tú también puedes caer...

¿CÓMO PUEDE LA GENTE “CAER” EN ESTO?

2. Los delincuentes **no tienen límites morales** 🙄 (**cualquier táctica** vale para convencer)
- **Religión, aficiones...** 🏠 ⚡ ✝️ 🍷 ⚙️ 🌀 🌀
 - **Complicidad** por ser “bro”, ser **familia**, ser de un **mismo grupo...** 👉
 - Ofrecer **relaciones amorosas** ❤️
 - Fingir **miserias y pobreza extrema...** 😞
 - Víctima de **terrorismo**, de **violencia**, de una **guerra...** 😱
 - **Compartir ideales** 🗣️
 - Y un largo etc... ¡cualquier excusa, no hay límite con tal de engañar!
 - **Suelen involucrar la actualidad**
 - Terremotos, inundaciones, volcanes, pandemias... 🌪️ 🚰 ⚠️
 - **Lo hacen para ser más creíbles:** estate atento a las noticias y prepárate para recibir cosas así
 - **No juegan con tus reglas** (ni con ninguna), no se mueven con tus parámetros
 - En serio, piensan de otra forma



“Todo por la pasta”, literalmente. ¿Has oído hablar de los perfiles sicopáticos, personas sin ninguna empatía? Pues eso. Los mismos que hacen ciberbullying mayoritariamente (P-74 “Atalaya”), por cierto

¿CÓMO PUEDE LA GENTE “CAER” EN ESTO?

3. Los delincuentes **NO son como tú y como yo**

- **Esta gente piensa distinto**, "prey on the weak" 🦅
 - Ellos son "depredadores", nosotros todos "presas"
 - No descartes la **extorsión** (fingida o real)
 - **Robo de identidades** de tus conocidos
 - Que te **vigilen** (stalking) tus RRSS o en la vida real para saber más de ti, y que la estafa resulte más creíble
 - Se llama "hacer OSINT", y lo vemos en la "**Santísima Trinidad**"
 - ¡O **cualquier maldad** que se te ocurra! 😞
- Se llega incluso a **autojustificaciones** como
 - "Se lo merecía por ser tan tonto", "Haber estado más atento"...
 - Culpar a la víctima, victim blaming
 - Hay quien dice que como la sociedad "les roba", ellos también
- **No trates de entender sus motivos**
 - **Porque salvo que seas uno de ellos no los vas a entender**



Detrás del cibercrimen no solo hay estafas, puede haber muchas otras cosas más: ciberacoso, espionaje, ciberguerra entre empresas o países...es otro mundo del crimen, mucho más profundo y turbio de lo que imaginas....

NO SE VAN A APIADAR DE TI

¿QUIÉN ESTÁ DETRÁS?

● **Bandas organizadas y especializadas de todo país y etnia** que viven de esto y son profesionales del timo 🍌 🍌

- **Nunca asumas que son “tontos”**, este tipo de criminales son cada vez más sofisticados
- Se pueden ganar **grandes sumas de dinero**, e invierten en su propia formación
 - ¡Como tú estás haciendo ahora para protegerte de ellos!
- <https://twitter.com/elhackernet/status/1527197191755948033?t=Q8N0fopmwhSJ20ZjdvbtUA&s=19>



Banda encarcelada por timo telefónico a pensionistas
bbc.co.uk



Banda londinense encarcelada por una estafa multimillonaria con entradas falsas
kentlive.news

¿GRUPOS CRIMINALES PROFESIONALES ORGANIZADOS?

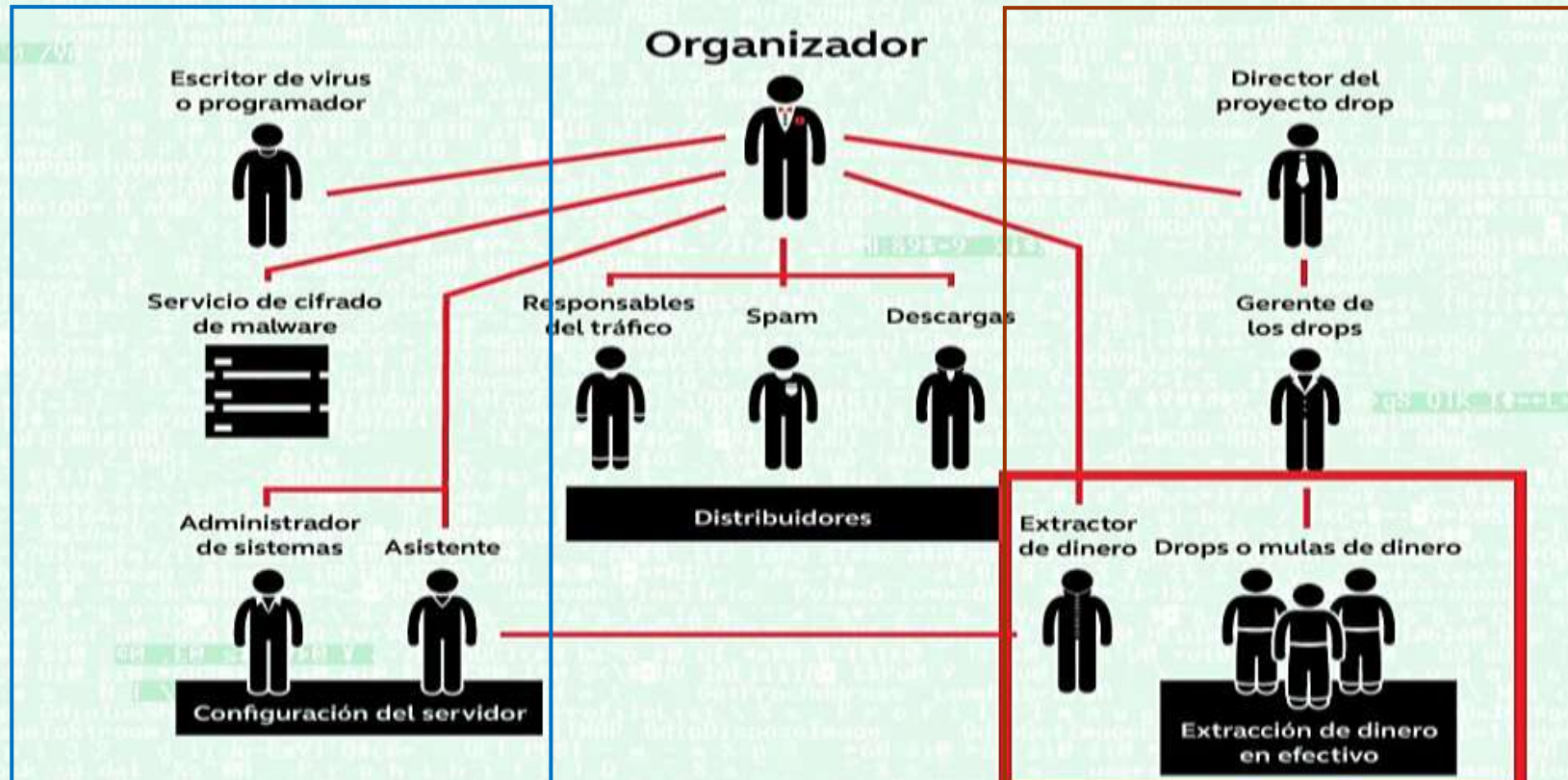


José Manuel
Redondo López

Cómo está organizado un grupo cibercriminal

En este momento, Kaspersky Lab está investigando cinco grupos ciber criminales de habla rusa involucrados en robo de dinero mediante malware.

Gente
técnica



Gente no
necesariamente
técnica

El extractor de dinero transfiere fondos desde las cuentas financieras atacadas hacia las cuentas provistas por el gerente de drops. Éste les indica a los drops o mulas de dinero adónde transferir el dinero. Una parte del dinero resulta en manos del director del proyecto drop, mientras que el resto se transfiere al director del grupo criminal.

¿CREES QUE LO HAS ENTENDIDO TODO? ¡AUTOEVALÚATE!



● Asegúrate de haber entendido lo siguiente

- Respecto a los **objetivos**...
 - *Los distintos objetivos de un ciberdelincuente*
 - *Que no siempre buscan dinero directo, sino cosas que les den beneficios económicos indirectos*
 - *Que la base de todos los problemas es un clic donde no debes*
 - *Las distintas formas de contacto principales que tiene un ciberdelincuente*
- Respecto a la **sicología** del delincuente...
 - *Cómo funciona la mente de un ciberdelincuente, y que se puede tratar como un "depredador" de la naturaleza*
 - *Que nadie está a salvo de estos problemas debido a la sofisticación de las falsificaciones*
 - *Que son bandas profesionales organizadas y no personas probando suerte desde su casa*

< Ir al Índice



FORMAS DE ENGAÑO

Corre más que el veneno que llevan dentro



 Documentos

 Llamadas

 Webs falsas

 Identidades



¿QUÉ VAMOS A VER EN ESTE BLOQUE?



José Manuel
Redondo López

● En este bloque te voy a enseñar...

- **Cómo se falsifican** los distintos elementos que participan en un fraude
 - Para ello voy a usar una **escala de sofisticación** propia que uso para categorizarlas
- Que cualquier cosa que puedes recibir vía email **puede ser falsificada**
 - Y que algunas falsificaciones son **prácticamente indistinguibles** de la real
- **Cómo tomar conciencia** de que puedes ser una víctima cuando menos te lo esperes
 - Tu nivel de conocimientos técnico **no te puede mantener 100% a salvo**
 - En realidad, **nada** puede hacerlo...



ELEMENTOS FALSIFICABLES

- Ya vimos que la cantidad de cosas falsificables hoy día **es enorme**
 - **Medios digitales** 📱 : Emails, SMS, mensajería (WhatsApp, Telegram, Discord, en público/grupos cerrados de cualquier red social...), llamadas telefónicas...
 - **Medios físicos** 📄 : **QR colocados estratégicamente** o suplantados, **USBs "perdidos"** ...
- Las falsificaciones **ya no son "cutreces"** fácilmente identificables
 - Las **"fugas de datos"** (data leaks), tan frecuentes hoy en día, se usan para mejorarlas
 - Se usan **datos reales robados** de las víctimas para aumentar la credibilidad
 - Y con el **uso de la IA**, los spear phishing son **MUY** elaborados
 - Muchas falsificaciones integran **varios elementos de forma coordinada**
 - **"Obra de teatro" del mal**
 - Emails, webs, documentos, personas (vidas incluidas), llamadas, mensajes...se crea una ilusión completa
- **NUNCA te confíes** 🛑
 - Incluso la estafa con la premisa más absurda puede ser muy peligrosa
 - Todo **depende de lo elaborado de la falsificación**

“NIVELES” DE COMPLEJIDAD DE UNA FALSIFICACIÓN

● Yo clasifico las falsificaciones en **5** niveles

- De más a menos cutre, ya que resulta fácil de entender a quién se lo explico (**no es algo oficial**)
- **El nivel 5 incluye la suplantación:** No hay falsificación de elemento alguno, es alguien usando algo real tras robarlo (incluido cuentas de usuario)

Probabilidad de
engaño

-

+

Trabajo de
elaboración del
delincuente

Nivel	Tipo de falsificación
1	 Falsificación burda , sin cuidado y/o en lenguaje no nativo del delincuente (errores obvios)
2	 Falsificación fácilmente detectable teniendo entrenamiento sobre ciberestafas básico
3	 Falsificación trabajada que puede engañar incluso a personas entrenadas que no presten atención (tienen prisa, les pilla por sorpresa...)
4	 Falsificación avanzada con un trabajo considerable detrás, que requiere atención y entrenamiento avanzado para pillarla
5	 Falsificación ¿casi? indistinguible del elemento real incluso a ojos expertos, robo de la identidad del emisor real de manera que no es posible distinguirlo de algo falso, o falsificación muy realista con IA, extremadamente peligroso



Documentos maliciosos

Cuando un fichero lleva el mal dentro



Enlaces



Malware



Falsificaciones

DOCUMENTOS FALSIFICADOS Y/O MALICIOSOS

● Cualquier nivel de documento falso **puede venir con malware adjunto que se ejecutará al abrirlo**

- Especialmente de Office, pero también PDF
- **¡Mucho cuidado al abrir documentos, aunque resulten “cutres” pueden venir con “bicho”!** 

Probabilidad de
engaño



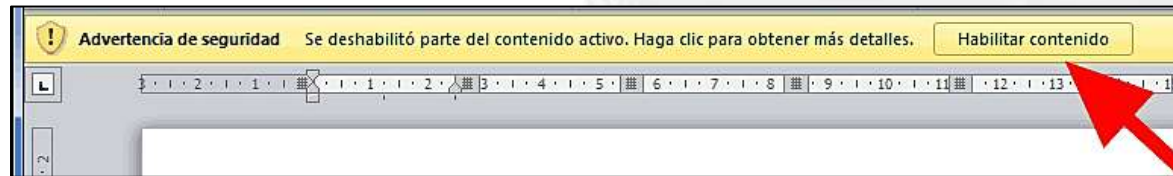
Trabajo de
elaboración del
delincuente

Nivel	Tipo de documento falsificado
1	 Documento redactado de forma negligente , sin formato profesional y/o errores evidentes en el uso del idioma o la presentación de la información
2	 Documento que usa logos e iconos oficiales , pero con aspecto no profesional y pequeños errores en el uso del idioma
3	 Documento manipulado a partir de un clon con muestras de manipulación, imitación de una comunicación / documentación real o con un estilo visual más convincente y profesional
4	 Lo anterior + con elementos falsos que refuercen su “veracidad” para aumentar su credibilidad y no detectar manipulaciones. Ej.: falsos sellos, firmas, etc. para que parezca que han sido verificados por alguna entidad o persona...
5	 Comunicación indistinguible de una real hecha por un empleado malicioso o delincuente que ha robado la cuenta de un empleado real (data leak): ¡la única defensa es ver si lo que pide es razonable!

FORMAS POR LAS QUE EL CONTENIDO DE UN DOCUMENTO PUEDE SER MALICIOSO

• Cuando abres un documento malicioso (independientemente de su “cutrez”) te pueden pasar dos cosas

1. Que sea un documento “normal” que “sólo” te pida **hacer clic en un enlace** 
 - Ya vimos que en la página a la que irás al hacer ese clic se encuentra el malware **¡No hagas nunca clic!**
 - Esto se tratará cuando hablemos de enlaces posteriormente
2. **Que el documento tenga el malware dentro** , con lo cual te pedirá que lo ejecutes
 - Es decir, que **“habilites su contenido”**
 - Hazte a la idea de que eso equivale a “hola, soy un virus, ejecútame”: **va a engañarte para que lo hagas**
 - **¡Cualquier cosa con tal de que pulses en el botón “Habilitar contenido”!**



Pulsar este botón es lo peor que puedes hacer. Yo le llamo “el botón de la muerte”    
¡NO HAGAS CLIC! (esto no te pasa si lo abres vía web con un programa de Office 365 online, por cierto)

- **Cuidado:** Si tu visor (Word, Acrobat...) no está actualizado, podría ejecutarse...**¡sin que habilites nada!** 
 - Se aprovecharía de un **fallo de seguridad** en el programa

• ¡Veamos unos ejemplos de ambos tipos!



Documentos con enlaces maliciosos



DOCUMENTOS CON ENLACES MALICIOSOS

- Estos son documentos PDF con un enlace malicioso de **Nivel 1**
 - Tira el enlace ahí en medio “a cara perro” 🐕
- No tienen aspecto profesional en absoluto
 - Texto y poco más
 - No hay logos, estilos...
- Usa la urgencia y un falso agradecimiento para que no pensemos y hacer clic
 - Muy típico...
- Tiene errores gramaticales
- ¿Crees que son los más comunes? Pues lo siento, pero **ya no** 🧑
 - Ha llegado la IA amigos/as...



José Manuel Redondo López

Ya (casi) nadie pica con estas cosas...

Barrister Bills Adams
para Barrister [v] 13:35 (hace 1 hora) ☆ [icon] [icon]

Buenas noticias de Barrister Bills Adams.

1

Espero que usted está leyendo este mensaje por la buena salud. Quiero hacerle saber que he recibido ayuda de un Estado Unidos de América ciudadano que es un hombre de negocios. Él fue capaz de ayudar con la transacción / herencia que anteriormente empecé con usted.

No he olvidado su esfuerzo pasado que hizo que me ayude. Sé que ha intentado todo lo posible para que me ayude, aunque las cosas no funcionaron para los dos. Debido al esfuerzo que hizo en asistir a mi y el gran amor y preocupación que me mostró durante el periodo que estuvimos comunicarse entre sí, me trasladaron a compensar con la suma de \$ 500,000.00 (quinientos mil dólares estadounidenses).

Esto es para hacerle saber que me dejó un cheque bancario con Virgin Atlantic Delivery Company en Dubai en los Emiratos Árabes Unidos para la seguridad antes de viajar a mi país.

En este sentido, yo le aconsejaría que en contacto con el Virgin Atlantic entrega Compañía tan pronto como sea posible saber cuándo van a entregar su paquete a usted antes de la fecha de caducidad.

Para su información, he pagado por los gastos de envío para su giro bancario pero sólo a exigir la suma de (\$ 580 USD) quinientos ochenta dólares por tasas de seguridad y de demora, que se va a enviar a la empresa de mensajería y seguridad para entregar su proyecto directamente a su dirección postal en su país. Por lo tanto usted necesita ponerse en contacto con la empresa de mensajería y seguridad de inmediato y pagar las cargas que no excederá la suma de (\$ 580 USD).

A continuación se presentan los datos de contacto de la empresa de entrega:

[View document](#) 1.

E-mail: infovirginatlantic@gmail.com

Número de registro: wwdsc100 / 2016

Número de Referencia: Virgin / wwdsc / 0000453

Hi,

I have shared an important document via Dropbox, for security reasons. To view shared document, log in with your email address and password to access. Please quote immediately.

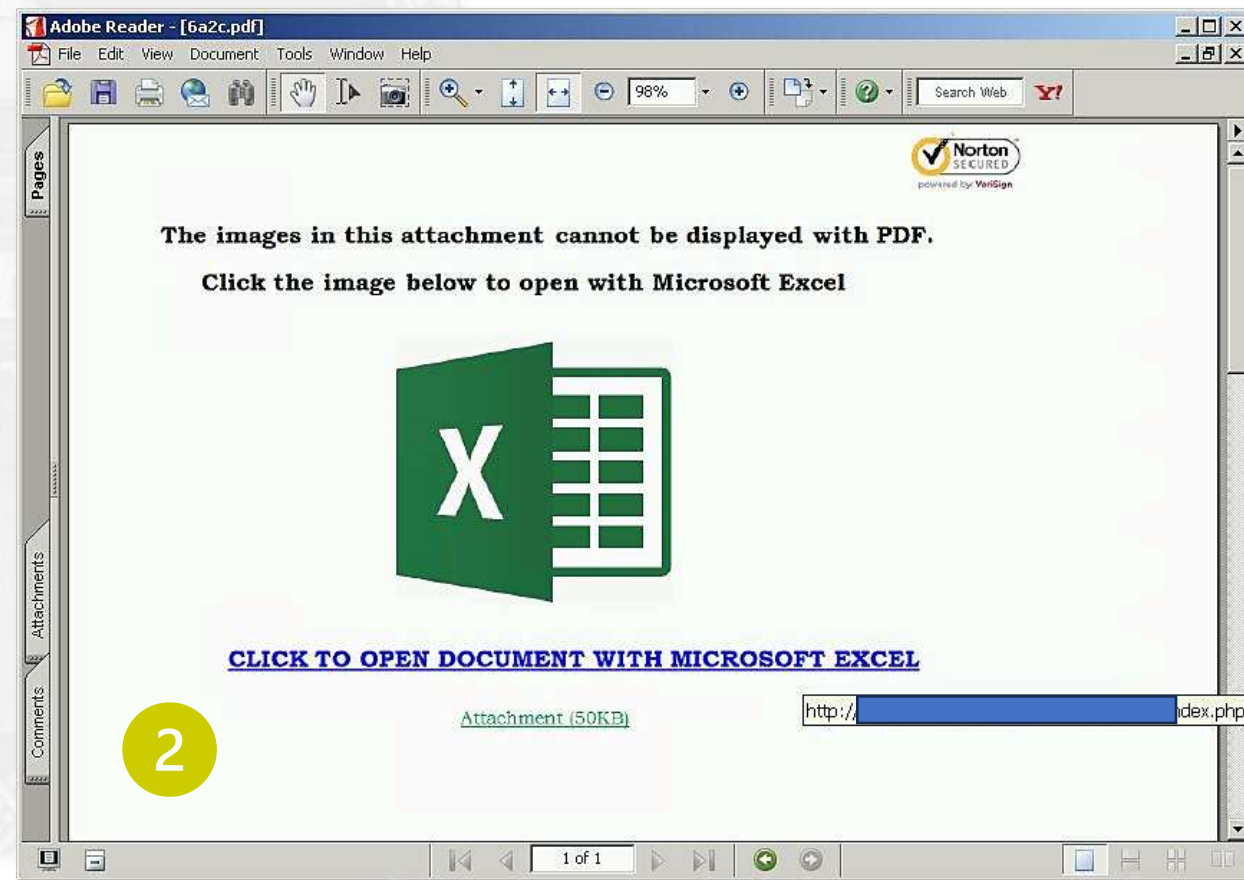
[View document](#)

Thank you.

1

DOCUMENTOS CON ENLACES MALICIOSOS

- Este documento PDF es de **Nivel 2**
- Dice que abre un Excel, pero en realidad va a una web
- Usa logos (bastante cutremente) para ganar credibilidad
 - Falsamente verificado por el antivirus Norton
 - Básicamente **han pegado la imagen del logo** y ya está 😊
- El estilo es malo, pero al menos usa imágenes y colores 🤪



Al menos usa el logo correcto... 🤪

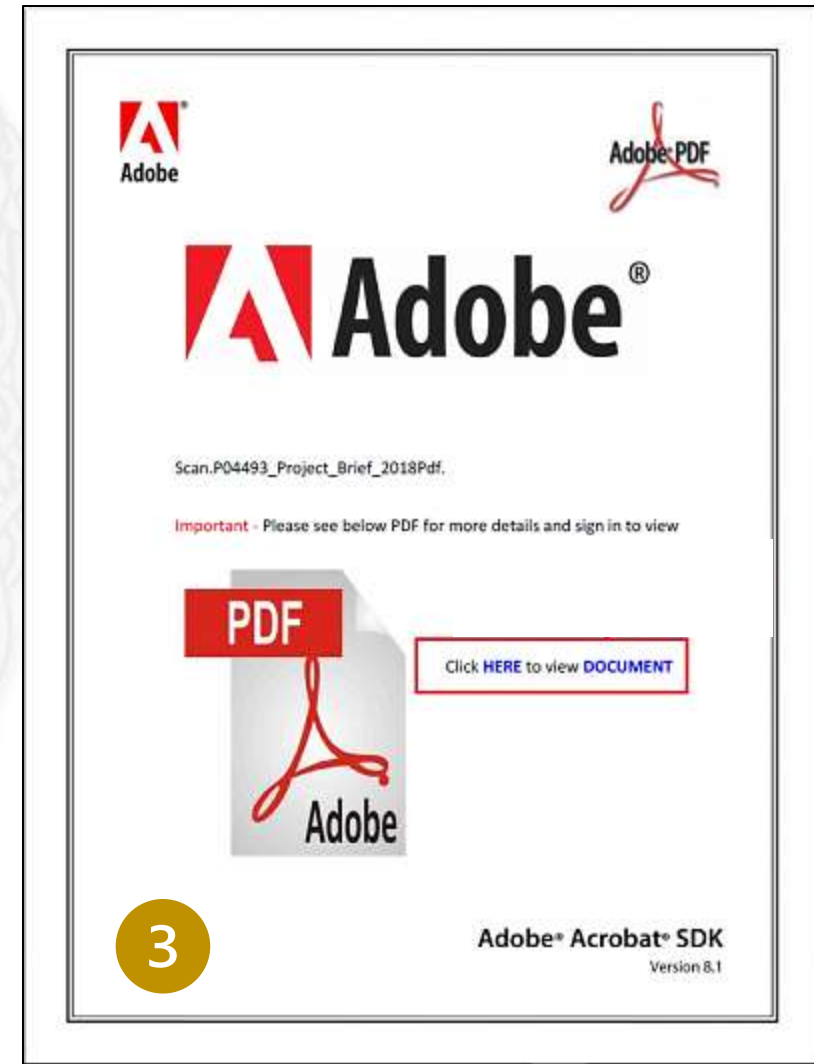
DOCUMENTOS CON ENLACES MALICIOSOS



José Manuel
Redondo López

● Esto es un documento de **Nivel 3**

- Estilo más cuidado que los anteriores, más profesional
- Aspecto más cuidado....
 - Imita la pantalla de bienvenida del lector Acrobat PDF Reader
- Muchos logos oficiales
- Tiene aún algún error gramatical pequeño
- Pero, como ves, al final todo es para que **hagas clic en el enlace** para ver el documento



Repleto de imágenes e iconos robados, pero al menos no da asco verlo

DOCUMENTOS CON ENLACES MALICIOSOS



José Manuel Redondo López

● Este es un documento de **Nivel 4**

- Correspondiente a una **falsa denuncia** por tenencia de pornografía
- Timo clásico (ver "**Nautilus**")

● ¿Por qué es bueno?

- Estilo profesional y **correctamente redactado**
- **Estructura** de documento formal
- **Logos y sellos** oficiales falsificados
- Seguramente plagiado de uno real

● Pero con un correo de Gmail de contacto

- ¿Documento oficial y contacto por Gmail / Outlook / etc.? ¡**Estafa seguro!**
- ¡Las entidades oficiales tienen su propio dominio de correo! (Ej.: soyunprofe@uniovi.es)



INTERPOL CONVOCATORIA



4 Carpetas N°:ES00415215-03/22

Sr. Sra.

A solicitud del Sr. ALEJANDRO MAYORKAS, Secretario de Seguridad Nacional de los Estados Unidos de América, Jefe del Departamento de Riesgos Mayores "Brigada para la Protección de Menores (BPM)" le hacemos llegar la presente invitación.

La citación por un agente de la policía judicial está prevista en el artículo 390 -1 del Código de Procedimiento Penal. Vale citación ante el tribunal y lo decide el Ministerio Público.

De conformidad con lo dispuesto en el artículo 372 del Código Penal establece: "El atentado al pudor cometido sin violencia ni amenazas contra la persona o con ayuda de la persona de un niño de cualquier sexo, menor de 16 años, será reprimido con pena privativa de libertad".

El artículo 227-23 del Código Penal dispone: "El hecho, con vistas a su difusión, de fijar, grabar o transmitir la imagen o representación de un menor cuando esta imagen o esta representación tiene un carácter pornográfico es castigado con 5 años' prisión y multa de 80.000 dólares.

Emprenderemos acciones legales contra usted poco después de la incautación de una computadora de la ciberinfiltración por:

(PORNOGRAFÍA INFANTIL - PEDOFILIA - EXHIBICIONISMO - PORNOGRAFÍA CIBERNÉTICA)

Para su información, la ley 390-1 del Código Procesal Penal de marzo de 2007 aumenta las penas cuando las proposiciones, agresiones sexuales o violaciones se hayan cometido a través de Internet.

Cometió el delito después de ser atacado en Internet (sitio de publicidad), ver videos de naturaleza pornográfica infantil, fotos/videos desnudos de menores fueron grabados por nuestro gendarme cibernético y constituyen prueba de sus delitos.

En aras de la confidencialidad, le enviamos este correo electrónico, por lo que lo invitamos a responder a la dirección que se indica a continuación, por supuesto, brindándonos sus documentos de respaldo y las razones que lo llevaron a actuar de esta manera, sus justificaciones para que sean investigados y verificados para evaluar las sanciones; esto en un plazo estricto de 72 horas.

Contactar: ppoliciadelainterpol793@gmail.com

Ahora está llamado a responder por su propia voluntad de inmediato para evitar que este asunto se propague y tome otro giro desagradable a su favor.

Pasado este tiempo, nos veremos obligados a enviar nuestro informe al Ministerio Fiscal para que dicte orden de detención contra usted y procederemos a su detención inmediata por parte de la policía más cercana a su lugar de residencia.

Atentamente

Sr. Général-major Ahmed Nasser Al-Raisi

Presidente de Interpol, presidente electo de la Organización Internacional de Policía Criminal

Secretaría General Sección de Delitos Cibernéticos Brigada de Protección Civil



Mira las firmas , sellos, etc. aquí hay calidad...hasta que ves el mail

DOCUMENTOS CON ENLACES MALICIOSOS: COSAS A TENER EN CUENTA...

- Aunque algunos de los ejemplos estén en inglés, lo mismo pasa en Español
 - Con errores gramaticales obvios...¡o sin ellos!
 - ¡La falta de errores al escribir ya no es una razón para confiar en un documento!
- *¿Motivo de eso?* La IA, como veremos luego
- El objetivo de todos estos documentos es **que hagas clic en el enlace que tienen**
 - Sus enlaces pueden además estar diseñados para engañarte (lo veremos luego)
- A dónde vayas determinará cómo te atacarán, recuerda...
 - Te pedirán **descargar y ejecutar** algo
 - Te **pedirán datos personales** con algún pretexto
 - Directamente, **tratarán de instalarte** un malware
 - Más probable en lectores sin actualizar
 - Se aprovechan de vulnerabilidades que puedan tener





Documentos con malware dentro

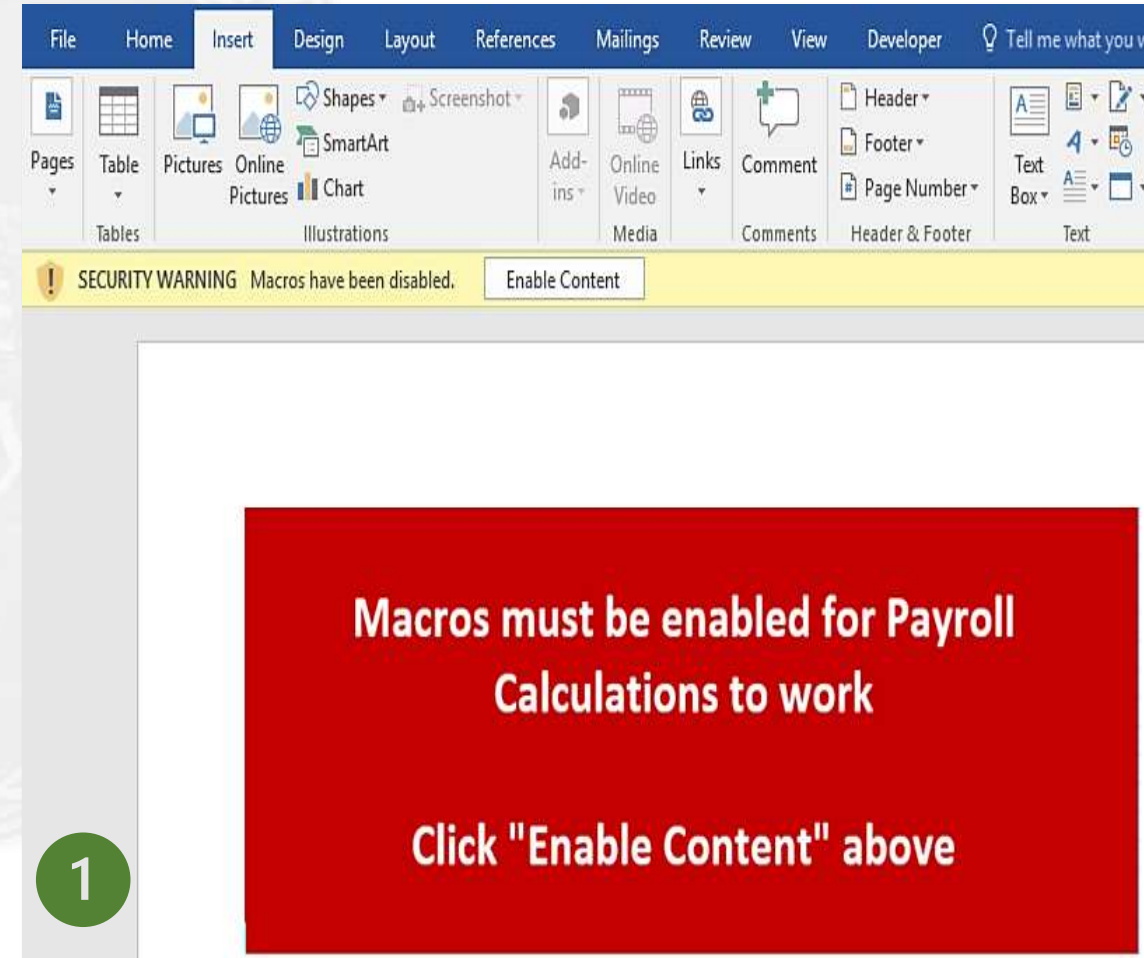


DOCUMENTOS CON MALWARE DENTRO: CÓMO TE CONVENCEN



José Manuel
Redondo López

- Este es un documento con malware adjunto de **Nivel 1**
- Es CUTRE 
 - Un cuadro rojo con letras, sin más 😊
 - Un mensaje simple con una excusa malísima
 - Cero esfuerzo en intentar que parezca algo creíble...
 - Estos delincuentes o pasan de todo o no tienen formación alguna...
- Pero vuelto a insistir, *¿es esto lo común hoy en día?* **Ya no**



Insertar Forma -> Rectángulo-> Añadir texto y hala, ya está...

DOCUMENTOS CON MALWARE DENTRO: CÓMO TE CONVENCEN



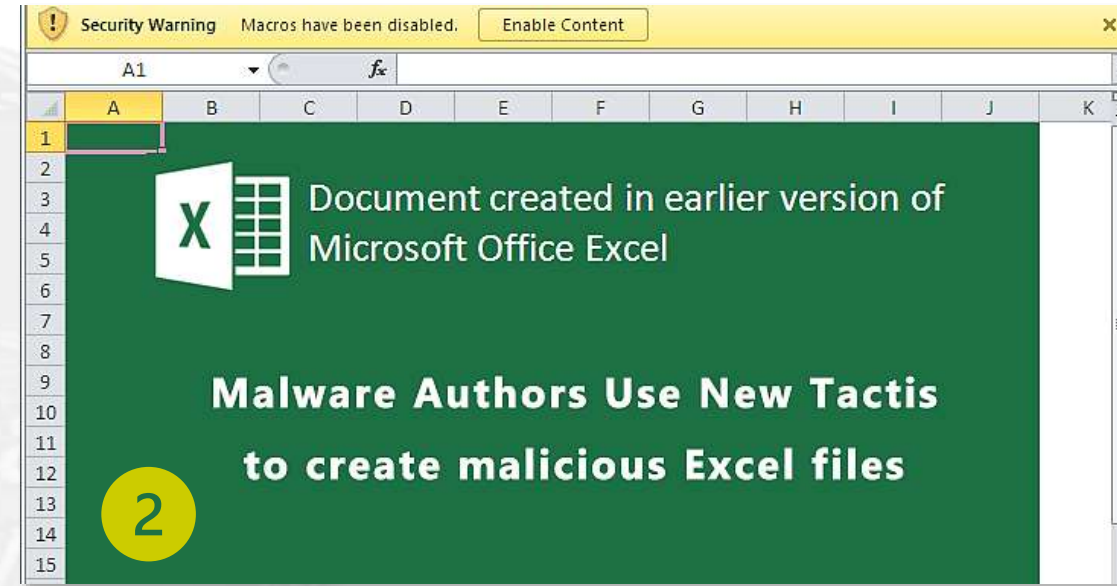
José Manuel
Redondo López

● Estos los considero **Nivel 2**

- Se inventa la excusa de que se ha creado en una versión anterior de Excel o Word
 - **Mentira** 😬: Los documentos de versiones anteriores los abre cualquier programa Office actual
- ¡Encima critica a los creadores de malware!
 - ¿Sicología inversa? 🤪

● Se usa el logo oficial de la Excel o Word como “gancho”

- Logos que se pueden descargar de Internet con una simple búsqueda en Google
- Se hace creer a la víctima usuario que el contenido del documento está “tapado”
 - Hasta que lo autorice con el 🪦 “botón de la muerte” 🪦 visto antes



Imita una especie de aviso del programa para que hagas lo que no debes

DOCUMENTOS CON MALWARE DENTRO: CÓMO TE CONVENCEN



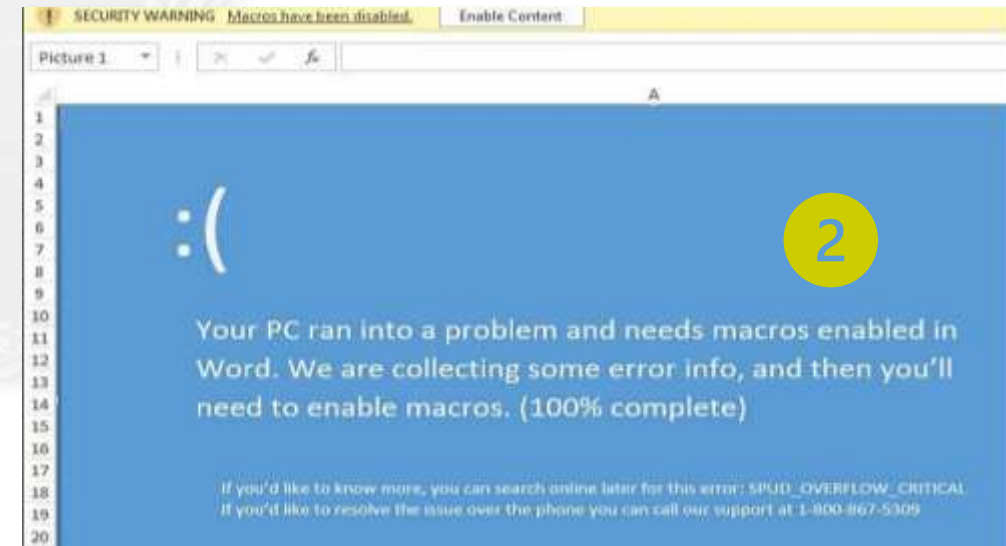
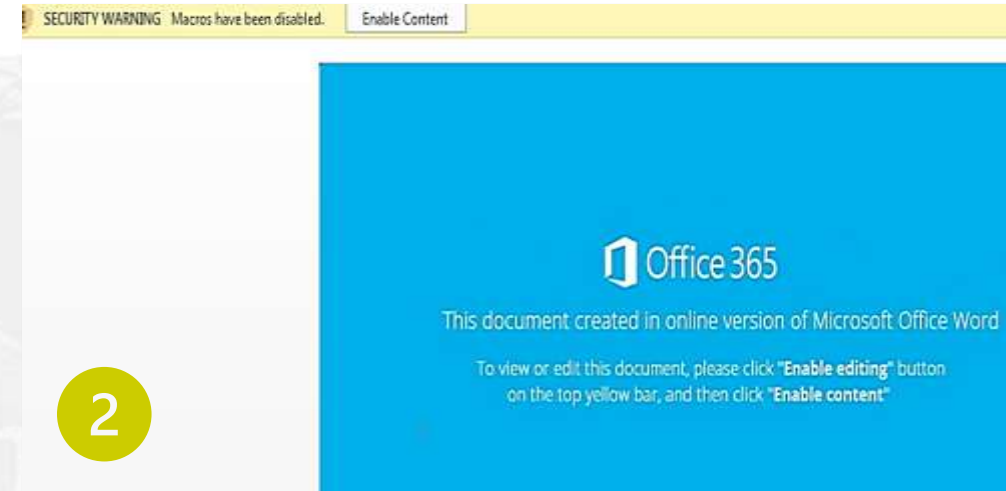
José Manuel
Redondo López

• Otros ejemplos de **Nivel 2** con excusas varias

- No lo puede abrir por que el documento se ha creado con la versión online de Word
 - **Otra Mentira** 🤔: Todo lo creado con esa versión puede abrirse con el Word “normal”
- Copia de la pantalla de fallo catastrófico de Windows
 - Y que pulses el “botón de la muerte” 💀 para “arreglarlo”
- ¡Cualquier excusa que se os ocurra les sirve con tal de que cliques en el dichoso botoncito!

• Y ojo, que esto no se limita a Word ¿eh?

- Cualquier documento **de cualquier programa** de Office vale para propagar malware
 - Excel, Word, PowerPoint...
- ¡No abras ninguno que no conozcas!



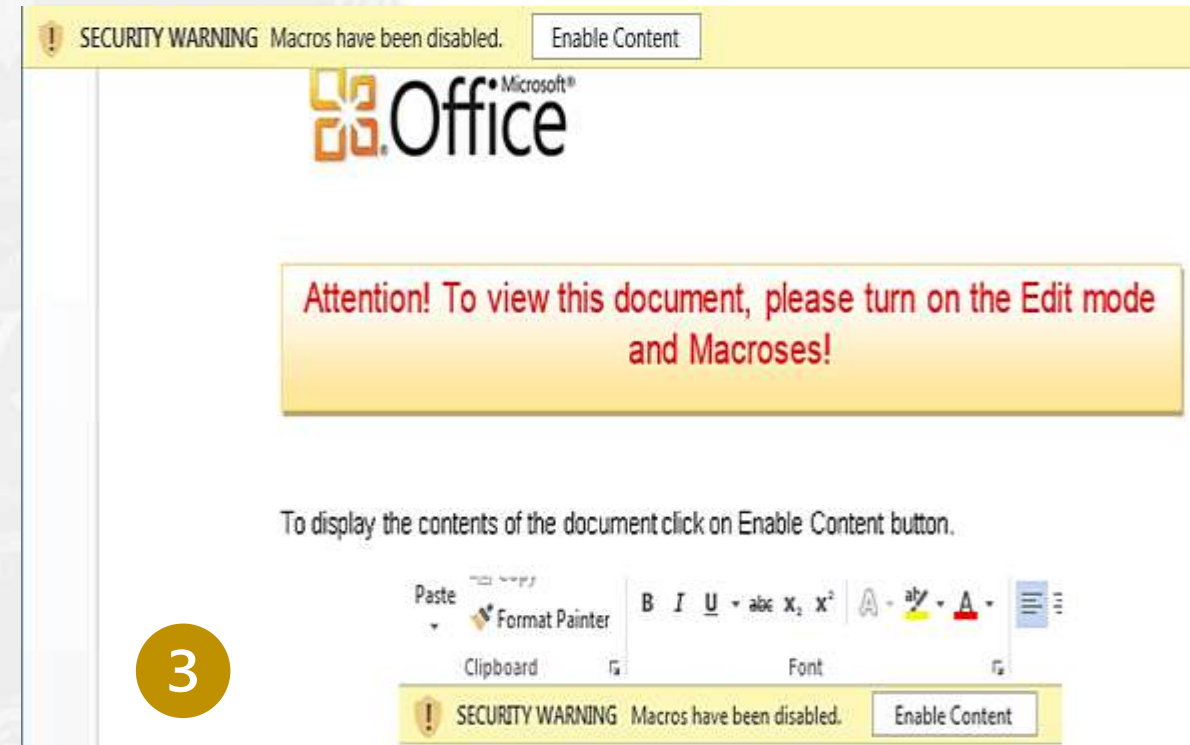
Más imitaciones de avisos, una de ellas incluso imita la típica “pantalla azul” de Windows

DOCUMENTOS CON MALWARE DENTRO: CÓMO TE CONVENCEN



José Manuel
Redondo López

- Esto es un **Nivel 3**
- Incluye logos oficiales e instrucciones precisas para habilitar el contenido
 - Quieren que toques el “botón de la muerte” y no les vale la excusa de que no sabes hacerlo 😊
 - *¿Has visto que delincuentes más serviciales?*
- El aspecto es algo más profesional...
 - Pero la disposición de los elementos en el documento “canta” 🗿 bastante



¡Te hacen mansplaining! 😊

DOCUMENTOS CON MALWARE DENTRO: CÓMO TE CONVENCEN



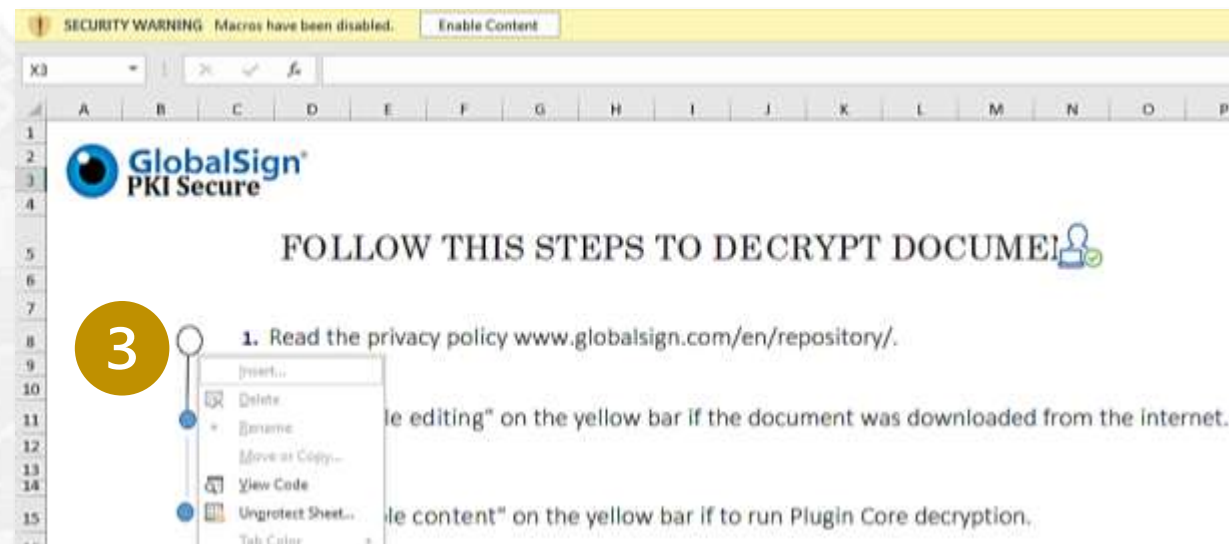
José Manuel
Redondo López

● Estos los he clasificado como de **Nivel 3** por la excusa “débil” que alegan

- **El documento está cifrado**  : Si lo estuviera, no podrías leerlo (ni esas instrucciones)
- **El documento está protegido**  : Si lo estuviera te pediría una contraseña
 - No que “habilites el contenido” (vaya basura de protección que con un botón te la saltas, ¿no?)

● Con una excusa un pelín más “currada”, podrían ser nivel 4 fácilmente...

- Logos oficiales y de empresas de seguridad para dar “credibilidad”
- Un aspecto gráfico más cuidado
 - Especialmente el de abajo
- Y más mansplaining...



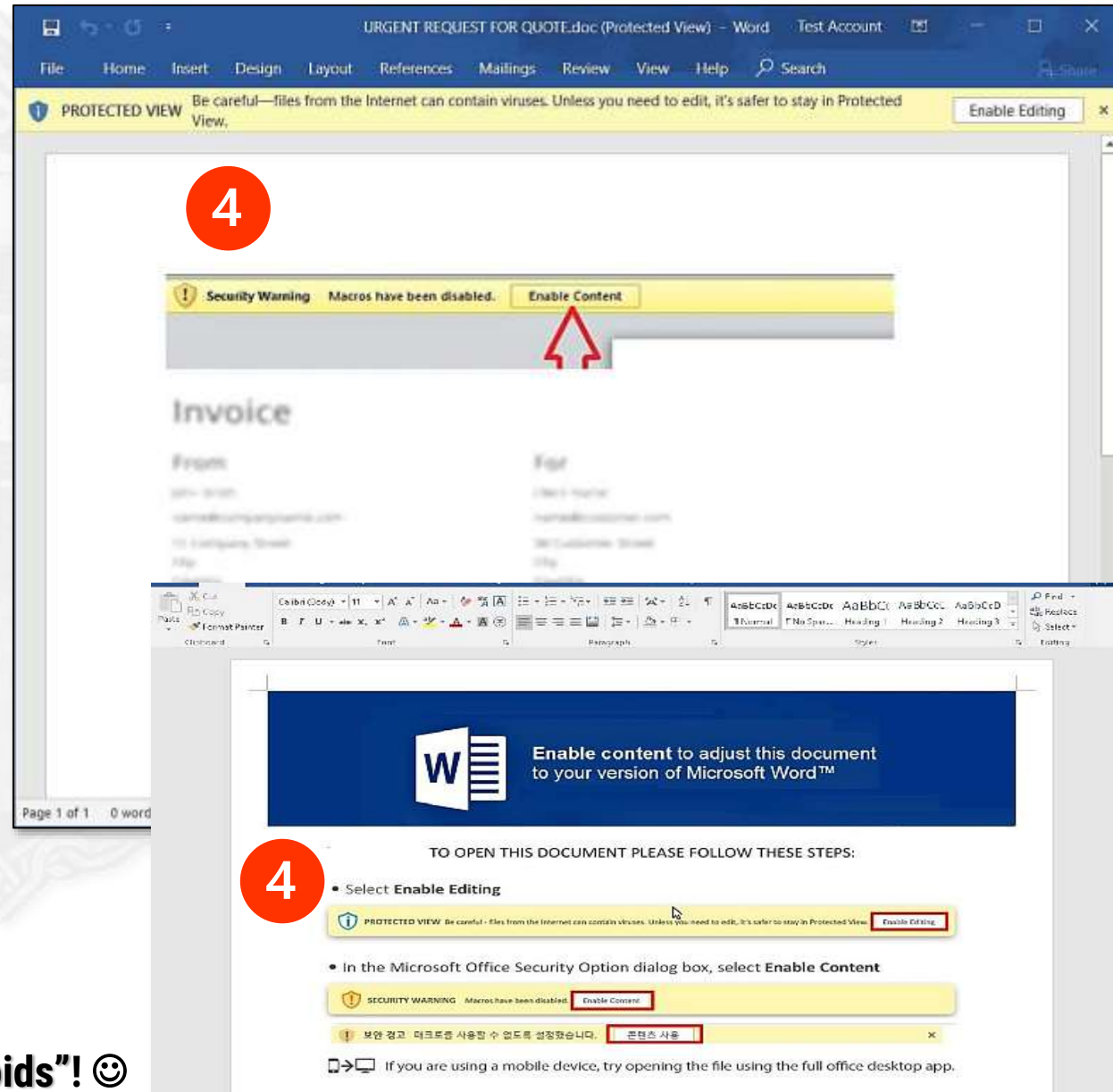
DOCUMENTOS CON MALWARE DENTRO: CÓMO TE CONVENCEN



José Manuel
Redondo López

- En un **Nivel 4** ya vemos mucho más trabajo gráfico
- Fíjate como sombrea el supuesto documento que contiene
 - El importante, el de la excusa del delincuente... (factura, multa...)
 - A la espera de que lo “desprotejamos” para verlo y ¡saber qué pasa!
 - Es falso, claro, es **otra táctica para engañarnos** (normalmente es una imagen)
- Tienen instrucciones precisas y un aviso en colores de Windows
 - ¡Todo vale para que le demos al botón!

¡Te hacen mansplaining “on steroids”! 😊

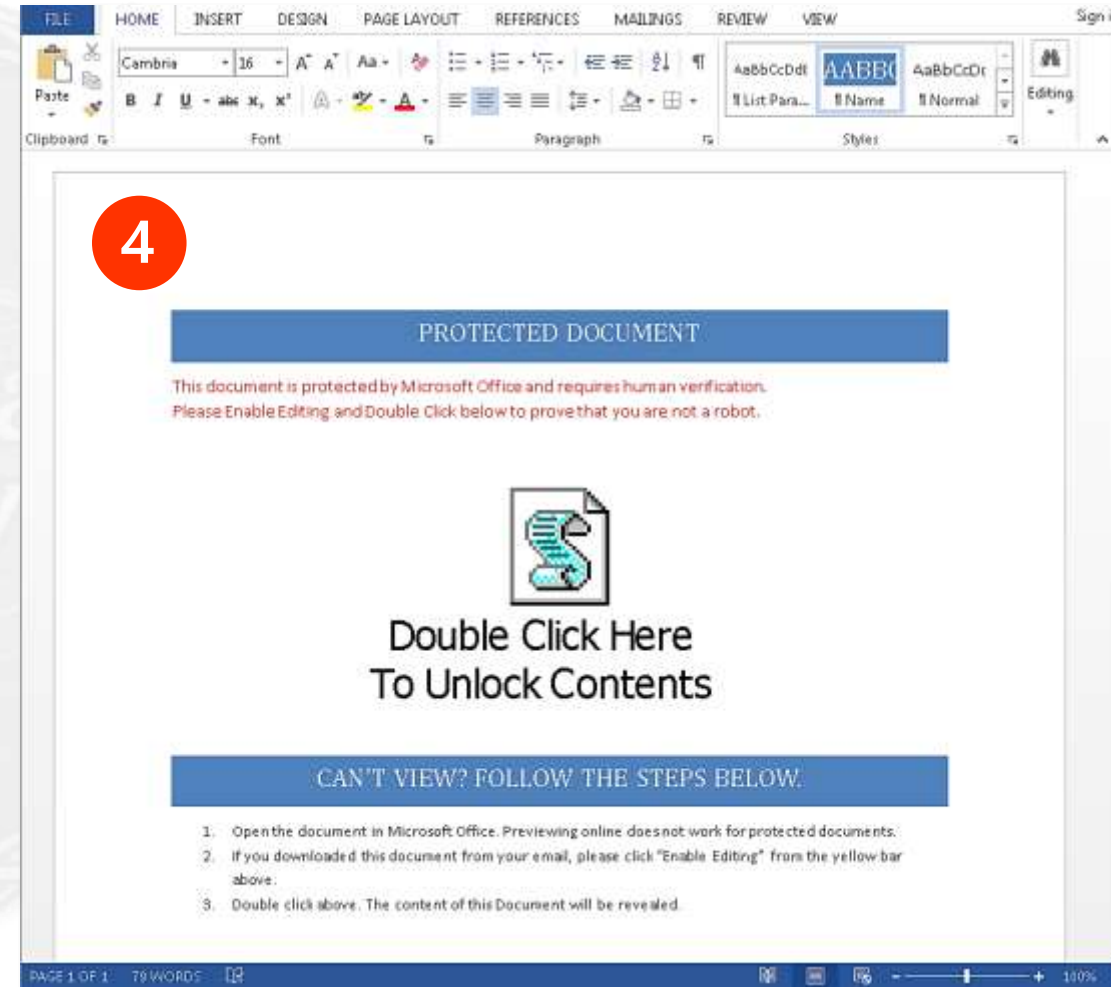


DOCUMENTOS CON MALWARE DENTRO: CÓMO TE CONVENCEN



José Manuel
Redondo López

- Este es otro ejemplo de un **Nivel 4**
- Redacción profesional, con estilos, párrafos...
 - **Recuerda:** Con las IA cualquier puede escribir como Cervantes si quiere 🖋️
- Presentación cuidada de los contenidos
- Excusa más creíble (“human verification”)
 - ¡Quieren que le des al botón para comprobar que eres una persona!



Mansplaining “on steroids” y encima apelando a que no eres humano...

DOCUMENTOS CON MALWARE DENTRO: ¿Y LOS PDF?



José Manuel
Redondo López

- Hay la creencia de que los PDF no pueden contener malware, **pero no es cierto**
- Pueden ser peligrosos de estas formas
 - Aprovechándose de **versiones viejas del lector** que sean vulnerables a fallos conocidos
 - **Problemas de configuración** que permiten que un PDF ejecute algo que lleva dentro
 - Que o es un **malware** o se lo descarga de algún sitio al ejecutarse
 - Pueden **engañarte para que cliques** en un enlace que te lleva a una web
 - Y en esa web es donde está el peligro
- Es decir, o tienen “bicho” o son portadores del sitio donde está el “bicho”



DOCUMENTOS CON MALWARE DENTRO: COSAS A TENER EN CUENTA...



- **De nuevo no te dejes engañar porque muchos ejemplos estén en inglés**
 - He visto equivalentes en Español de casi todo lo que te propongo aquí
 - *¿Y por qué no nos los has puesto en Español?* Porque la redacción de los ejemplos que encontré era muy cutre, y desvirtuaba la explicación del timo 😊
 - A lo mejor creías que los timos españoles se pillan fácil por lo mal redactados que están, y no ✖
 - Y recuerda, las IA **traducen muy bien** hoy en día...
- **Recuerda: Da igual el nivel, el objetivo siempre es el mismo**
 - **Que pulses en el botón de “habilitar contenido”** (aka “botón de la muerte”) y desencadenes esto
 - El documento trae dentro un programa (malware)
 - Al habilitar contenido das permiso al Office para que lo arranque
 - **Y es el que hará el verdadero daño** (o se descargará algo que lo haga)
 - Robarte datos, instalarte más **malware**, bloquearte el PC, cifrártelo (el **ransomware** del que hablamos)...
 - Es decir, sí que le estás diciendo al **malware** “venga, arranca”...
 - Solo que con la pulsación de ese botón “Habilitar contenido”
 - **Así que...** ❌ ❌ ❌ **¡ NUNCA PULSES ESE BOTÓN!** ❌ ❌ ❌

DOCUMENTOS CON MALWARE DENTRO: COSAS A TENER EN CUENTA...

● *¿Esto de habilitar contenidos tiene entonces algún uso legítimo?*

- Siempre me preguntan *¿Por qué no se quita si solo da problemas?*

● ¡Sí!, se creó para hacer documentos “inteligentes” o “automatizados” 🤖

- Que **comprueben los datos** que se le introducen ✅
 - Fechas correctas, edades que sean números, etc...
- Que den **mensajes de error** / aviso / instrucciones si el usuario hace algo mal ❌
- Que **calculen datos** a partir de otros datos ⚙️
- Que se **auto rellenen** en función de lo que los usuarios vayan introduciendo ↔️
- ...

● Pero todas estas funciones **ahora se usan mayoritariamente para el mal**

- Se que muchas administraciones usan documentos con esas características...
- ... pero debemos estar **MUY SEGUROS** de la procedencia del documento para habilitar su contenido

¿PUEDE UNA IMAGEN O UNA CANCIÓN TENER UN MALWARE?

- Es técnicamente posible (aunque bastante raro) que un fichero de esta clase tenga dentro malware
 - Pero para que se ejecute, necesitan aprovecharse de una vulnerabilidad del visor/reproductor
 - O de un segundo programa que lea y ejecute ese contenido malicioso
 - **Cosa que puedes evitar si los mantienes actualizados**
 - No obstante, **si recibes un fichero de imagen de extensión `.svg` desconocido, mejor no lo abras**
 - Son ficheros de imagen especial que **sí pueden tener malware dentro** por como se construyen
- Otra cosa es que abramos un documento que **CREAMOS** que es una imagen / canción / video, pero es un malware
 - Se suele recurrir a técnicas que **falsifican la extensión de un fichero**
 - Por ejemplo, poner una doble: `mitexto.txt.exe`
 - Es un programa, pero vemos `mitexto.txt`
 - Por defecto no se muestran las extensiones de los ficheros
 - Si hacemos doble clic estamos perdidos
 - **¡Se ejecuta un programa!**





 Documentos falsos



FALSIFICACIONES: MALICIOSOS, PERO PORQUE TE ENGAÑAN



José Manuel
Redondo López

● A veces lo que engaña es el contenido

- El documento no tiene malware alguno...pero el contenido es completamente falso
- Se usan como refuerzo (aumentar la credibilidad) en estafas
- Vamos, que son falsificaciones 😊

● Hoy en día se puede falsificar **TODO** para que parezca real

- De nuevo, gracias a las IA...
- Por muy “guapo” ✨ que parezca un documento, **todo es falsificable**

● Por tanto, ¡no decidas solo por el aspecto de un documento!

The image shows two examples of falsified documents. The left document is a bank statement from RBC Royal Bank, showing various transactions and balances. The right document is a bank transfer slip from RBC Royal Bank, showing a transfer of \$78,000.00 to a beneficiary named GAYDAMASCHUK YURIY. Both documents have red circles with numbers 4 and 5 respectively, indicating they are falsified.

Firmas, sellos, logos,
emblemas...da igual
¡Todos estos son
falsos!

The image shows a falsified Authority to Pay Certificate from the Federal Ministry of Justice, Nigeria. The document is dated 28TH NOVEMBER 2003 and certifies a payment of US\$6,000,00,00 MILLION DOLLARS to LATE ENGR. MARK ELHOURRY. The document has a red circle with the number 5, indicating it is falsified.

FALSIFICACIONES: MALICIOSOS, PERO PORQUE TE ENGAÑAN



José Manuel
Redondo López

- Los documentos con contenidos falsos son el medio favorito para **propagar desinformación**
 - Hay canales de Telegram, etc. donde se difunden muchos documentos falsos
 - Con fines **políticos, religiosos, ideológicos...**
 - Podrías alucinar con la cantidad de desinformación que existe hoy en día en Internet
 - Algunos le llaman **“la Internet muerta”** a la enorme cantidad de contenidos inventados existente en ella
 - Generados con IA, fake news, etc.
- Algunas falsificaciones son **muy buenas**
 - Algunas pueden descubrirse con la búsqueda de imágenes en Google (**F-31 “Descubierta”**)
 - Otras, con Maldito Buló (**F-31 “Descubierta”**)
 - Lo mismo que Maldito Timo (<https://maldita.es/timo/>)
 - Pero para fake news

Plaza Alfonso Comín, 5
08023, Barcelona, Catalunya
+34 932 55 40 00
www.quironsalud.es/portal-pacientes/

HD Health Diagnostics

Nº Laboratorio: 932274737
Fecha registro: 06/02/2021
Fecha edición: 06/02/2021

**** PARCIAL ****

Datos del Paciente
Fecha: 06/02/2021
Centro: QuirónSaludBarcelona
Servicio: E.A. CLINICA
Cama:
Sexo: VARON
Edad: 05/05/1966 (54 años)
Tel: [REDACTED]

Nombre: Salvador Illa Roca
Nº Historia: [REDACTED]
D.N.I.: [REDACTED]

Cargo: PRIVADOS

Página 1 de 1

Biología molecular

Prueba	Resultado	Unidades	Valores de Normalidad
Detección del nuevo Coronavirus COVID-19 (SARS-2) mediante PCR	Positivo		

Consulte inmediatamente a su médico de cabecera o centro de salud en caso de resultado positivo de la prueba. Si desea que el seguimiento de su caso se lleve a cabo en un centro del grupo Quirónsalud, llame al teléfono 901 500 501 para solicitar cita urgente. Un resultado negativo indica ausencia de infección activa (no se detecta presencia del virus). Sin embargo, no excluye que el paciente haya estado expuesto al virus y tras superar la enfermedad su futura presencia viral. En el caso de sospecha de una infección pasada, se

Imagen falsa que se difundió vía Telegram de una falsa PCR positiva del entonces ministro Salvador Illa con fines políticos. Fuente:

https://www.lasexta.com/noticias/nacional/elecciones-Cataluña/psc-denuncia-fiscalia-alvise-perez-difusion-falsa-pcr-positiva-salvador-illa_2021021260267d0fec8b8d0001a891b6.html

¿CREES QUE LO HAS ENTENDIDO TODO? ¡AUTOEVALÚATE!



José Manuel
Redondo López



● Asegúrate de haber entendido lo siguiente

- *Que las falsificaciones ya no son "cutres", sino todo lo contrario*
- Y con respecto a los **documentos que recibes...**
 - *El problema de los documentos maliciosos que llevan enlaces*
 - *El problema de los documentos maliciosos que llevan archivos adjuntos (aunque no los veas), y lo que quieren los delincuentes que hagas con ellos*
 - *Que, hoy en día, se puede falsificar todo en lo relativo al aspecto de un documento*
 - *Que, aunque un documento no llegue contenido malicioso per se, en caso de que sea falso se puede usar para otro tipo de ataques que pueden ser igual o más peligrosos*
 - *Cómo esto afecta a las enormes campañas de desinformación que tenemos en nuestro día a día, tanto en internet como en algunos medios de comunicación*



Llamadas y mensajes falsos

Formas de comunicarse contigo (teléfono, emails, mensajes de RRSS, apps...) para engañarte



SMS O LLAMADAS FALSIFICADAS: N° DE TELÉFONO DE ORIGEN

- Los n°s de origen de llamadas / SMS pueden ser falsificados con el equipamiento adecuado ¡No te fíes!
- Es una técnica llamada “Caller ID Spoofing”: https://en.wikipedia.org/wiki/Caller_ID_spoofing

Probabilidad de
engaño



Nivel	Tipo de n° de origen
1	🇵🇪 N° extranjero desconocido / de un país donde no conocemos a nadie ni tenemos relación alguna
2	😄 N° nacional desconocido
3	👤 N° nacional de una supuesta “empresa colaboradora”
4	👤 N° de la empresa real suplantado
5	👤 N° teléfono oficial robado por un delincuente o empleado malicioso. Solo es posible identificar la estafa por las intenciones de lo que pida (datos privados, información bancaria...)

Trabajo de
elaboración del
delincuente

COMPORTAMIENTO SEGURO ANTE LLAMADAS

- **A la hora de recibir llamadas telefónicas, el comportamiento aconsejable es**
 - 🧐 **Nº extranjero** desconocido / de un país donde no conocemos a nadie ni tenemos relación alguna: No te molestes ni en contestar, bloquea y listo
 - 😄 **Nº nacional** desconocido: Normalmente se debe tratar igual que los anteriores
 - Salvo que tengamos contacto o estemos esperando llamadas de alguna entidad que use centralitas (médicos, escuelas...)
 - Suelen ser **nºs más largos de lo habitual** que empiezan por 6 o 9 normalmente
 - 😬 **Nº nacional** de una supuesta “empresa colaboradora” de una legítima (gas, teléfono...): Alguien se hace pasar por una empresa legítima para algún fin malicioso
 - **Sonsacar datos personales** (para hacer contratos fraudulentos, robo de datos bancarios...)
 - O para cualquier tipo de estafa o robo derivado
 - La respuesta es que **hay que colgar a cualquier persona que te pida datos** de cualquier tipo
 - Y si lo que ofrece interesa, llamar tú a la compañía (con el nº oficial)
 - 🤖 **Nº de la empresa real** suplantado: Igual que antes, si pide datos, cuelga
 - Es así de triste, pero las campañas de venta por teléfono ya no son fiables (hay demasiados delitos)

SMS O LLAMADAS FALSIFICADAS: N° DE TELÉFONO DE ORIGEN



José Manuel
Redondo López

- ¡Los SMS falsos con n° falsificados **aparecen en la misma lista que los reales!**

- Esto es muy peligroso, al aumentar su credibilidad

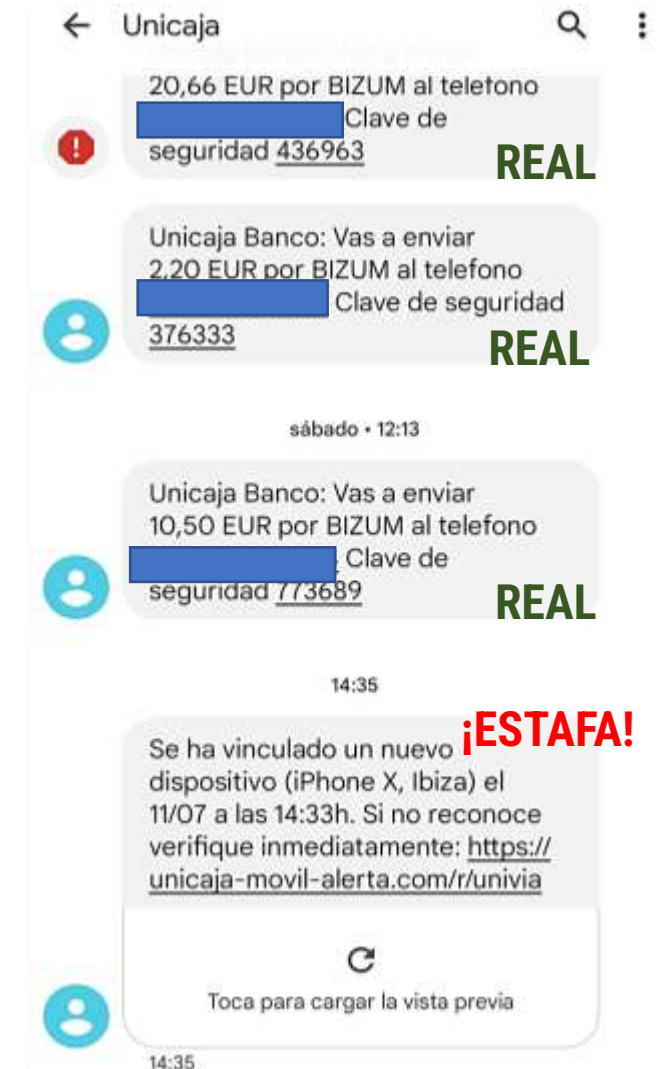
- Las normas con el contenido de un SMS son las mismas que las de los mensajes que veremos

- En general asume que si un SMS lleva un enlace **ES FALSO** 📎 😡
 - Los reales te dicen “Vete a tu cuenta de...” pero no te ponen el enlace para que pulses en él

- Si es una llamada, el que te llama te intentará comer la cabeza con **CUALQUIER COSA** para que

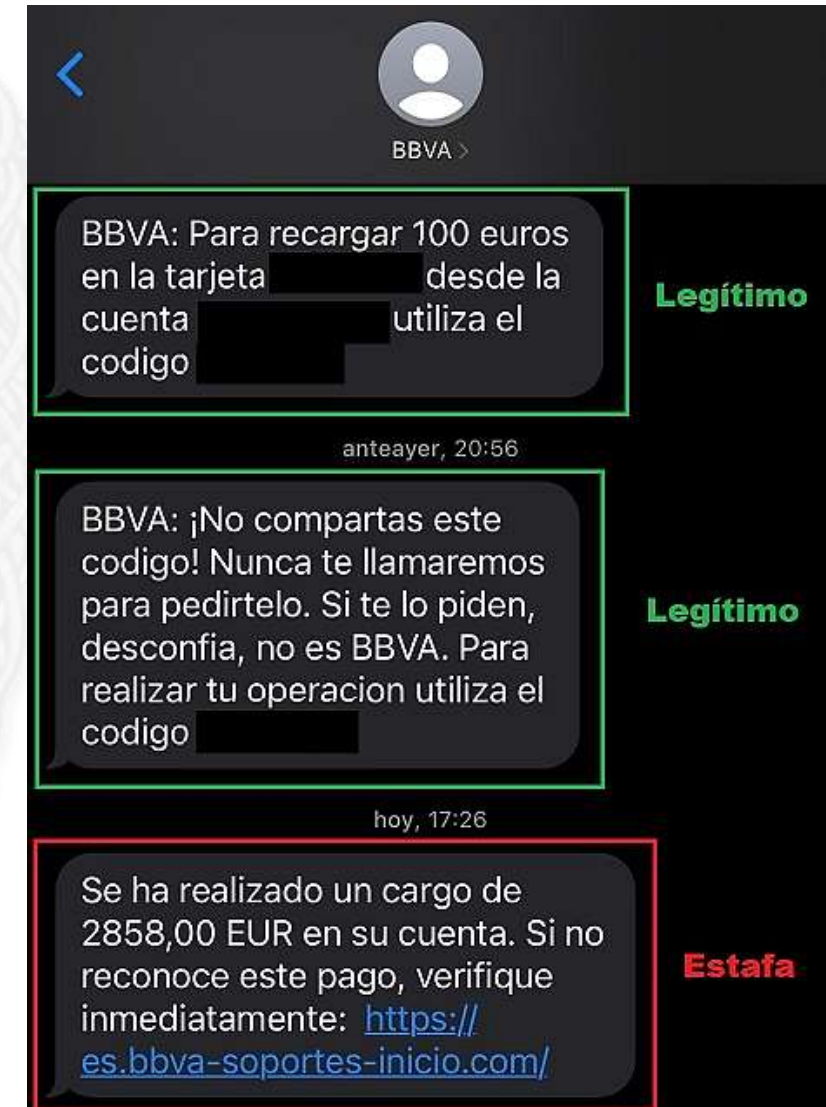
- Le des información personal (cuentas bancarias, etc..)
 - Instales un programa (virus, toma de control de tu PC...)
 - Que contrates un servicio que no cumpla lo prometido, sea engañoso o fraudulento (falsos contratos de telefonía/luz/gas...)
 - Cualquier otra cosa que le dé un beneficio (recuerda lo que hablamos)

¡Puede pasar con cualquier remitente!



SMS O LLAMADAS FALSIFICADAS: N° DE TELÉFONO DE ORIGEN

- Esto de que se mezclen mensajes reales y falsos en el mismo hilo de mensajes está causando estragos
- Recuerda lo siguiente: **El teléfono realmente no sabe quién te escribe o llama** 🤔
 - Él solo ve **un nombre o n° de remitente** cuando le llega
 - Y mete el mensaje en el “cajón” asociado a ese n° o nombre 📦
 - Pero, como decía, ese n° o nombre es **100% falsificable...**
 - Así que el teléfono no tiene la culpa
 - **Le han engañado**, como lo están intentando hacer contigo
- Por supuesto, hay servicios que trabajan detectando estas cosas 🚔
 - Si el teléfono te dice que un mensaje es spam, **créelo**
 - ¡Es muy muy raro que falle!



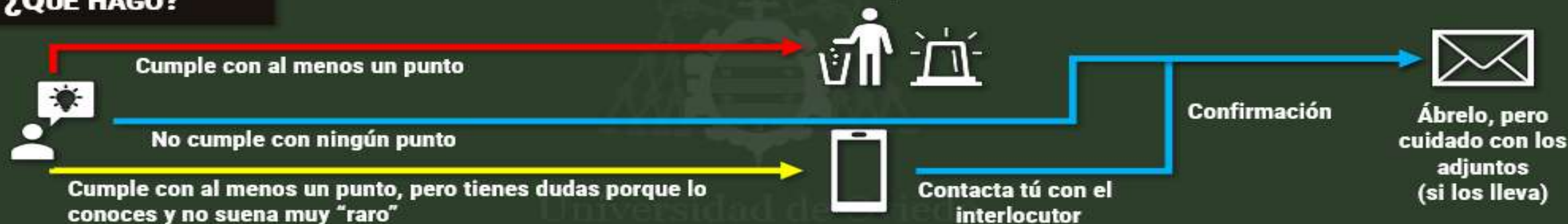
De verdad, esto es un señor problema...

RECONOCIMIENTO RÁPIDO DE MENSAJERÍA / SMS SOSPECHOSOS

¿El mensaje cumple con alguno de estos puntos? ¡Considera seriamente borrarlo!

¿QUÉ HAGO?

Bórralo y/o denuncia



De:

- ☐ Remitente **desconocido, no habitual** o no tengo **referencias** tuyas
- ☐ **No es de mi empresa** o no tiene que ver con ella
- ☐ **Le conozco** (empleado, proveedor, cliente...) pero me escribe algo **atípico o diferente a lo habitual**
- ☐ El **nº del que viene es conocido**, pero el contenido **me causa alarma e incluye un enlace**

A:

- ☐ Es de un **grupo de conocidos**, pero cuentan noticias u opiniones sin contrastar (**típica distribución de bulos**)



Enlaces

- ☐ **Enlace acortado** (**++fraude**)
- ☐ Apunta a webs parecidas a la real pero con **errores** (Ej.: rnrw.es, gogle.com...)

Adjuntos

- ☐ **No lo esperaba o sin relación** con el contenido
- ☐ **Nunca manda adjuntos** y ahora sí, sin explicación
- ☐ Es un **fichero comprimido, un fichero Office, un PDF** o similar
- ☐ **Doble extensión** (Ej.: .txt.exe) (**fraude seguro**)

Texto

- ☐ Me pide hacer clic en un enlace o abrir el adjunto, da **igual el motivo** (**++fraude**)
- ☐ Es atípico, **usa mal el idioma** (ortografía, tiempos verbales, vocabulario...), usa un **traductor automático** o usa un **saludo genérico**
- ☐ Me manipula con **culpa, chantaje, preocupación** (robo de cuentas, pago de multas...) o **amenazas veladas** (**++fraude**)
- ☐ Me pide una **acción urgente / inmediata**

MENSAJES FALSIFICADOS: DIRECCIÓN DE ORIGEN (EMAIL)

● El remitente de un email puede ser falsificado

- LO que ocurre si tu proveedor de correo no tiene bien configurados sus servidores
 - Lo mencionamos en el **S-74 "Tramontana"**, cuando hablamos de DKIM, SPF y DMARC
- Pero es algo que tú no tienes ni que entender ni tampoco puedes controlar
- Por tanto, **¡no te fíes de un remitente conocido si el contenido es extraño!**

Probabilidad de
engaño



Nivel	Tipo de dirección de origen falsificada
1	 Dirección aleatoria (números y letras sin sentido de proveedor público (Ej.: Gmail))
2	 Dirección con un nombre del remitente o empresa, pero de proveedor público
3	 Dirección que trata de imitar en su nombre a la dirección completa de una cuenta oficial, pero de proveedor público
4	 Dirección falsificada pero idéntica a la oficial por una mala configuración del sistema de correo que permite suplantar a los remitentes
5	 Dirección robada por un delincuente o empleado malicioso. Solo es posible identificar la estafa por las intenciones de lo que pida (datos privados, información bancaria...)

Trabajo de
elaboración del
delincuente

EJEMPLOS DE DIRECCIONES FALSIFICADAS (EMAIL)

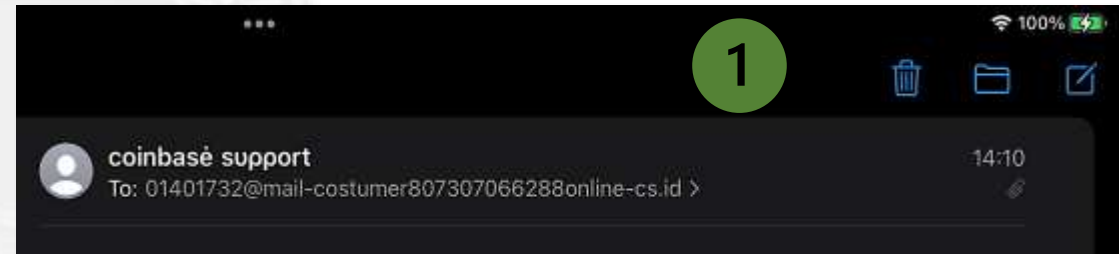


José Manuel
Redondo López

● Ejemplos de direcciones de email de **Nivel 1**

- Enormes direcciones con n°s y letras aleatorios
- **De proveedores públicos** (Gmail, Outlook...) **haciéndose pasar por empresas** u organismos
 - Sí, ya sé que no pocas empresas usan un correo personal en lugar del oficial
 - Pero en vista de cómo están las cosas, hay que tener mil ojos en estos casos
 - O no fiarte nunca de ellos
- Direcciones **con faltas de ortografía**
- Direcciones que no tienen **nada que ver** con quien manda el mensaje

● *¿Es esto común? Ya sabes la respuesta, ¿no? **Ya no***



¡Todos gritan “cutre” por los cuatro costados!



EJEMPLOS DE DIRECCIONES FALSIFICADAS (EMAIL)



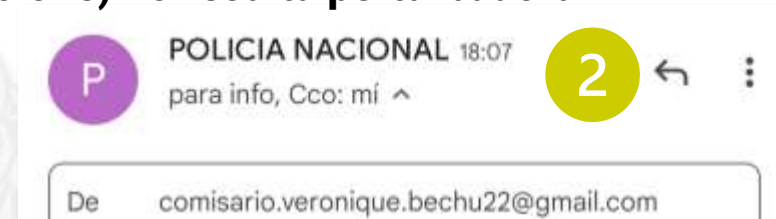
José Manuel
Redondo López

En este caso su falta de fe (en que el timo funcione) no resulta perturbadora

● Aquí varios ejemplos de **Nivel 2**

- Comisarios que te escriben desde Gmail
 - Los comisarios no te contactan así, y menos desde un proveedor público de email
- Empresas que te contactan
 - Pero el dominio del correo (lo que va tras la @) no es el de la empresa
- Direcciones que **imitan sitios conocidos** (youtub) pero de Gmail
- Sistemas de transferencias de archivos gratuitos (WeTransfer) para simular emails de otra persona
 - Incluyendo una dirección real en el asunto
 - Ejemplo:

https://twitter.com/ing_juani7a/status/1512413417960792064?t=nCxqQH0ZfkwJEaJtf5qg6w&s=19



EJEMPLOS DE DIRECCIONES FALSIFICADAS (EMAIL)

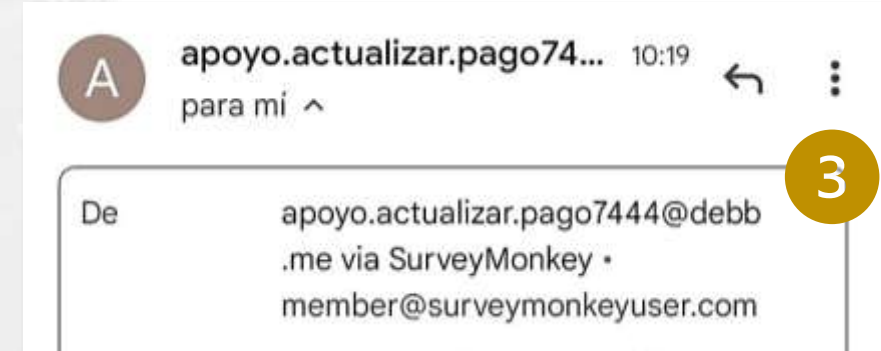
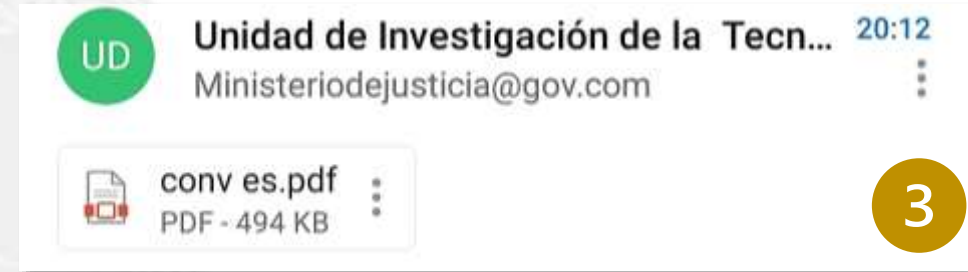


José Manuel
Redondo López

En general, hay más trabajo puesto en crear una dirección de email medianamente creíble...

● Aquí vemos ejemplos más avanzados de **Nivel 3**, con dos casos

1. En el nombre del remitente y/o parte de la dirección de correo **imita la dirección de correo real**
 - Pero el correo es falso (otro proveedor de correo)
2. La dirección de correo **se crea en función del objetivo** del email (pagos, cobros...)
 - Pero el dominio no es el real (el proveedor de email es **diferente al oficial**)
 - Se suelen usar proveedores poco conocidos por el público general para levantar menos sospechas
 - ¡Hay otros aparte de Gmail y Outlook! 😊



EJEMPLOS DE DIRECCIONES FALSIFICADAS (EMAIL)



José Manuel
Redondo López

- Aquí tenemos ejemplos de **Nivel 4**
- Es la suplantación de direcciones de correo reales
 - Es decir, **tu LEES la dirección que conoces**
 - Pero quien te escribe es un delincuente que la suplanta
 - La culpa es **de vuestro sistema de correo**, no vuestra
 - No verifica que la dirección de origen sea realmente quien dice ser
 - Si se hiciera bien, el correo se rechaza o acaba en spam
 - Los atacantes saben que vuestro sistema no está bien y pueden mandaros un correo en nombre de quien quieran
 - Además, buscan nombres de empleados (Ej.: LinkedIn)
- ¡Son **MUCHO** más frecuentes de lo que crees!

Algunos remitentes son 100% falsificables y no hay nada que puedas hacer.
Asume que todo correo puede ser falso, aunque venga de la dirección real

De: SERVICIO_AL_CLIENTE48350207@santander.es
Fecha: 12/4/22 2:07 (GMT+01:00)
Para: [\[Redacted\]](#)
Asunto: ☑ ! SERVICIO AL CLIENTE Santander Espana - tu cuenta necesita atencion. - (478695732431)

4

Notificación Dirección General de la Policía

4

 notificaciones@policia.es (notificaciones@policia.es)
Para: [Redacted]



Rosana Alfonso <r.alfonso@ibipal.com>
Para Rosana Alfonso

4



Rodríguez Gonzalez <rodriguezgonzalez@prolactea.com>
Para Raul Jesus

4



Factoring y Confirming - Grupo Santander <fykout@gruposantander.es>
Para undisclosed-recipients:

4



Deniz SEVINÇ <denizsevinc@marslogistics.com>
Para undisclosed-recipients:

4



Confirming.bbva@bbva.com
Para undisclosed-recipients:

4



Pablo Soler Lillo <psoleir@hinojosa.es>
Para Pablo Soler Lillo

4



MetaMask
support@metamask.io

Para TÚ

miércoles, 16 de febrero 08:30

4

MENSAJES FALSIFICADOS: USUARIO DE ORIGEN (RRSS)

- El usuario emisor (RRSS, app de mensajería, videojuego), etc. de un mensaje o información puede ser un delincuente
 - No aceptes nada de desconocidos
 - Y mucho ojo con los conocidos: podrían haberle robado la cuenta
 - ¡No te fíes nunca de un remitente (incluso conocido) si el contenido es extraño!

Probabilidad de engaño	Nivel	Tipo de dirección de origen falsificada
-	1	👤 Cuenta de nombre aleatorio sin verificar/desconocida, posiblemente recién creada y/o con pocos seguidores
	2	😬 Cuenta con un nombre de persona o proveedor "creíble" , pero sin verificar/desconocida, posiblemente recién creada y/o pocos seguidores
	3	😬 Cuenta sin verificar/desconocida con contenido clonado de una oficial , con bastantes seguidores (comprados o bots, A-71 "Juan Sebastián Elcano")
	4	😬 Cuenta verificada robada , a la que se le modifica el nombre y contenidos para ser un clon perfecto de una oficial, con muchos seguidores (los que tenía, comprados o bots, A-71 "Juan Sebastián Elcano")
+	5	👤 Cuenta oficial robada por un delincuente o empleado malicioso. Solo es posible identificar la estafa por las intenciones de lo que pida (datos privados, información bancaria...)

Trabajo de elaboración del delincuente

LA ESTAFA NO ENTIENDE DE MEDIOS

- Todo lo que hemos dicho para los emails tiene su equivalente con los nombres de cuentas de usuario
 - El típico consejo de “no hables con desconocidos” también funciona aquí 😊
- Ahora vemos a hablar de los contenidos de los mensajes
 - Esto también aplica **tanto a emails como mensajes** que recibas por MD en cualquier red social
- No cambia la estafa, solo el medio por el que se propaga
 - ¡Y los criminales no distinguen medios para llegar a sus víctimas!

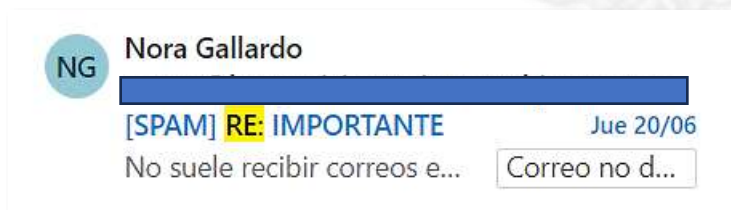


MENSAJES FALSIFICADOS: CONTENIDO DEL MENSAJE

- Cuerpos de mensajes y documentos falsos tienen los **mismos niveles**
- Con las siguientes particularidades
 - A veces se usa la **excusa de no ser nativo** para justificar que escriban fatal
 - **Saludos y formas de dirigirse genéricas** (Ej.: “Estimado usuario”), no ponen tu nombre
 - Pueden tener **adjuntos** (programas, documentos) y enlaces a páginas que, como vimos...
 - Al navegar por ellas descargan e instalan (o te invitan a hacerlo), cualquier tipo de **malware**
 - Te piden datos para robártelos
 - **Te invitan a instalar "extensiones" para tus RRSS** (que propagan el intento de estafa a tus contactos)
 - Es mucho más probable que **se juegue con el factor prisa** 🏃 🏃 🏃
 - **Haz algo ya** para que no pienses y hagas clic o instales lo que te pidan
 - **Cualquier cosa que te meta prisa es muy mal indicio...**
 - En cuanto a los enlaces recibidos...
 - Usan **acortadores de enlaces** ([t.com](#), [lnkd.in...](#)) para que no se sepa exactamente a donde van
 - **¡Nunca te fíes de nada que lleva un enlace acortado!**
 - Si no los usan, pueden recurrir a los trucos que veremos luego para falsificar la URL

EL TÍTULO DE UN MENSAJE Y EL “CLICKBAIT”

- Para que seas víctima de un mensaje fraudulento tienes que leerlo 📖
- Y para eso recurren a técnicas turbias como el clickbait
 - Crearte **alarma** (multas, denuncias...), **urgencia** (debes contestar rápido), **preocupación** (amenazas en el asunto de un mensaje)...
 - Hacerte creer que es una **oportunidad/oferta increíble**
 - Hacerte creer que es la **respuesta a un correo que has enviado tú** (incluyen “Re:” en el asunto)
 - Estudian lo que haces en tus RRSS y con esa información te mandan algo que creen que te interesará
 - Puedes ver qué más claramente en la **F-31 “Descubierta”**
 - Aunque eso para más cuando van a por ti expresamente por algún motivo (raro salvo que seas jefazo 😎)
 - ...
- Las noticias suelen recurrir también al clickbait para que las leas...
 - ¿En qué lugar deja esto a los periódicos? 🤔



Si tu cliente de correo añade **[SPAM]** al asunto del mensaje, ni te molestes en abrirlo. Si en lugar de eso es **[BULK]** tiene una probabilidad altísima de ser spam, así que pasando de él también 🤔

EL TÍTULO DE UN MENSAJE Y EL “CLICKBAIT”



José Manuel
Redondo López

Todos transmiten el mensaje: “¡Haz clic! ¡Ya! ¡Mira!”

● Vemos aquí varios ejemplos reales

- **Meter prisa** (asunto urgente o que caduca)
- Supuestos **premios**
- Supuesta **confirmación de asuntos** importantes (transferencias)
- Simular **comenzar un negocio** (que la empresa oferte algo)
- **Fingir ser la respuesta** a un mail anterior (en realidad solo añaden “Re:” al título)

Re: [Alert] [Dear Customer]: We lock your amazon account and hold all your last orders on Monday, April 4, 2022 (EST)

You Could Win! See Inside to Get your Apple Reward

Pago de factura pendiente

Notificación de Transferencia realizada

SOLICITUD DE OFERTA

RE: presupuesto urgente

Re: Orden de compra de enero (P.O_343209) ¡Un recordatorio!

¡Rápido, rápido, rápido! De momento se ofrecen 30€ con Amazon Business

RECONOCIMIENTO RÁPIDO DE CORREOS SOSPECHOSOS

¡Cuantas más casillas puedas marcar, el mensaje será menos de fiar!

De:

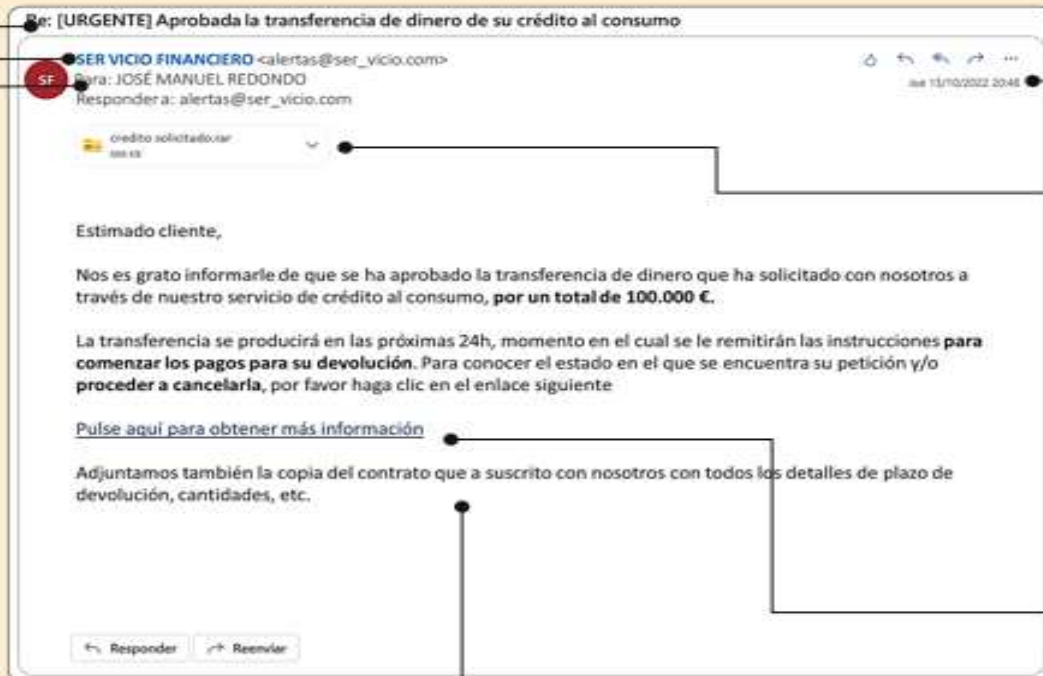
- ☐ Remitente **desconocido, no habitual** o no tengo **referencias** tuyas
- ☐ **No es de mi empresa** o no tiene que ver con ella
- ☐ **Le conozco** (empleado, proveedor, cliente...) **pero me escribe algo atípico o diferente a lo habitual**
- ☐ **El dominio del remitente es "raro"** (muy largo, con guiones, con letras y n°s sin sentido...) y es el oficial (Ej.: mrw-clientes.com, unicaja-banco.uk...)

A:

- ☐ Estoy en copia (CC) con más personas, **pero no sé quienes son**
- ☐ Estoy en copia (CC) con gente de mi trabajo, pero **no veo relación** entre ellos o hay un **patrón** (Ej.: orden alfabético de apellido)

Asunto

- ☐ **No tiene sentido** o no encaja con el **contenido** del mensaje
- ☐ Pone **Re:**, pero **nunca le he mandado un mensaje**
- ☐ Me habla de algo **urgente**



Texto

- ☐ Me pide hacer clic en un enlace o abrir el adjunto **para ganar algo**, porque tiene **información comprometedor** u otros **motivos extraños** (++)fraude)
- ☐ Es atípico, **mal uso del idioma** (ortografía, tiempos verbales, vocabulario...), usa un **traductor automático** o tiene un **saludo genérico** (Ej.: "Estimado usuario")
- ☐ Intenta manipularme con **culpa, chantaje, preocupación** (robo de cuentas, pago de multas...) o **amenazas veladas** (++)fraude)
- ☐ Me pide **una acción urgente / inmediata**

Fecha

- ☐ Es de mi trabajo, pero **fuera de horas**

Adjuntos

- ☐ **No lo esperaba** o **sin relación** con el contenido
- ☐ **Nunca me manda adjuntos** y ahora sí, sin dar explicación
- ☐ Es un **fichero comprimido, un fichero Office, un PDF** o similar
- ☐ **Doble extensión** (Ej.: .txt.exe) (**fraude seguro**)

Enlaces

- ☐ Si paso el ratón por encima **SIN HACER CLIC**, la dirección en la barra inferior del navegador es otra (++)fraude)
- ☐ Es un **enlace acortado**
- ☐ Apunta a webs parecidas a la real pero **con errores** (Ej.: nrw.es, gogle.com...)

Basado en:

<https://www.knowbe4.com/hubfs/Social-Engineering-Red-Flags.pdf>

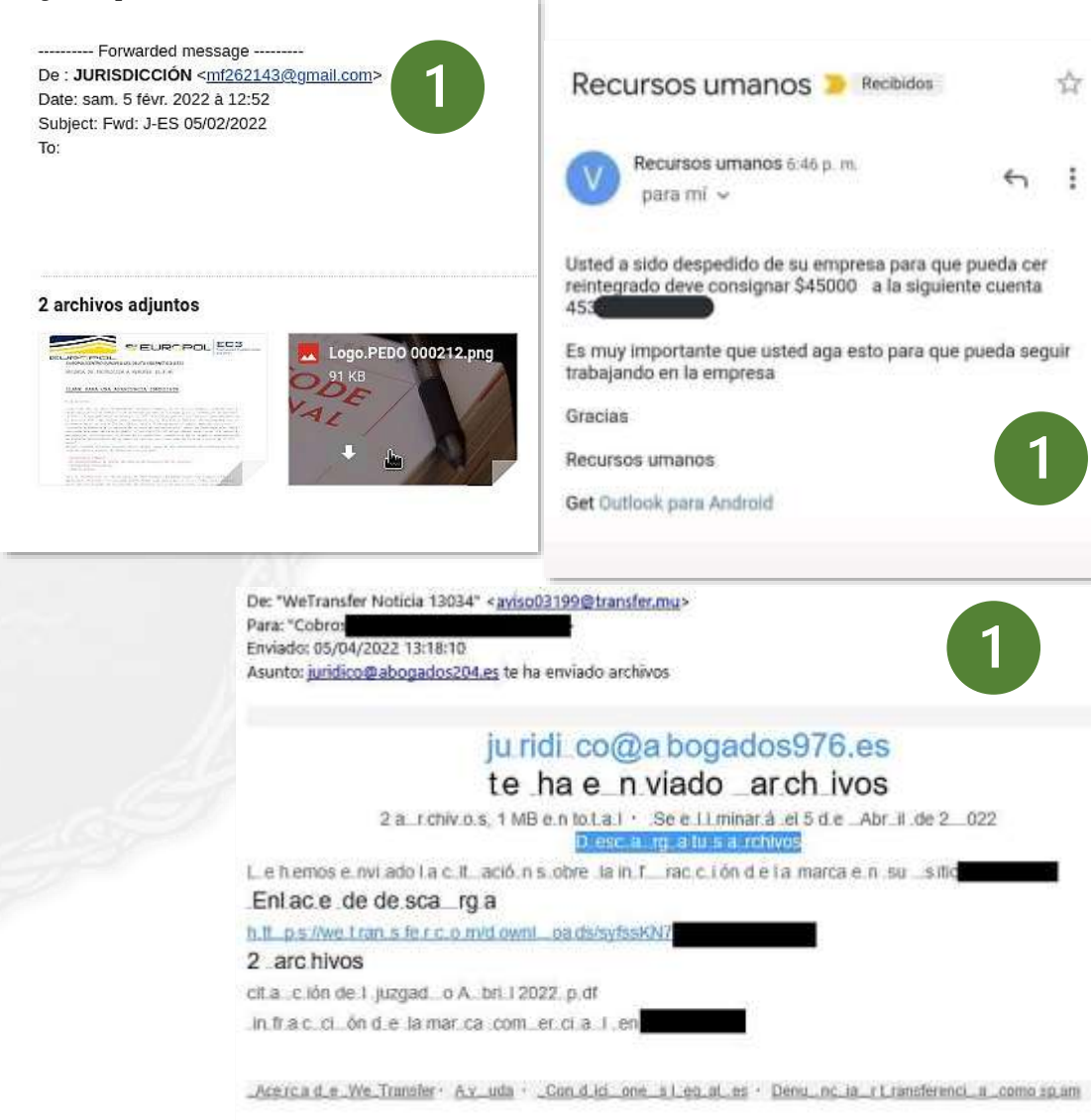
EJEMPLOS REALES DE MENSAJES FALSOS



José Manuel
Redondo López

- Estos mensajes de **Nivel 1** son los que la gente cree más comunes
 - No hay elementos gráficos, texto mal redactado, etc.
 - **Pero recuerda: ¡Ya no son comunes! ¡Los delincuentes están evolucionando!**
- Algunos meten una cantidad enorme de caracteres en blanco o puntos
 - Para saltarse filtros de contenido
 - Todo email que venga así es falso, no hay mucho que discutir 😊
- En general, tienen un aspecto nada profesional y son fácilmente identificables

Ejemplos de correos falsos de calidad terrible



EJEMPLOS REALES DE MENSAJES FALSOS



José Manuel
Redondo López

- Estos mensajes de **Nivel 2** ya usan una redacción más cuidada
- Siguen sin usar elementos gráficos
- Suelen tener muchas menos faltas de ortografía

Al menos con estos tienes que fijarte para saber que son falsos

Rv: investigación

Unidad de Investigación de la Tecn... 20:12
Ministeriodejusticia@gov.com

conv.es.pdf
PDF - 494 KB

Reporte de investigación

Nuestros servidores nos han permitido identificar y geolocalizar en tiempo real sus direcciones IP utilizadas para ver contenido de pornografía infantil. se le solicita que responda lo antes posible.

Para más información ver el documento

El paquete {009232513} fue detenido en el centro de distribución. Siga su envío aquí: <https://www.bswck.edu.in/c/70-qg9c8o>

24 oct. 10:56

Mensaje de texto

acusación contra ti

POLICIA NACIONAL 18:07
para info, Cco: mi

De: comisario.veronique.bechu22@gmail.com
POLICIA NACIONAL y +

Para: info@europol.eu

Cco: [redacted]

Fecha: 27 abr. 2022 18:07

Mostrar texto citado

ORGANIZA...INAL 24.pdf

EJEMPLOS REALES DE MENSAJES FALSOS



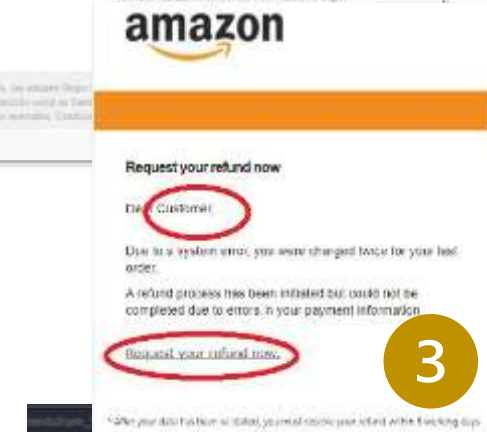
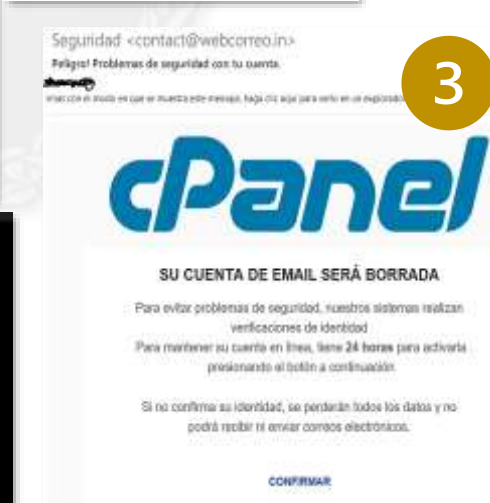
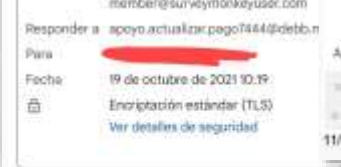
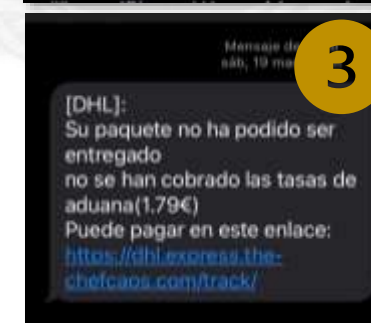
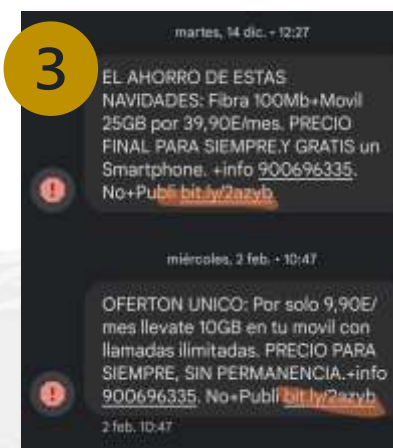
José Manuel Redondo López

En el **Nivel 3** aparecen cosas que hacen los mensajes más creíbles

0 imitación de mensajes reales

- Iconos de webs oficiales
- Aspecto gráfico más cuidado, imitando al original
- Enlaces acortados
 - Para que no se vea claramente a dónde se va con un clic
- Falsos iconos para adjuntos
 - Ej.: Son programas con “bicho” pero les ponen el icono de una imagen

Iconos, colores, tipos de letra...son imitaciones, algunas bastante buenas

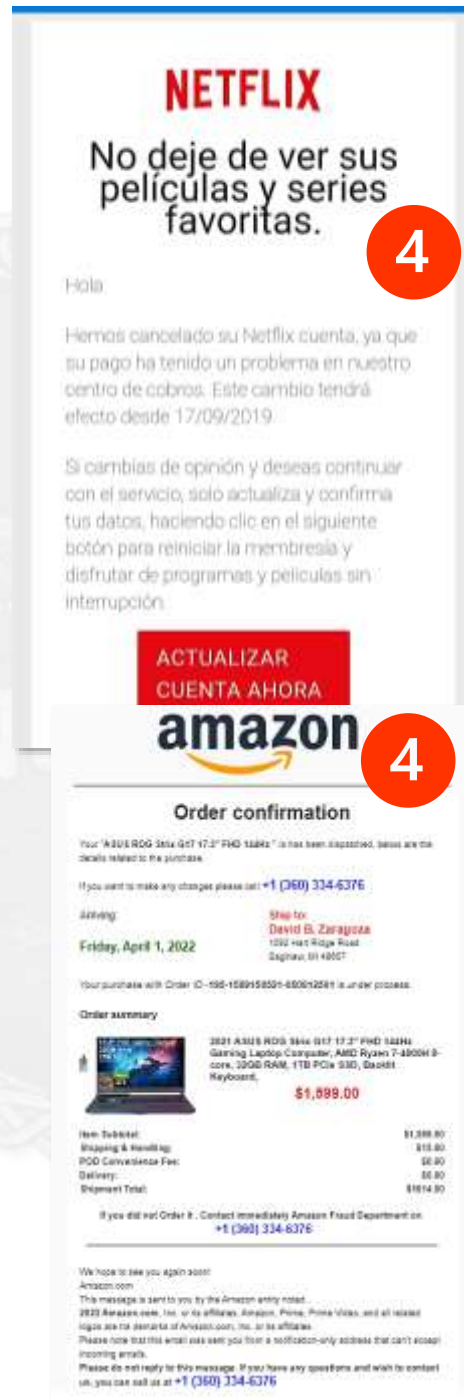


EJEMPLOS REALES DE MENSAJES FALSOS



José Manuel
Redondo López

- El **Nivel 4** es ya una amenaza mucho más seria
 - Y hoy en día muy común
- Son clones 🐶 de mensajes reales
 - Con direcciones de webs para hacer clic muy bien falsificadas
 - Uso de datos reales de la víctima para aumentar su credibilidad
 - Procedentes de **filtraciones**
 - Con tanto robo de datos que se hace a todas partes, es un problema serio 😞
 - O de **ingeniería social**
 - Que le engañan para sonsacarles cosas, vamos 🕵️



A partir de un mensaje real, lo clonan y lo alteran

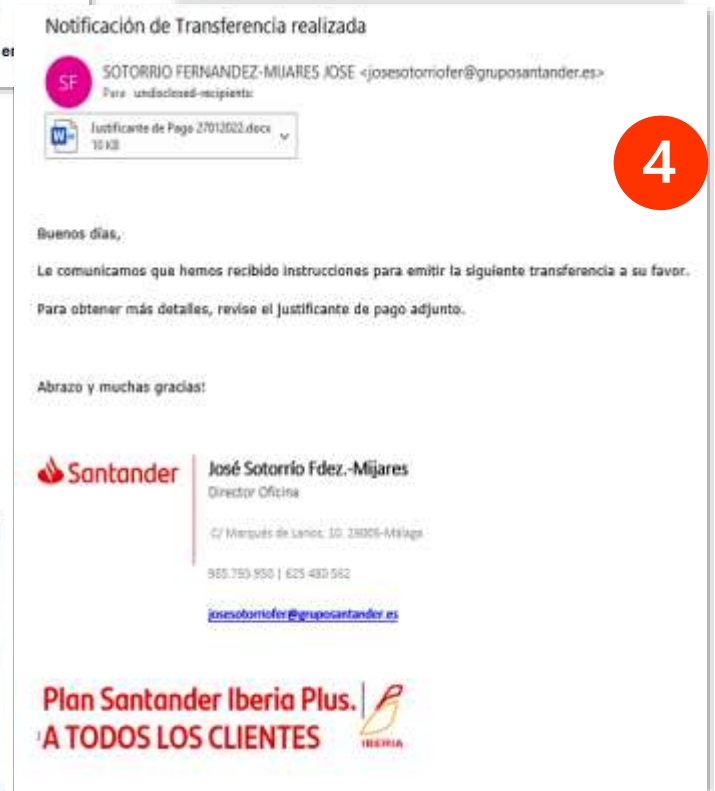
EJEMPLOS REALES DE MENSAJES FALSOS



José Manuel
Redondo López

- La redacción y aspecto de algunos mensajes puede ser brutal
 - No presentan faltas de ortografía
 - Lógico si los hacen básicamente clonando comunicaciones reales 😊
 - Los alteran sutilmente para añadir enlaces/adjuntos maliciosos...
 - O también mediante el uso de IA
- Copian elementos gráficos de los mensajes originales, etc.
 - Hay trabajo detrás de su elaboración, y por tanto **mayor % de éxito**
 - ¡Si se lo curran es porque les compensa!

Fijaros en el curro que tienen algunos...aunque muchas veces el curro real lo hizo el original, que se clona



¿CREES QUE LO HAS ENTENDIDO TODO? ¡AUTOEVALÚATE!

● Asegúrate de haber entendido lo siguiente

- Respecto a **teléfonos y mensajes en general** (por cualquier medio)...
 - *Que el nº de teléfono/email que te llama o escribe se puede falsificar*
 - *Cómo esto puede hacer aparecer mensajes SMS falsos en la misma lista de mensajes que otros que son verdaderos*
 - *Que, en general, cualquier SMS que lleva un enlace es no fiable*
 - *Que tienes que mirar con lupa al remitente de un correo electrónico para detectar si es una estafa*
 - *Que nadie “oficial” te va a mandar un email con una cuenta de un proveedor público (es decir, que se puede hacer una cuenta todo el mundo), como Gmail u Outlook*
 - *Que, incluso aunque la cuenta que te envía el mensaje sea la real, se podría falsificar si el sistema de correo del remitente no está bien configurado, y que eso es algo que tú no puedes controlar*
 - *Que lo más sensato es tratar cualquier mensaje de correo como falso por defecto, venga de quien venga, diga lo que diga, y este lo “currado” que esté*





Webs falsas

Cuando nos redirigen a webs que son imitaciones (o clones exactos) de las reales



WEBS FALSIFICADAS: URL DE LA WEB

- **En general debes tratarlas igual que las direcciones de origen de los mensajes**
 - Pero sabiendo leer una URL (lo vemos a continuación), que es un poquito más difícil que un email
 - Si recibes un enlace cuya dirección visible no es la real (la que se ve cuando pones, **sin hacer clic**, el ratón encima) **es un fraude seguro**

Probabilidad de engaño	Nivel	Tipo de URL falsificada
-	1	💩 URL aleatoria (colección de números y letras sin sentido) de un proveedor de cloud o hosting contractable por un particular cualquiera (Ej.: godaddy)
	2	😬 URL que imita el nombre de la empresa (Ej.: paipal.com), o que se aprovecha de errores típicos a la hora de escribir (gogle.com)
	3	😬 URL que trata de imitar la de una web oficial o una parte “sensible” de la misma, con un dominio distinto (Ej.: paypal-inspection.com, microsoft.miweb.com) o enlace acortado
	4	😬 URL falsificada para que parezca idéntica a la oficial con trucos con caracteres, uso creativo de Unicode, etc... muy difícil (o imposible) de distinguir a simple vista
+ Trabajo de elaboración del delincuente	5	😬 Dominio oficial robado / expirado (y comprado por un delincuente o empleado malicioso que restaura una copia de una página) o comprometido. Sólo es posible identificarlo/prevenirlo por herramientas de seguridad y/o sentido común

TÉCNICAS PARA SABER CUÁNDO UNA URL ES FALSA

- Hay varias formas de que te la cuelen con una URL (dirección de una web)
 - **Jugar con caracteres “extraños” de otros idiomas** 🇯🇵 : Existen letras en ciertos idiomas (Ej.: el cirílico) que son visualmente iguales a alguna de nuestro alfabeto
 - Pero, aunque sean iguales visualmente, **son letras distintas**: corresponden a códigos **Unicode** diferentes
 - *¿No sabes que es Unicode? No pasa nada: Asume que es un código único que se le da a cada carácter existente*
 - Ej.: www.apple.com puede ser la ‘a’ “normal” o un carácter “a” que hay en el alfabeto cirílico
 - Debería aparecerte como <https://www.xn--80ak6aa92e.com/> en la barra de direcciones...
 - Pero a veces los delincuentes encuentran caracteres que no se convierten correctamente a Unicode
 - *¿Cómo evitarlo? Actualiza el navegador: Es fallo suyo (y se aprovechan de él 🙄)*
 - **Usar enlaces acortados** 🍌 : suponen mucho riesgo, **asume que todo son falsos**
 - Ejs.: t.co/..., bit.ly/..., goo.gl/...
 - Hay formas de saber hasta dónde llevan sin riesgo (expandirlas), pero **es mejor ignorarlos**

TÉCNICAS PARA SABER CUÁNDO UNA URL ES FALSA

- **Direcciones que imitan a otras reales** 👁️ : Solo te queda **aprender a leerlas** y, para ello...
 - **Entiende la estructura de una URL** (mira la imagen, siempre es la misma)
 - Quítale el **http://** o el **https://** del principio (el protocolo)
 - Luego, **quítale todo lo que haya a la derecha del TLD** (sin incluirlo)
 - No nos interesa para lo que vamos a hacer aquí
 - Te deberías quedar por tanto con estas partes, todas separados por '.'
 - **Su TLD**: Indica país, tipo de web o más cosas
 - **El dominio**: Que es el elemento realmente importante para saber de quién es la web
 - **Subdominio(s)**: Puede haber más de uno, separados por '.'

https://tienda.dominio.es/subcarpeta/ficha-de-producto#etiqueta



Fuente:

<https://www.sidn.es/blog/estructura-url-seo/>

TÉCNICA PARA SABER CUÁNDO UNA URL ES FALSA: EJEMPLO PRÁCTICO

<https://descargas.microsoft.es/es-es/login.aspx>

Quítaselo

Primer '/',
el importante 😊

No importa para lo
que vamos a hacer aquí

- subdominio(s) + dominio + TLD deben leerse **siempre de derecha a izquierda** (del TLD hacia atrás)
 - descargas.microsoft.es: sitio español (TLD, **es**) llamado **microsoft** (**dominio**, y además el oficial), y estamos en su sección (**subdominio**) **descargas**
 - descargas-microsoft.es: sitio español (TLD, **es**) llamado (**dominio**) **descargas-microsoft**
 - ¿Es el oficial? **NO** (¡ese sería microsoft.es!), ¿Se ha hecho a propósito para confundir y es un fraude? **SÍ**
 - El truco es **usar el '-' como si fuese un separador** (y siempre es '.', ¡no piques!)
 - Es un fraude así que: 🗑️
 - microsoft.dm123453.com: Es un sitio comercial (TLD, **com**) llamado (**dominio**) **dm123453**
 - Y que "casualmente" tiene una sección (**subdominio**) llamada "**microsoft**"
 - Quién es el dueño de una dirección **lo marca el dominio+TLD**, nunca un subdominio (¡es otra trampa!)
 - **Pretenden que lo leas deprisa y creas que es el sitio oficial (dominio) de Microsoft**

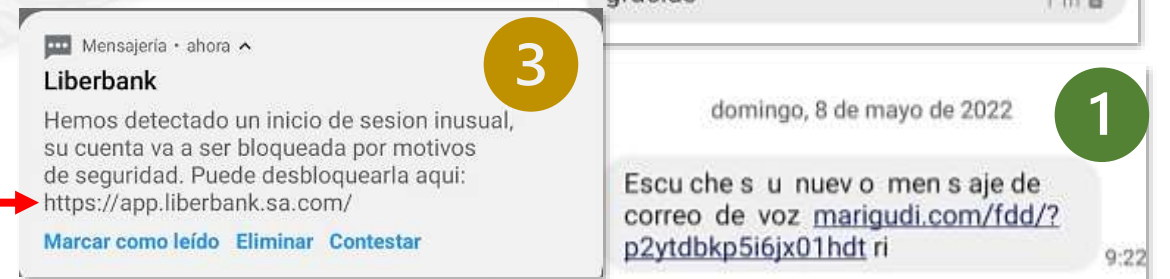
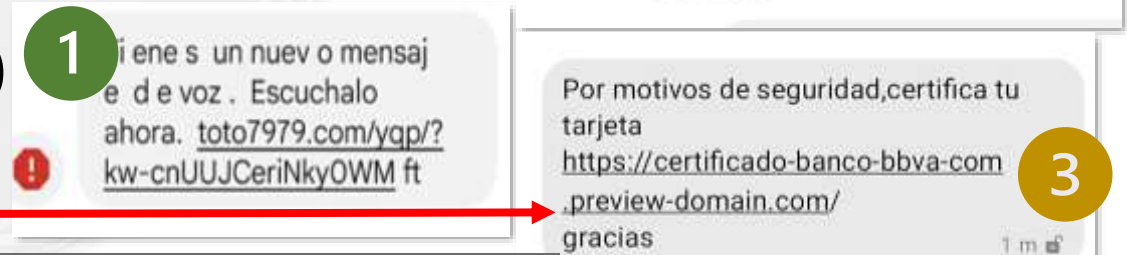
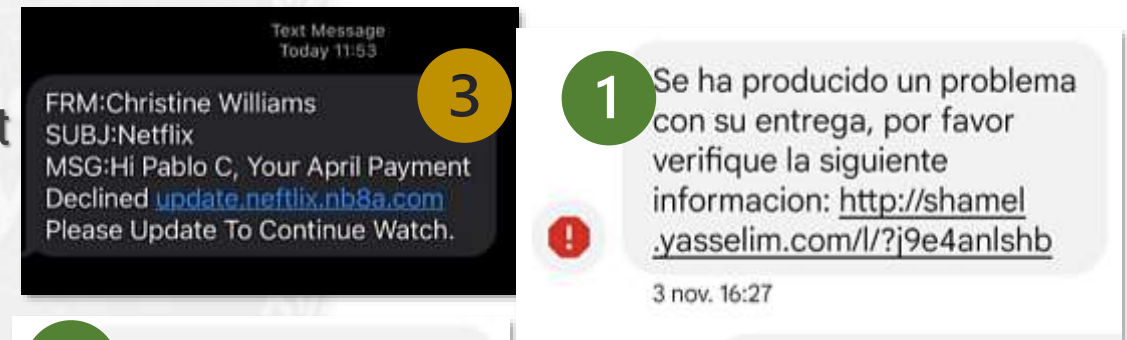
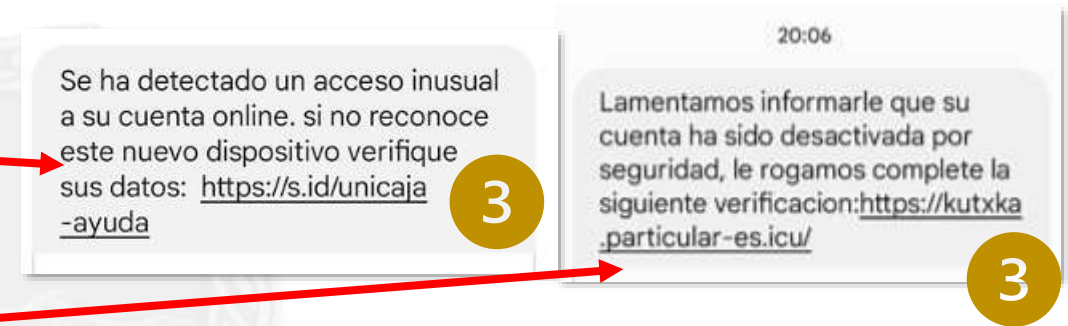
EJEMPLOS REALES DE URLS FALSAS



José Manuel
Redondo López

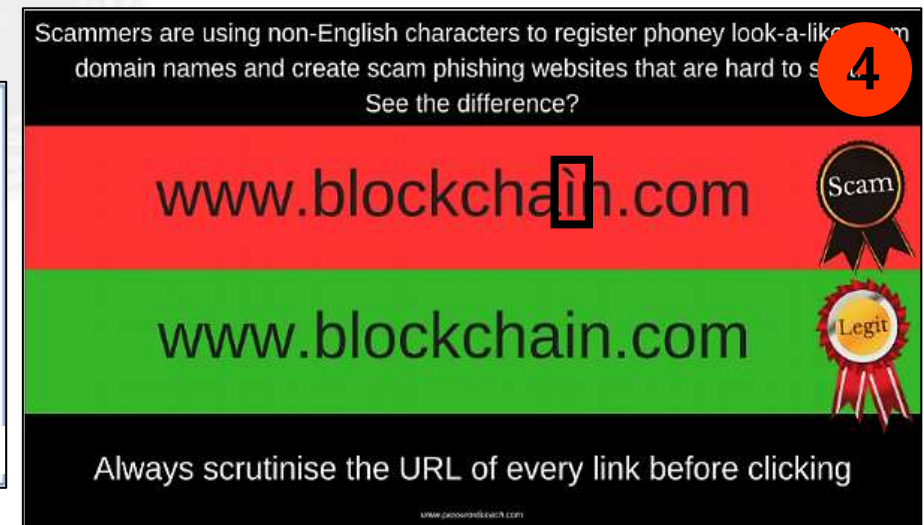
• Trucos para engañarte si lees deprisa

- Usar **dominio + TLD muy corto** (Ej.: [s.id](#))
 - Y luego usar la subcarpeta y el resto para simular que es un sitio real
- Usar **TLDs “raros” o minoritarios** con nombres de dominio conocidos (Ej.: [microsoft.icu](#))
 - El dueño de [microsoft.icu](#) puede **no** ser Microsoft
 - Un delincuente ve una combinación dominio + TLD “abandonada” y la compra para engañar
 - Mientras nadie denuncie la suplantación... 👤 💰
- Meter como una parte del nombre del sitio (**dominio**) algo que simule el sitio real
- Ej.: [certificado-banco-bbva-com.com](#)
- Usar **subdominios de nombre realista**, pero en un dominio falso (y corto). Ejs.:
 - [update.netflix.nb8a.com](#)
 - [app.liberbank.sa.com](#)



EJEMPLOS REALES DE URLs FALSAS

- Muchos engaños se basan en que tendemos a “leer deprisa” 
 - Lees “Microsoft”, “Amazon”, etc. y haces clic por instinto...pero te la han colado 
- Hay más formas de crear URLs a propósito para que piques
 - Tu cerebro “autocompleta” y no te das cuenta del engaño si vas con prisas 😞
 - O no tienes la formación para saber que es una estafa (por no saber leerlas...pero ahora sí sabes )
- La “mente del crimen” es muy prolífica y te encontrarás con más
 - ¡Aprende a no ser engañado! (desarrolla tu “sentido arácnido!”)



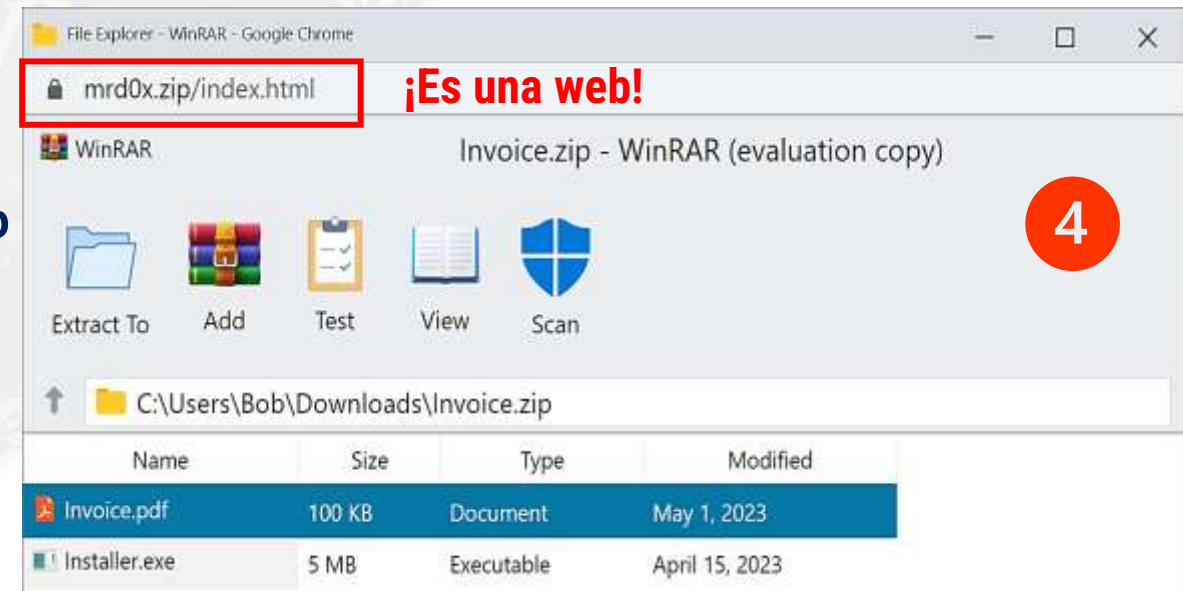
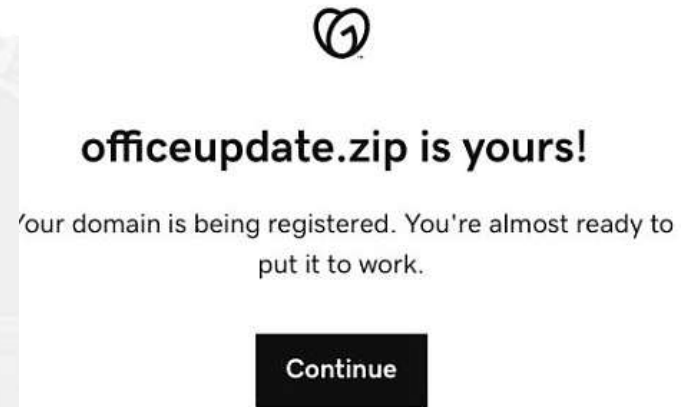
EL ÚLTIMO GRITO EN DIRECCIONES FALSIFICADAS

● Hace poco Google decidió legalizar nuevos TLD válidos para direcciones

- Añadió a **.com**, **.es**, etc. posibles “terminaciones” nuevas válidas en todo el mundo...
- Entre ellos **.zip** (como los ficheros comprimidos)
 - Además de otras combinaciones que idénticas a **tipos de archivos**

● La consecuencia es la de imagen

- Un delincuente registra una web acabada en **.zip**
- Al entrar ves una web que es una imitación perfecta del popular compresor WinRAR
- Con un correo falsificado adecuado, la víctima creerá que se está bajando e instalando un programa legítimo



¿POR QUÉ ES IMPORTANTE IDENTIFICAR LA DIRECCIÓN?



José Manuel
Redondo López

- Detectar que una dirección es falsa es muy importante
 - Hoy en día, las falsificaciones de webs **son indistinguibles** de la real
 - Da igual que sea para PC o para móvil
 - En la imagen ves **un clon exacto de la página** para móviles de ING
 - Fue la página donde mucha gente fue víctima de una estafa recientemente
 - Por tanto, como no evites entrar detectando que es una URL falsa...
- Veamos qué pasa con las falsificaciones del contenido de las webs

The image shows a side-by-side comparison of two mobile login screens for ING. The left screen is the real one, with the URL 'ing.ingdirect.es/app-login/' in the browser bar. The right screen is a fake clone, with the URL 'es.ing-app.net' in the browser bar. Both screens have the ING logo at the top. The left screen has a green 'REAL' label, and the right screen has a red 'FALSA' label. A red circle with the number '4' is placed on the right screen. The login forms are identical, with fields for 'Elige tu documento' (DNI or Tarjeta de residencia selected on the real page, Pasaporte selected on the fake), 'Número de documento', 'Fecha de nacimiento' (DD, MM, AAAA), and a 'Recordar' checkbox. Both screens have an orange 'Entrar' button and a link for 'Más información sobre seguridad'.

REAL	FALSA
ing.ingdirect.es/app-login/	es.ing-app.net
ING	ING
REAL	FALSA
Accede a tu Área Clientes	Accede a tu Área Clientes
Elige tu documento	Elige tu documento
☒ DNI o Tarjeta de residencia	☐ DNI o Tarjeta de residencia
☐ Pasaporte	☒ Pasaporte
Número de documento	Número de documento
DNI o Tarjeta de residencia	Pasaporte
Fecha de nacimiento	Fecha de nacimiento
DD MM AAAA	DD MM AAAA
☐ Recordar	☐ Recordar
Entrar	Entrar
Más información sobre seguridad	Más información sobre seguridad

WEBS FALSIFICADAS: CONTENIDO LA WEB

- El contenido de una web falsa hoy en día es normalmente **MUY** convincente
 - Los niveles 1 y 2 ya no se ven nunca prácticamente.. 🦖.

Probabilidad de
engaño



Trabajo de
elaboración del
delincuente

Nivel	Tipo de contenido web falsificado
1	🤖 Web creada de forma negligente , sin formato profesional y/o evidentes defectos en el uso del idioma, o con claros indicios de estar “reutilizada” de otras estafas u otros fines
2	😬 Web que usa logos e iconos oficiales , pero aspecto no profesional y pequeños errores en el uso del idioma
3	😬 Clon de una web real , pero solo su front-end (su aspecto). La funcionalidad está muy limitada o redirige a la real cuando se usa (pero previamente te habrá robado tus claves o información personal)
4	😬 La anterior con funcionalidad completa programada: muestra supuestas cuentas, saldos, usuarios, pedidos...lo que le haga falta a la estafa concreta de forma muy convincente (obviamente todo falso, pero es una falsificación con mucho trabajo detrás)
5	😬 Página real de la empresa/organización modificada con elementos de una estafa concreta por un empleado malicioso, un delincuente que ha robado la cuenta de un empleado real (data leak), o por una vulnerabilidad de la web (o sus infraestructuras). La modificación se hará para robo de datos / instalación de malware. Solo es posible identificarla por software de seguridad / sentido común

SOBRE LAS WEBS FALSIFICADAS...



José Manuel
Redondo López

- Copiar el aspecto de una web cualquiera es **trivial**

- Hay herramientas para eso que lo hacen en un clic
- Por tanto, su aspecto **NO IMPORTA** a la hora de saber si es falsa
 - **Lo típico es ver copias exactas en aspecto (niveles 3 y 4)**
 - Solo cambia si detrás tienen una funcionalidad más o menos compleja

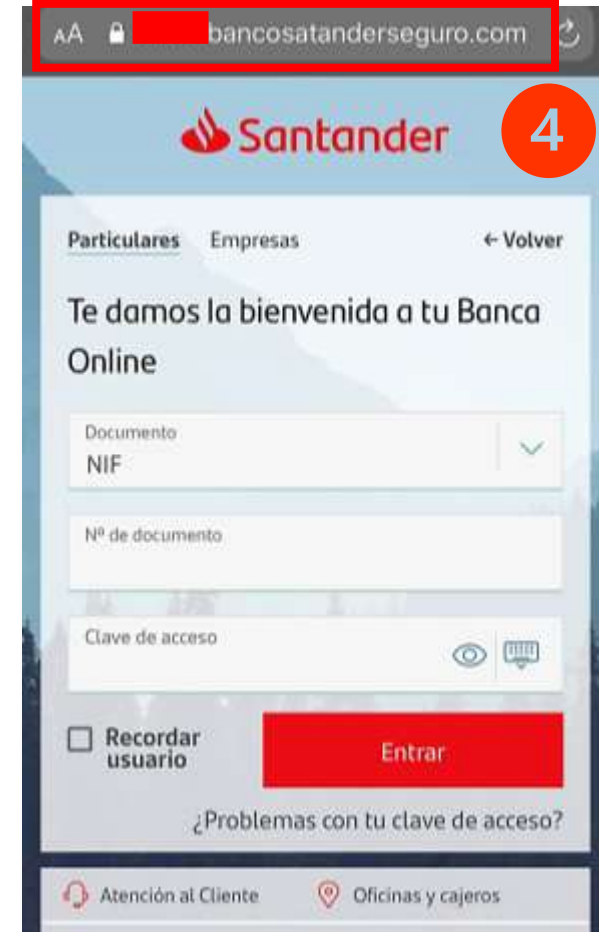
- Por eso es importante distinguirlas por su dirección

- Pero *¿miras las direcciones de todas las webs que visitas?* 🚶
- *¿Y si usan URLs acortadas?* (¡por eso te dije que no te fíes de ellas!)

- Las webs fraudulentas más típicas son

- Formularios en los que pretenden recoger **datos personales**
- **Webs de descarga** de malware (robo de datos, espionaje...)
- **Páginas legítimas con vulnerabilidades:** con un enlace a ellas preparado para sacar partido de una vulnerabilidad y robarnos
 - ¡Aun siendo la página real!

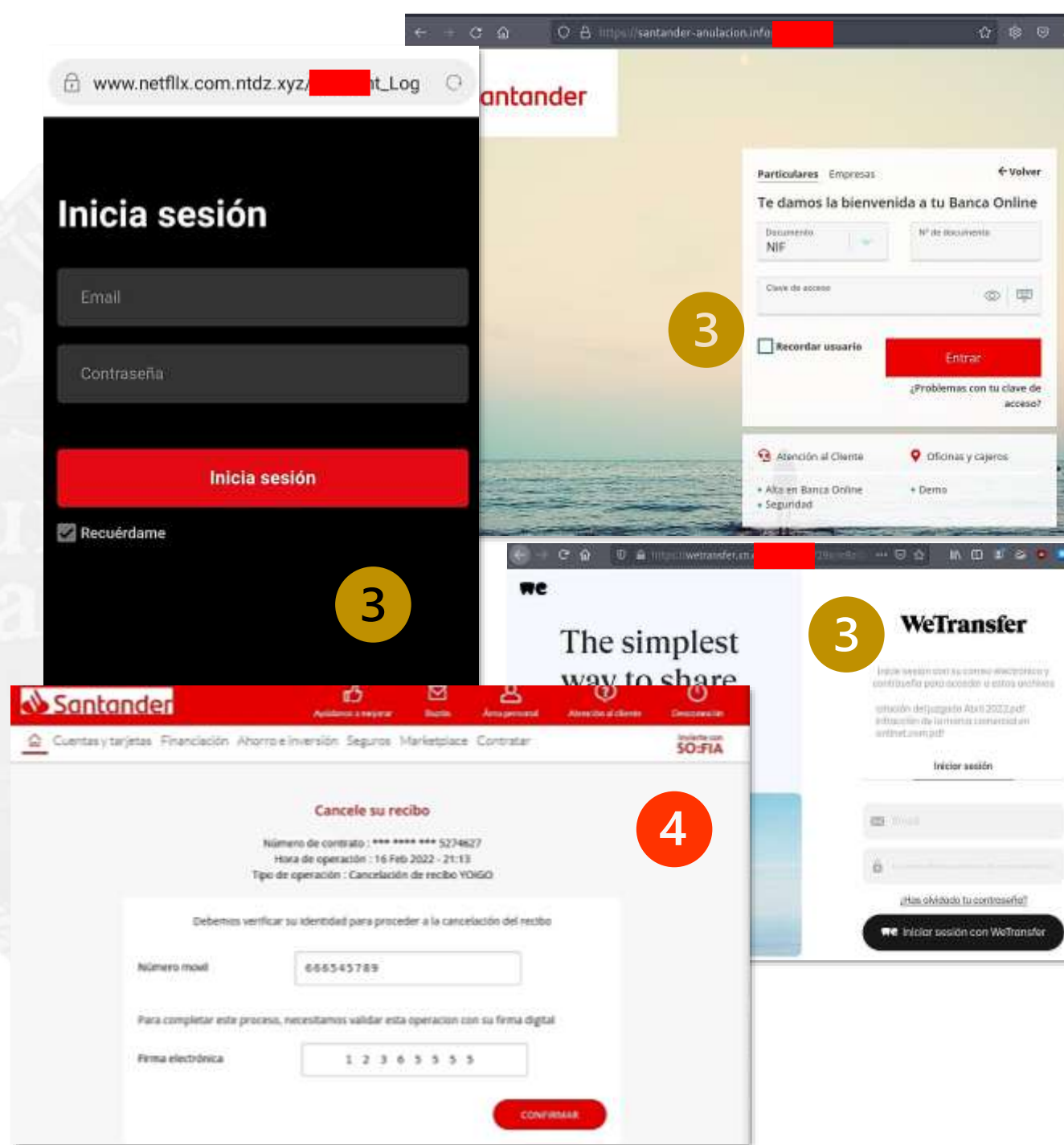
¡Se puede falsificar con un aspecto perfecto CUALQUIER página!



SOBRE LAS WEBS FALSIFICADAS...

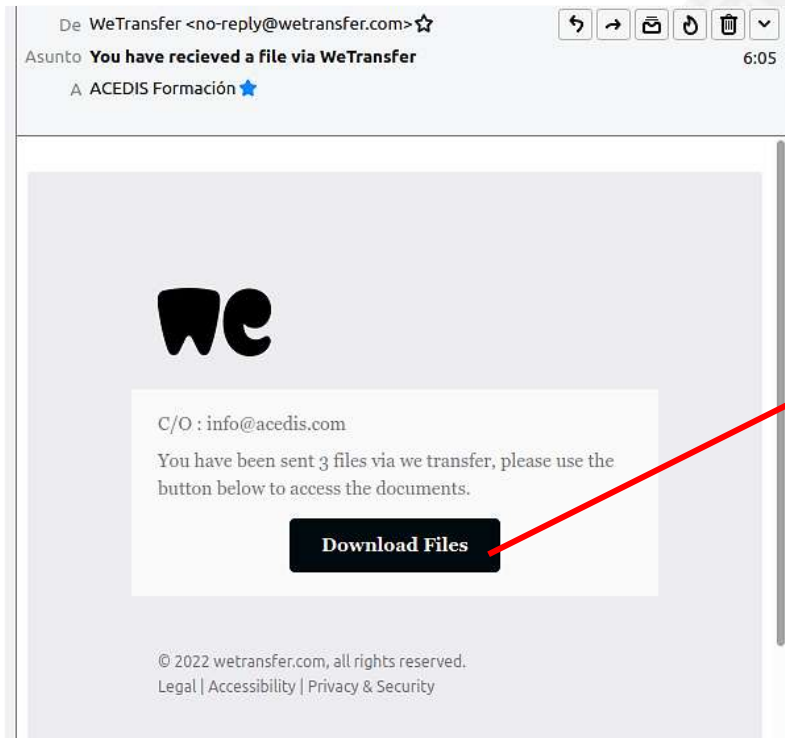


- Las de **Nivel 4** tienen programada funcionalidad
 - ¡Incluso simulando 100% a la real! 🤖
- Hay incluso copias integrales alteradas de webs reales
 - El código original fue robado...
- El objetivo es robarte tus datos
 - La funcionalidad programada hace lo que los atacantes quieren
 - La copia de la web es suya, aunque a ti te parezca que estás en la real 🤖

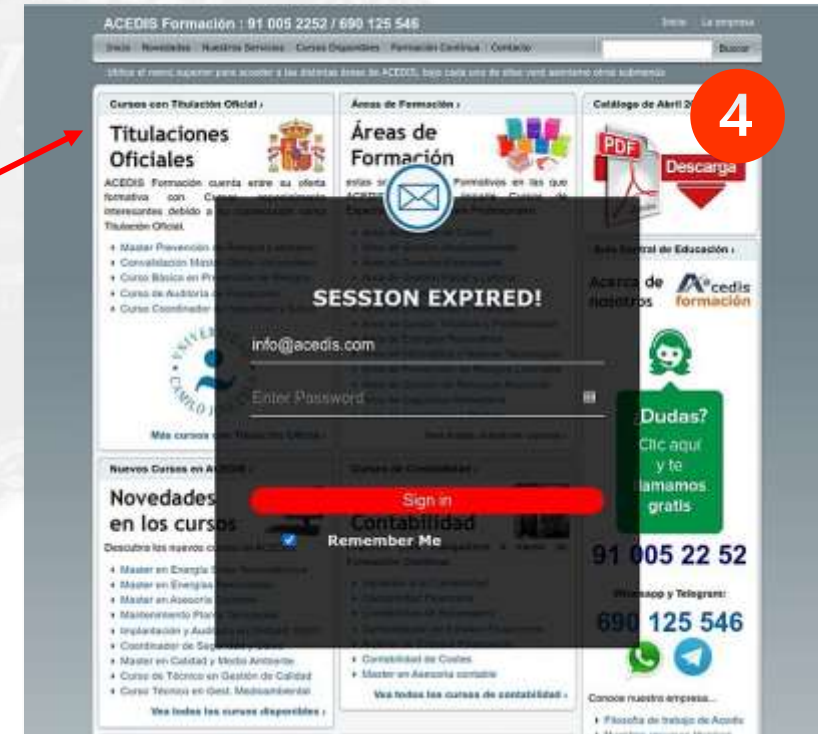


SOBRE LAS WEBS FALSIFICADAS...

- Algunas falsificaciones tienen mucho trabajo detrás 🤖 🤖 🤖 🤖
- Como esta, que **simula ser cualquier web que los atacantes quieran**
- Se piden usuario y contraseña con un formulario (falso) **encima de una imagen de la web verdadera**
- Si el usuario no se da cuenta y las introduce, le habrán robado la clave sin saberlo
- <https://twitter.com/MarcosBL/status/1512366113346265092?t=8wzaLe7IJVCaG7ON5Ve4sg&s=19>



Se recibe un correo para descargar un fichero en una web muy conocida para estas cosas
El enlace no va a esa web, sino a una falsa



La web falsa pone de fondo la del destinatario del correo y muestra un falso formulario de volver a iniciar sesión



Identidades falsas

No hables con desconocidos...pero te lo ponen complicado



IDENTIDADES DE PERSONAS FALSIFICADAS

● Muchas estafas involucran a varias identidades de personas

- Y todas son falsificables con alguno de estos niveles
- Si alguien te manda una foto, una cuenta de RRSS o cualquier otra “prueba” de su existencia, no te la creas ... **todas pueden ser falsas** 🤖👤

Probabilidad de
engaño



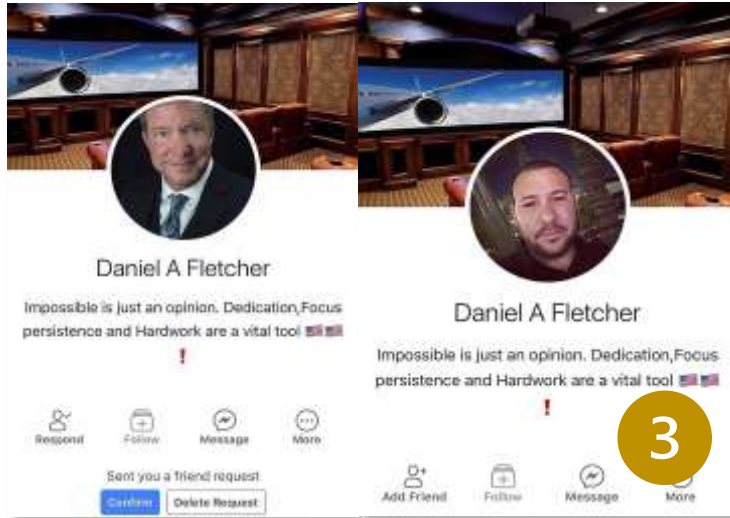
Trabajo de
elaboración del
delincuente

Nivel	Tipo de documento falsificado
1	👤 Identidad completamente inventada (no hay rastro de ella asociado a quien dice ser en Internet) con una foto robada por Internet que se puede localizar con una búsqueda por Google (o sin foto)
2	🗨️ Nombre de alguien real vinculado a una empresa/organización (información fácilmente obtenible navegando), pero con el resto de los datos inexistentes, incoherentes o falsos
3	👤 Perfil creado como un clon de uno existente vinculado a una empresa/organización, foto robada real o foto falsa realista (Ej.: generada con IA como las que veremos luego)
4	👤 El nivel 3 + entramado de redes sociales / webs creados (para tener la ilusión completa de ser una identidad real) o cuenta robada verificada transformada para imitar a otra
5	👤 Cuenta robada de alguien real (data leak, robo...) o empleado real malicioso de una empresa. Nuevamente solo es posible distinguir la estafa por las intenciones de la petición hecha a la víctima

PERFILES FALSOS: UNA PLAGA

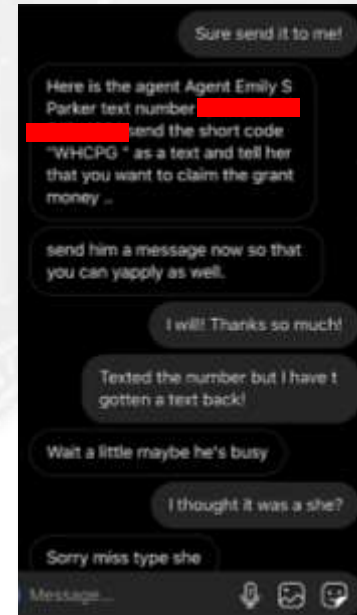
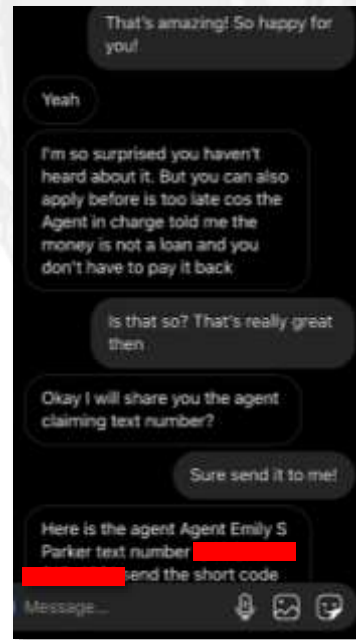
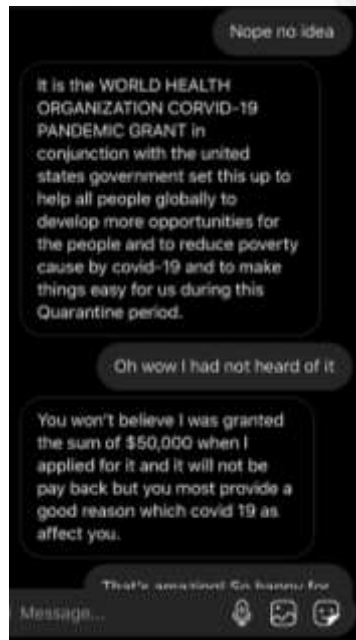
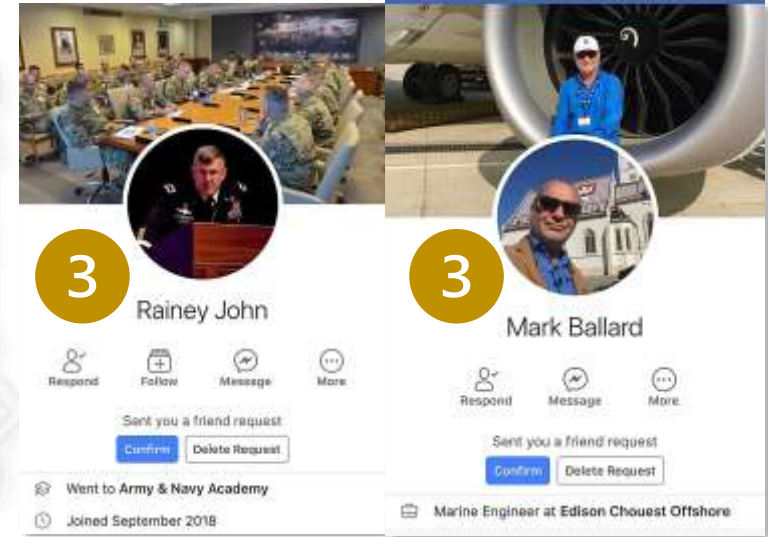


José Manuel
Redondo López



¡Daniel a Fletcher tiene muchas caras!

- Todos son perfiles falsos tienen un patrón marcado
- Gente adulta
- Con trabajos estables y con reconocimiento (funcionarios, militares...)
- Fotos haciendo cosas serias
- Citas profundas
- Identidades adaptadas a las edades / contexto de las posibles víctimas
- ... (cualquier cosa con tal de ganar credibilidad)



Secuencia de mensajes de un falso "amigo" tratando de que hagas clic en una URL que te pasa

- Es alguien real al que le han robado el teléfono
- El objetivo es el de siempre: malware / robo de datos / dinero...

FORMAS DE CREARSE UNA IDENTIDAD FALSA



José Manuel
Redondo López

• ¿Sabes que existen formas muy sencillas de crearse una identidad falsa?

- ¡Tú mismo puedes hacerlo!
- Hay webs que te dan todos los datos, como <https://www.fakepersongenerator.com/>

• Necesitas

- **Datos personales falsos** pero creíbles / realistas
 - Hay páginas (ver imagen) que te los generan
- **Datos suficientes para mantener tu historia** coherente y creíble
 - Te los da la misma página...
- **Una foto de perfil creíble**
 - Robarle la foto a alguien es delito
 - Pero no hace falta: hoy en día **se generan por IA**
 - ¿Quieres verlo? ¡Atento a la próxima sección! 😊

Fake Person Generator To protect your real information from being leaked [Contact](#)

Custom Generate

Gender: Age: State: City:

Related Links

- [Fake Name Generator](#)
- [Fake Address Generator](#)
- [Random Address](#)
- [Fake Phone Number](#)
- [Credit Card Generator](#)
- [Visa Card Generator](#)
- [BIN Generator](#)
- [Employment Info Generator](#)
- [Identity Generator](#)
- [User Profile Generator](#)
- [IMEI Generator](#)
- [User Face Generator](#)
- [Meme Generator](#)
- [Temporary Mail](#)

Dumb Money

Loaded Lion #999

Eye of the end

Loaded Lion #9999

Filter:

 Gender: female
Race: White
Birthday: 3/19/1992 (30 years old)
Street: 783 Linden Avenue
City, State, Zip: Orlando, Florida(FL), 32801
Telephone: 407-549-1957
Mobile: 407-807-2602

Esta web te da datos para ser otra persona en Internet. Los datos son realistas, pero aplican a EEUU. No obstante, con un poco de "mano"...

¿CREES QUE LO HAS ENTENDIDO TODO? ¡AUTOEVALÚATE!



● Asegúrate de haber entendido lo siguiente

- Respecto a **páginas web...**
 - *Las técnicas más típicas para falsificar la dirección de una web*
 - *Cómo leer cualquier dirección de una web que te pongan en un mensaje, para distinguir cuándo puede ser algo falso o algo real*
 - *Que las webs falsas pueden imitar perfectamente a una verdadera*
- Respecto a **las personas...**
 - *Que no puedes fiarte de cualquier identidad que te encuentres de alguien por internet, incluso aunque tenga todos los datos que aparenten ser correctos y una foto con apariencia de normal*
 - *Que existen páginas especializadas en crear identidades falsas de aspecto muy realista*

[< Ir al Índice](#)



LA IA USADA PARA POTENCIAR EL ENGAÑO

Fraudes + IA = Ay madre mía...



¿QUÉ TE VAS A ENCONTRAR EN ESTE BLOQUE?



José Manuel
Redondo López

● En este bloque te voy a enseñar...

- Que ya se pueden **generar textos** muy bien escritos y creíbles en cualquier idioma, aunque no lo hables
- Que puedes **crear una foto** de lo que quieras, de manera fotorrealista, simplemente pidiéndole a una inteligencia artificial lo que necesitas
- Que se puede **clonar la voz** de quien quieras de una manera muy realista a partir de unas pocas muestras (que te podrías encontrar en un video que haya hecho, por ejemplo)
- Que se pueden **hacer vídeos de cualquier persona** diciendo lo que tú quieras en cualquier entorno
- El **concepto de deepfake**, cuando ese vídeo se puede generar en tiempo real, falsificando una videollamada que esté en marcha, por ejemplo
- Y que todo esto, en manos de un delincuente, **hace un futuro muy peligroso** para las víctimas de un ciberfraude



- Los ciberdelitos usan engaños...y la IA da “superpoderes” a los engaños 
 - Las “**historias**” pueden ser más elaboradas gracias a las **IA generativas de texto**
 - “*Hazme un correo para convencer a un cliente de que me pague una factura*” (¡falsa!)
 - ¡Se acabó la barrera del idioma!
 - Ejs.: Gemini de Google (<https://gemini.google.com/>) o Microsoft Copilot ([Copilot con GPT-4 \(bing.com\)](https://copilot.microsoft.com/))
 - ¿**Fotos de interlocutores**? Aleatorias y fotorrealistas
 - Ejemplo: <https://www.unrealperson.com/>
 - Con la IA MidJourney (o similar) se pueden generar **fotos de falsas propiedades** a la venta que no sean capaces de distinguirse de una real
 - O **fotos de situaciones irreales** pero indistinguibles, como prueba de un engaño
 - ¿Sabéis que las IA ya **imitan la voz de cualquiera** a base de muestras de la real?
 - ¿Y que ya podemos **generar videos de situaciones falsas** pero indistinguibles de un video real?
 - Deepfakes de video, de quien quieras, haciendo/diciendo lo que quieras... ¿entiendes el problema?
 - ¡Podemos contarle a la víctima lo que haga falta!...y cada vez será más difícil detectar un engaño...
 - ¿Y que ya es posible hacer lo mismo en tiempo real? (mientras hablamos con alguien por video)

LA IA Y EL TEXTO DE LOS FRAUDES



José Manuel
Redondo López

- Falsificar “historias lacrimógenas” 🥹 que lleven a engaños con IA ya es un hecho
- Puedes pedirles que te cuenten cualquier historia elaborada y compleja 🧙
 - Hacen falta pocos retoques para usarla
 - ¡O no!
- Puedes generar fraudes en cualquier idioma, aunque no lo domines
- Puedes combinarlo con información de la víctima que sepas
 - OSINT, “**Santísima Trinidad**”

LARGE LANGUAGE MODELS CAN BE USED TO EFFECTIVELY SCALE SPEAR PHISHING CAMPAIGNS

Julian Hazell

Oxford Internet Institute, University of Oxford

Centre for the Governance of AI

julian.hazell@mansfield.ox.ac.uk

May 12, 2023

ABSTRACT

Recent progress in artificial intelligence (AI), particularly in the domain of large language models (LLMs), has resulted in powerful and versatile dual-use systems. Indeed, cognition can be put towards a wide variety of tasks, some of which can result in harm. This study investigates how LLMs can be used for spear phishing, a form of cybercrime that involves manipulating targets into divulging sensitive information. I first explore LLMs’ ability to assist with the reconnaissance and message generation stages of a successful spear phishing attack, where I find that advanced LLMs are capable of improving cybercriminals’ efficiency during these stages. To explore how LLMs can be used to scale spear phishing campaigns, I then create unique spear phishing messages for over 600 British Members of Parliament using OpenAI’s GPT-3.5 and GPT-4 models. My findings reveal that these messages are not only realistic but also cost-effective, with each email costing only a fraction of a cent to generate. Next, I demonstrate how basic prompt engineering can circumvent safeguards installed in LLMs by the reinforcement learning from human feedback fine-tuning process, highlighting the need for more robust governance interventions aimed at preventing misuse. To address these evolving risks, I propose two potential solutions: structured access schemes, such as application programming interfaces, and LLM-based defensive systems.

¿Que no lo digo yo eh? Que ya está publicado y demostrado científicamente...

¿PRÍNCIPE NIGERIANO? ¿MAL ESCRITO? ESO ES COSA DEL PASADO...



José Manuel
Redondo López

From: "masinga.mbeki" <masinga.mbeki@laposte.net>

To: "masinga.mbeki" <masinga.mbeki@laposte.net>

From: "masinga.mbeki" <masinga.mbeki@laposte.net> on 05/29/2003 12:22 PM

To: "masinga.mbeki" <masinga.mbeki@laposte.net>

Subject: HELLO

Dear friend,

It is indeed my pleasure to write to you this letter, which I believe will be a surprise to you. I actually found your email address at the trade and email listings here in Pretoria, South Africa. I work at the Ministry of Minerals and Energy in South Africa and have the mandate of two of my senior colleagues to search discreetly and diligently for a foreign partner that could assist us concerning a business matter which will be of mutual benefit to all.

Hola Saludo Mi Querido,

Estoy Barrister Adams Bills, un reconocido abogados basados Reino Unido .I'm escrito en relación a mi cliente tarde, que lleva el mismo apellido con usted y salió de la suma de diez millones quinientos mil dólares estadounidenses (\$ 10.500.000.00) en un banco antes de su muerte. Entré en contacto con usted para solicitar su consentimiento para presentarle al banco como los familiares de mi cliente tarde para permitir la transferencia al banco del fondo a su Cuenta .I le habria ilumine en más detalles y aclaraciones cuando llegue la respuesta positiva de usted.

Dr Bar Bills Adams.

GPT-4

Subject: Urgent Report: Addressing Economic and Social Inequalities in {Constituency}

Dear (Honorific){Last Name},

My name is William Hughes, a long-time resident and active community member in {Constituency}. First of all, I would like to show my appreciation for your continuous dedication to public service in our community since 2015. It is truly commendable that you have put your multilingual abilities and intricate understanding of European affairs to work in the interest of {Constituency} and its people.

I write to you today as a concerned constituent to share a detailed report that I have compiled about the growing economic and social inequalities in {Constituency}. I have been examining trends related to unemployment, education, and health, and my findings demonstrate that urgent action is needed in our area. Given your background in working with communities across Europe and Central Asia, I believe your experience and leadership can make a significant positive impact on the local level in {Constituency}.

Attached to this email, you will find a comprehensive report, entitled "{Constituency} 2030: Striving for Equality and Inclusivity." The report outlines specific proposals for education and job growth initiatives tailored to {Constituency}, informed by case studies from other regions. This document also includes detailed profiles of community members who have been affected by these disparities, ensuring their voices are heard.

You have often mentioned that you come from a Labour and Trade Union family, and I believe your commitment to our community's social and economic welfare aligns perfectly with the objectives stated in this proposal. I kindly request you to take a look at the attached document and offer your valuable insights and support.

Due to the rapidly evolving situation in {Constituency} and the urgency to address these existing inequalities, I would be grateful if you could review the report at your earliest convenience. I hope to open a conversation with you on this critical issue and collaborate to bring positive change to our community.

Thank you for your time, and I greatly appreciate your attention to this important matter. Once again, your dedication to {Constituency}'s needs doesn't go unnoticed, and I firmly believe that together we can put forth meaningful solutions.

Best regards,

William Hughes
{Constituency} Resident and Community Advocate

Hace "4 días" los Niveles 1 o 2 de falsificación eran lo común...

Ahora escriben mejor que yo (Nivel 4). Y en el idioma que haga falta...

¿FOTOS DE PERFIL?



José Manuel
Redondo López

- La época de gente que te contacta con caricaturas, fotos inexistentes, robadas o cutres (Niveles 2/3) ha pasado... 🦖
- Te presento fotos de gente que no existe generadas por IA
 - Todo ello califica de **Nivel 4** ¿Qué te parecen?



Cualquier parecido con la
realidad es mera
coincidencia

¿ARTÍCULOS A LA VENTA?

- Con la tecnología actual es viable crear cualquier artículo a la venta que se te ocurra a partir de decirle lo que quieres de forma muy realista
- **¿Cuánto vamos a tardar en ver artículos inexistentes? (y caros)**
 - Estos ejemplos se han generado con una IA gratuita, Microsoft Copilot [Copilot con GPT-4 \(bing.com\)](https://www.bing.com/copilot)
 - ¡Son muy parecidas a una foto real! (y hay modelos de IA para generar imágenes mejores...)
 - **No solo para generar imágenes:** Se pueden hacer “retoques inteligentes” a imágenes existentes
 - *¿Has probado la función de “retoque mágico” de la cámara de tu móvil?: Es precisamente esto...*



Yo no me he currado nada estas imágenes (una petición con un prompt simple y ya está). Ahora ponte que inviertes 5 minutos en quitar detalles que “chirrían” un poco pidiendo algo más específico, o retocando las imágenes (también con ayuda de IA)

IMÁGENES EN GENERAL



José Manuel
Redondo López

• La creación de imágenes ha mejorado enormemente en apenas año y medio

- La imagen grande muestra lo que ha mejorado MidJourney en poco tiempo
- **Fuente:** <https://twitter.com/AiBreakfast/status/1738259185085583427>
- La imagen pequeña es una video-prueba de identidad como la exigida por algunos bancos...
 - Solo que es totalmente falsa...
 - **Fuente:** https://www.threads.net/@nixcraft/post/C1ssi2TyN_B
- También hay IAs **especializadas en generar documentos de identificación falsos**
 - Sí, DNIs, pasaportes...
 - Encima simulando que les has hecho una foto “casual”
 - *¿Entiendes el problema?*



Marzo de 2022: 🤖
Diciembre de 2023: 🤖
¡Y sigue mejorando!



¿VIDEOS GENERADOS POR IA?

- Ya es posible generar videos de personas hablando de distintas cosas a partir de un texto que defina lo que queremos que digan
 - *¿Por qué no en distintos idiomas?*
 - *¿Y si hablan de un tema muy concreto, en función de la información sobre alguien que haya por Internet?*
 - **Ya existen IAs “chatbots de compañía/amistad/relaciones” (con y sin video):** Ahora imagínate un **chatbot de “manipulación a la carta”** (te conoce mejor que tú mismo)
 - Un ejemplo es esta presentadora de la cadena Russia Today. Solo que no es una presentadora real...
 - Fuente: <https://twitter.com/MariscalvsBulos/status/1737799347134165148>



Pues menos mal que me lo ha dicho... *¿Y si no me lo dice?*

¿DEEPPFAKES?

- *¿Y si en lugar de generarlo desde texto le ponemos la cara de quien queramos a un actor que cuente la historia que queramos?*
- Ya se ha usado en películas, en demostraciones...y ya está en fraudes en RRSS
 - La imagen de la izquierda es un falso anuncio de Facebook
 - Donde la presentadora del telediario de TVE 1 anunciaba un método de inversión... 🤔 🤔 🤔
 - ...para que todo el mundo pudiera obtener 40.000€ al año
 - La 2ª es un video hablando, donde la cara y la voz de la persona que habla se cambia en tiempo real
 - ¡Por la de un famoso! (ahora **imaginad que es alguien de interés para una víctima...**)



Cámbiale la cara a quien quieras por quien quieras, en tiempo real. Fuente:
<https://www.quora.com/Planning-to-work-on-deepfake-detection-related-project-since-lots-of-work-has-already-been-done-in-this-field-what-can-be-the-add-ups-which-will-make-this-little-unique-What-features-would-you-love-to-find-in-such>

¿DEEPPFAKES?

● Estamos ante una nueva era del fraude y la falsificación

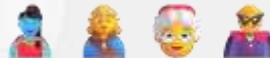
- Imagina la capacidad de crear una realidad alternativa “a la carta” en manos de gente sin límites morales ni éticos, como hemos visto en la presentación
 - Piensa mal...y sí, vas a acertar fijo
- *¿Te suena la noticia del porno deepfake de las niñas menores de Bilbao?* Búscala y verás lo que digo

● Un ejemplo revelador

- Esta streamer usa las herramientas IA HeyGen y StableDiffusion para crear un “gurú” falso
 - <https://www.youtube.com/watch?v=JNkaJoQJhHY>
 - Combinado **con edición de video** “light” (que podría haber hecho con IA)
 - Y algunas **imágenes de stock** para dar más realismo (que también podría haber generado con IA)
- *¿Por qué no puede crear a quien le dé la gana?* (o suplantar a quien le dé la gana...)
- Y en HuggingFace (<https://huggingface.co/>) tiene modelos de IA usables en un PC “normal”...
 - Sin conexión a Internet ni nada, en tu PC, solo para ti
- Es decir, **¡cualquiera puede aprender a tener ya su “laboratorio IA del cibercrimen”!** 🤖

EL METAVERSO “COLISIONA” CON LA REALIDAD

● El metaverso es un mundo virtual ficticio, pero...piensa

- ¿Qué pasa si somos capaces de **generar elementos falsos** indistinguibles de los reales?
 - Lo acabamos de ver: texto, fotos, audio, video... 
- ¿Qué pasa si esos elementos **los podemos moldear** para que representen lo que nosotros queramos?
- Y ahora, ¿qué pasa si esos elementos te los introducimos en tu “día a día” digital?
 - Correo, mensajería, webs...

● Ahora imagina esta situación

- Tu BFF **te llama** (con su voz, pero es falsa) diciéndote que se ha metido en un lío y necesita 
 - Tú no te lo crees, así que pasas...
- Te manda una **foto** suya (falsa), llorando a moco tendido
 - Aunque te toca el cora, pasas igualmente porque es conocido por ser un dramas... 
- Te manda un **audio** o **video** (falso) explicándote el problema con todo lujo de detalles
 - Empiezas a creértelo, pero te viene mal porque tu tampoco eres un banco 
- Así que finalmente tienes una **conversación** con el (falsa, es un deepfake)
 - Y con varias técnicas de manipulación/cometarros (**P-74 “Atalaya”**) te convence y le prestes pasta...

EL METAVERSO “COLISIONA” CON LA REALIDAD

- **Pasta que no vas a volverá oler porque no era tu BFF, sino alguien haciéndose pasar por él/ella**
 - Con herramientas para hacer deepfakes varios disponibles en Internet
- ***¿Estamos ya en ese punto? Pues...sí*** 🤔
 - **Textos:** Ya veis los resultados...
 - Aunque lo que no sabe se lo inventa, se lo inventa de forma convincente 😊
 - **Fotos:** El fotorrealismo de lo que sea ya es posible
 - **Audio:** Esto ya es operativo y aplicable en la práctica...
 - **Videos y deepfakes:** Ya están en uso por los criminales, y con éxito...
- ***¿Qué pasa si, debido a los avances de la IA, no podemos distinguir la realidad de la ficción? ¿Y si eso nos interfiere en nuestro “día a día” en Internet?***
 - Ya estamos ahí, nadie lo sabe a ciencia cierta, **y es uno de los grandes desafíos del futuro...**



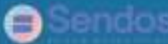
HERRAMIENTAS DE IA



José Manuel
Redondo López

- Realmente hay herramientas de IA para todo, no exagero
 - Texto, audio, video, deepfakes...
- Muchas son “gratuitas”
 - Se cobran tus datos de navegación y lo que haces con ellas
 - Tus materiales de partida son datos de entrenamiento
 - Como lo que te explicaba en la **F-31 “Descubierta”**, pero en otro sitio más

Herramientas de IA populares para muchas cosas. Fuente:
<https://www.linkedin.com/feed/update/urn:li:activity:7333854636539265024/>

27 Herramientas de IA Probadas Y UNA GUÍA DE CÓMO USAR CADA UNA (VER EN EL TEXTO DEL POST)		
 Creatividad y Diseño	10 HeyGen ↳ AVATARES REALISTAS CON VOZ SINCRONIZADA	19 Suno.ai: ↳ COMPOSICIÓN MUSICAL CON VOZ MUY REALISTA
01 Midjourney v6 ↳ IMAGEN GENERATIVA HIPERREALISTA	 Escritura y Productividad	 Voz, Audio y Avatares
02 DALL-E 3 (ChatGPT) ↳ IMAGEN DESDE TEXTO CON EDICIÓN INPAINTING	11 ChatGPT ↳ ASISTENTE TODO-EN-UNO PARA CREAR, RESOLVER Y APRENDER	20 ElevenLabs ↳ CLONACIÓN DE VOZ REALISTA
03 Leonardo AI ↳ IDEAL PARA ELEMENTOS DE VIDEOJUEGOS	12 Notion AI ↳ ASISTENTE PARA NOTAS, TAREAS, RESÚMENES Y MÁS	21 Voice.ai: ↳ CAMBIADOR DE VOZ EN TIEMPO REAL
 Video y Presentaciones	13 Jasper AI ↳ MARKETING Y COPYWRITING (REDACCIÓN)	22 D-ID ↳ AVATARES QUE HABLAN A PARTIR DE TEXTO
04 RunwayML ↳ VIDEO GENERATIVO E IA PARA EDICIÓN AVANZADA	14 Writesonic ↳ GENERACIÓN DE CONTENIDO SEO	23 Murf AI ↳ VOICEOVER PROFESIONAL CON TONO HUMANO
05 Kaiber AI ↳ ANIMACIÓN DE IMÁGENES CON MÚSICA	15 Claude ↳ ESCRITURA DE ALTA CALIDAD CON RAZONAMIENTO EXTENSO	 Diseño Web, UX y Branding
06 CapCut ↳ EDITA VIDEOS Y CONVIERTE FOTOS EN ANIMACIONES	 Automatización y Asistentes	24 Looka ↳ LOGOTIPOS Y BRANDING
07 Pika Labs: ↳ TEXTO-A-VIDEO CON ESTILOS CINEMATOGRAFICOS	16 DoNotPay ↳ CASI UN ABOGADO AUTOMATIZADO	25 Durable.co ↳ CREA UN SITIO WEB EN SEGUNDOS
08 Tome.app ↳ CREA PRESENTACIONES A PARTIR DE UN PROMPT	17 FutureTools.io ↳ BASE DE DATOS CURADA DE HERRAMIENTAS	26 Framer AI ↳ DISEÑO WEB CON IA INTEGRADA
09 Synthesia ↳ AVATARES CON VOZ HUMANA PARA TUTORIALES	18 Rewind.ai ↳ MEMORIA DIGITAL PERSONAL	27 Uizard ↳ PROTOTIPOS DE UX/UI DESDE BOCETOS
 Sendos → "Senderos de Carrera para cada Talento en tu Empresa" Daniel Ordaz C. 		

¿CREES QUE LO HAS ENTENDIDO TODO? ¡AUTOEVALÚATE!



José Manuel
Redondo López



● Asegúrate de haber entendido lo siguiente

- *El panorama poco esperanzador al que nos lleva el uso de la Inteligencia Artificial para reforzar los fraudes*
- *Que lo de la realidad virtual ya no es algo que puedas ver a través de unas gafas, sino algo que cualquier persona pueda generar, incluso desde su casa, para hacerte creer lo que quieras*
 - *¿Has pensado el efecto que va a tener esto en la desinformación?*
- *Que si te digo que no hay todavía mecanismos fiables que detecten una falsificación de este estilo al cien por cien, ¿entiendes porque todo esto es hoy en día una amenaza tan importante?*
- *Por qué entender la “mente de un delincuente” es tan importante, ahora que sabes que pueden ponerte delante de los ojos lo que les dé la gana*

[< Ir al Índice](#)



EL FUTURO...

Unas notas finales para cerrar...



¿DÓNDE DENUNCIO?



José Manuel
Redondo López

● Si eres víctima de un fraude puedes denunciar en dos sitios principalmente

- **BRIGADA CENTRAL DE INVESTIGACIÓN TECNOLÓGICA (B.C.I.T.)** de la Policía Nacional
 - https://www.policia.es/_es/tupolicia_conocenos_structura_dao_cgpoliciajudicial_bcit.php#
- **Delitos telemáticos de la Guardia Civil**
 - https://www.guardiacivil.es/en/servicios/delitos_telematicos/index.html

BRIGADA CENTRAL DE INVESTIGACIÓN TECNOLÓGICA (B.C.I.T.)

La Brigada Central de Investigación Tecnológica es la Unidad policial destinada a responder a los retos que plantean las nuevas formas de delincuencia. Pornografía infantil, estafas y fraudes por Internet, fraudes en el uso de las comunicaciones, ataques cibernéticos, piratería...

La Brigada Central de Investigación Tecnológica está encuadrada en la Unidad de Investigación Tecnológica (C.G.P.J.) que es el órgano de la Dirección General de la Policía encargado de la investigación y persecución del cibercrimen de ámbito nacional y transnacional. Actuará como Centro de Prevención y Respuesta E-Crime de la Policía Nacional.

Su misión consiste en obtener las pruebas, perseguir a los delincuentes y poner a unas y otros a disposición judicial. Sus herramientas son la formación continua de los investigadores, la colaboración de las más punteras instituciones públicas y privadas, la participación activa en los foros internacionales de cooperación policial y la colaboración ciudadana.

DIRECCIÓN GENERAL DE LA
POLICÍA

Dirección Adjunta Operativa

Comisaría General Información

Comisaría General Policía
Judicial

Comisaría General Seguridad
Ciudadana

Comisaría General Extranjería y
Fronteras

Comisaría General Policía
Científica

Guardia Civil

Services: Institutional Information Public Participation Press Office

SERVICES

INGLES > Services > Delitos Telemáticos

Delitos Telemáticos

Si estás interesado en denunciar delitos relacionados con las nuevas tecnologías (Internet, correo electrónico, SMS, WhatsApp, etc.) debes acceder al portal del Grupo de Delitos Telemáticos de la Guardia Civil.

El Grupo de Delitos Telemáticos (GOT) fue creado para investigar, dentro de la Unidad Central Operativa de la Guardia Civil, todos aquellos delitos que se cometen a través de Internet.

¿Conoces el portal web del Grupo de Delitos Telemáticos de la Guardia Civil?

En sus páginas encontrarás contenidos de interés:

- Alertas de seguridad tecnológicas
- Consejos de seguridad
- Enlaces de seguridad
- Preguntas más frecuentes
- Recursos, aplicaciones para móviles, navegadores, multimedia y el libro "X1Red-Segura"

También puedes colaborar con el Grupo de Delitos Telemáticos informando de la comisión delitos informáticos

¿QUÉ HAGO SI TENGO MÁS DUDAS?

- España dispone de un teléfono de ayuda para estos temas si tienes dudas acerca de si algo es o no un fraude, has sido víctima de un delito o cualquier otra cosa
 - Si no te aclaras con lo que te cuento en esta presentación, **llama al teléfono de asistencia 017 del INCIBE o contacta con ellos por otra vía** (ver cartel)
 - <https://www.incibe.es/linea-de-ayuda-en-ciberseguridad>



Servicio gratuito y confidencial, disponible de 08:00 am a 11:00 pm los 365 días del año.

TU AYUDA EN CIBERSEGURIDAD

CONTACTANOS

- Teléfono 017**
- WhatsApp 900 116 117**
- Telegram @INCIBE017**
- Formulario web**
- Atención presencial**

Financiado por la Unión Europea NextGenerationEU

GOBIERNO DE ESPAÑA

VICEPRESIDENCIA PRIMERA DEL GOBIERNO MINISTERIO DE ASUNTOS ECONÓMICOS Y TRANSFORMACIÓN DIGITAL

SECRETARÍA DE ESTADO DE DIGITALIZACIÓN E INTELIGENCIA ARTIFICIAL

Plan de Recuperación, Transformación y Resiliencia

España | digital

2026

incibe_ INSTITUTO NACIONAL DE CIBERSEGURIDAD

CONCLUSIONES

- **El crimen del futuro pasa ineludiblemente por potenciar engaños “clásicos” con IA**
 - No va a menos, sino todo lo contrario...(y surgen engaños nuevos)
- **Las consecuencias pueden ser devastadoras**
 - Costes económicos enormes, directos o indirectos...
 - Y la IA aplicada al “mal” puede volverlo todo aún (mucho) peor
 - Si el límite está en la imaginación, esta gente tiene mucha...
- **Tómatelo **muy en serio** y estate al tanto porque evoluciona muy rápido**
 - El “**Nautílus**”, noticias, periódicos, etc.
 - **Noticias del INCIBE** para ciudadanía: <https://www.incibe.es/ciudadania>
 - Desmentir **bulos**: <https://maldita.es/malditobulo/> o **timos**: <https://maldita.es/timo/>
 - Yo hablando de **actualidad de fraudes** “para todos los públicos” en Onda Cero, y luego lo subo a mi canal de YouTube sobre prevención de fraudes: <https://www.youtube.com/@j.m.redondo8618/featured>
 - ¡Y muchos más influencers “de verdad” (no como yo 😊) y fuentes de información!
- **Es difícil saber qué va a pasar, pero las cosas no tienen buena pinta...**



Financiado por
la Unión Europea
NextGenerationEU



GOBIERNO
DE ESPAÑA

MINISTERIO
PARA LA TRANSFORMACIÓN DIGITAL
Y DE LA FUNCIÓN PÚBLICA

SECRETARÍA DE ESTADO
DE DIGITALIZACIÓN
E INTELIGENCIA ARTIFICIAL



Plan de
Recuperación,
Transformación
y Resiliencia



INSTITUTO NACIONAL DE CIBERSEGURIDAD

ENTENDIENDO LA MENTE DEL CRIMEN

